Universidad Tecnológica Nacional

Facultad Regional Mendoza

Departamento de Sistemas de Información

Tecnicatura Universitaria en Programación

Notificación Automatizada de Vulnerabilidades mediante Integración de Fuentes CVE y Orquestación con n8n

Estudio de caso ante la reforma del enriquecimiento de la NVD

Autor: Lorenzo Espetxe

Director de tesis: Alberto Cortez

Tutor: Ariel Enferrel

Línea de investigación: Ciberseguridad aplicada · Automatización de procesos de seguridad · Vulnerability & Patch Management · Integración n8n

Octubre de 2026

Resumen

Los flujos de detección automatizada cruzan las vulnerabilidades publicadas con el inventario de una organización, y dependen de que sus fuentes mantengan su comportamiento. Este estudio de caso documenta qué le ocurrió a una arquitectura de ese tipo cuando, en abril de 2026, el National Institute of Standards and Technology (NIST) restringió el enriquecimiento de la National Vulnerability Database (NVD) a un subconjunto priorizado de vulnerabilidades. Una Prueba de Concepto orquestada con n8n, que consultaba la NVD por los identificadores de producto de un inventario simulado de 30 activos, dependía de ese enriquecimiento: una respuesta vacía no registra ningún error y es indistinguible de la ausencia de amenazas.

El artefacto se rediseñó para ingerir todo lo publicado y correlacionar localmente por dos vías: el dato formal del NIST y, en su ausencia, una inferencia por los nombres de fabricante y producto que declara cada registro. Una campaña de veintiocho corridas diarias, entre agosto y septiembre de 2026, midió la cobertura, la precisión de la inferencia, la madurez de los datos de priorización y el cuello de botella de la detección.

La demora de la NVD no retrasó el dato de correlación: lo dejó fuera del alcance del flujo. La NVD publicó la configuración con una mediana de ocho días, y el flujo deja de revisar cada vulnerabilidad antes de que cumpla tres; en el 82,2 % de las correlacionadas, el dato no llegó a tiempo. El rediseño recuperó casi toda la detección por vulnerabilidad, 914 de 924, pero no los 2.112 pares de las estaciones con Windows 10, cuyo nombre la inferencia no reconoció y cuyo dato formal llegó cuando el flujo ya no las miraba. Fuera de Windows Server, la inferencia se equivocó en casi uno de cada cinco casos. Como resultado, 8 de las 17 notificaciones correspondieron a correlaciones falsas. En la priorización, ninguna notificación cambió con información madura: la explotación confirmada del catálogo de CISA fue necesaria en 10 de las 17, y la probabilidad de explotación no decidió ninguna. Lo que limitó al artefacto no fue su procesamiento, sino lo que recibió de la fuente, la ventana con que la consultó y la regla con que comparó los nombres.

Palabras clave: Gestión de Vulnerabilidades, National Vulnerability Database, Correlación CPE, Enriquecimiento de Vulnerabilidades, Orquestación Automatizada, Priorización Basada en Riesgo, Operaciones de Seguridad (SecOps).

Abstract

Automated detection workflows cross-reference published vulnerabilities with an organization's inventory, and they depend on their sources keeping their behavior. This case study documents what happened to an architecture of this kind when, in April 2026, the National Institute of Standards and Technology (NIST) restricted the enrichment of the National Vulnerability Database (NVD) to a prioritized subset of vulnerabilities. A Proof of Concept orchestrated with n8n, which queried the NVD by the product identifiers of a simulated inventory of 30 assets, depended on that enrichment: an empty response records no error and is indistinguishable from the absence of threats.

The artifact was redesigned to ingest everything published and to correlate locally through two paths: NIST's formal data and, in its absence, an inference from the vendor and product names that each record declares. A campaign of twenty-eight daily runs, between August and September 2026, measured coverage, the precision of the inference, the maturity of the prioritization data, and the detection bottleneck.

The NVD's delay did not postpone the correlation data: it placed it out of the workflow's reach. The NVD published the configuration with a median of eight days, and the workflow stops reviewing each vulnerability before it is three days old; for 82.2% of the correlated vulnerabilities, the data did not arrive in time. The redesign recovered almost all detection per vulnerability, 914 of 924, but not the 2,112 pairs on the Windows 10 workstations, whose name the inference did not recognize and whose formal data arrived when the workflow was no longer looking at them. Outside Windows Server, the inference was wrong in almost one in five cases. As a result, 8 of the 17 notifications corresponded to false correlations. For prioritization, no notification changed with mature information: confirmed exploitation from the CISA catalog was necessary in 10 of the 17, and exploitation probability decided none. What limited the artifact was not its processing, but what it received from the source, the window with which it queried it, and the rule with which it compared names.

Keywords: Vulnerability Management, National Vulnerability Database, CPE Correlation, Vulnerability Enrichment, Automated Orchestration, Risk-Based Prioritization, Security Operations (SecOps).

Tabla de Contenidos

Resumen ..... **i**
Abstract ..... **ii**
Lista de siglas ..... **v**
Capítulo 1: Introducción **1**
1.1 Contexto del problema 1
1.2 Planteamiento del Problema 3
1.3 Preguntas de Investigación 4
1.4 Justificación e impacto de la investigación 5
1.5 Objetivo general 6
1.6 Objetivos específicos 6
1.7 Alcance y Limitaciones 7
1.8 Hipótesis 10
Capítulo 2: Marco Teórico **12**
2.1 Estado del arte 12
2.2 Gestión de vulnerabilidades (VM) y gestión de parches (PM) 14
2.3 Nomenclatura y bases de datos públicas (CVE, NVD y CPE) 15
2.4 Priorización: del CVSS al riesgo contextual y predictivo 16
2.5 Automatización en ciberseguridad y el modelo Human-in-the-Loop 18
2.6 Gestión de activos tecnológicos (ITAM) y su rol en SecOps 19
2.7 Orquestación tecnológica y reproducibilidad metodológica 19
2.8 Bases de datos relacionales y trazabilidad empírica 20
2.9 Descentralización del dato de correlación 21
Capítulo 3: Marco Metodológico **23**
3.1 Tipo de investigación 23
3.2 Enfoque metodológico 23
3.3 Diseño de investigación 24
3.4 Dimensionamiento y justificación del entorno simulado 26
3.5 Operacionalización de variables 28
3.6 Definición formal del Índice de Riesgo Compuesto (IRC) 30
3.7 Técnicas de recolección de datos 33
3.8 Criterios de cómputo y exclusiones 36
3.9 Herramientas tecnológicas e infraestructura 38
3.10 Descripción de la Arquitectura de Flujos 40
3.11 Mecanismo de notificación y estructura de las alertas 44
3.12 Procedimiento 45
3.13 Cronograma de actividades 48
Capítulo 4: Desarrollo de la Investigación **51**

4.1 El entorno contenerizado 51
4.2 El esquema de datos 52
4.3 El inventario de activos simulados 55
4.4 El criterio de correlación 57
4.5 Los puntos de decisión del flujo 59
Capítulo 5: Resultados 61
5.1 Cobertura de correlación: qué vulnerabilidades alcanzó el artefacto y cuáles se le escaparon 61
5.2 Precisión de la vía de inferencia: cuántas de sus correlaciones eran correctas y qué errores cometió 68
5.3 Momento de la priorización: cuánto cambió el índice cuando maduró la información 76
5.4 Ubicación del cuello de botella: qué tramo determinó el momento de la detección 83
5.5 Fallas silenciosas: cómo se distinguió un resultado nulo legítimo de una falla 90
5.6 Notificaciones emitidas: qué hizo el tramo final del flujo con los pares que recibió 91
Capítulo 6: Conclusiones 93
6.1 Respuesta a la pregunta principal 93
6.2 Cumplimiento de los objetivos específicos 94
6.3 Alcance de las conclusiones 95
Capítulo 7: Recomendaciones 97
7.1 Correcciones propuestas al flujo 97
7.2 Inventario y modelo de datos 100
7.3 Priorización y notificación 101
7.4 Líneas de trabajo futuro 103
Capítulo 8: Referencias 105
Capítulo 9: Anexos 110
Anexo A. Diagnóstico previo del inventario (mayo a julio de 2026) 110
Anexo B. Paquete de reproducibilidad 111
Anexo C. Diccionario de datos del esquema relacional 114
Anexo D. Período de estabilización y apertura de la recolección 119
Anexo E. Revisión de la vía formal 121

Lista de siglas

Sigla	Significado
ACVRM	*Automated Context-Aware Vulnerability Risk Management*
ADP	*Authorized Data Publisher* (publicador autorizado de datos)
API	Interfaz de programación de aplicaciones
CIS	*Center for Internet Security*
CISA	*Cybersecurity and Infrastructure Security Agency*
CMDB	*Configuration Management Database*
CNA	*CVE Numbering Authority*
CPE	*Common Platform Enumeration*
CVE	*Common Vulnerabilities and Exposures*
CVSS	*Common Vulnerability Scoring System*
EPSS	*Exploit Prediction Scoring System*
FIRST	*Forum of Incident Response and Security Teams*
HITL	*Human-in-the-Loop*
IRC	Índice de Riesgo Compuesto
ITAM	*IT Asset Management*
ITIL	*Information Technology Infrastructure Library*
JSON	*JavaScript Object Notation*
KEV	*Known Exploited Vulnerabilities*
MISP	*Malware Information Sharing Platform*
MTTR	Tiempo Medio de Remediación
NIST	*National Institute of Standards and Technology*
NVD	*National Vulnerability Database*
OIG	*Office of Inspector General* (Oficina del Inspector General)
PM	Gestión de parches
PoC	Prueba de Concepto
SecOps	Operaciones de seguridad
SLA	Acuerdo de nivel de servicio
SOAR	*Security Orchestration, Automation, and Response*
SSVC	*Stakeholder-Specific Vulnerability Categorization*
VM	Gestión de vulnerabilidades

Capítulo 1: Introducción

1.1 Contexto del problema

Durante la última década, la superficie de ataque de las organizaciones se ha expandido significativamente debido a la rápida adopción de servicios web, infraestructura en la nube y un parque tecnológico heterogéneo que, frecuentemente, carece de documentación exhaustiva. En paralelo, el volumen de vulnerabilidades publicadas creció de forma sostenida: el propio National Institute of Standards and Technology (NIST) informó un incremento del 263 % en la presentación de registros CVE entre 2020 y 2025 (National Institute of Standards and Technology, 2026). En este contexto, la publicación diaria de nuevas vulnerabilidades en repositorios de acceso abierto, como la *National Vulnerability Database* (NVD) y los listados de *Common Vulnerabilities and Exposures* (CVE), plantea un desafío operativo crítico. Específicamente, surge la necesidad de identificar con celeridad cuáles de estas amenazas afectan el inventario tecnológico propio y cuáles requieren la aplicación de un parche de seguridad de manera inmediata.

Actualmente, en diversas instituciones, la gestión de estas amenazas se mantiene como un proceso reactivo y manual. Los analistas de seguridad deben revisar boletines técnicos y cruzar dicha información con su conocimiento del parque instalado para determinar prioridades de mitigación. Este procedimiento resulta inherentemente lento, costoso y susceptible al error humano. La relevancia de esta problemática se acentúa ante la aparición de vulnerabilidades de alto impacto y rápida explotación. En el caso de Log4Shell, menos de dos horas después de su publicación ya se registraba un aumento del rastreo de sistemas vulnerables, y en los días siguientes los intentos de explotación se contaron por millones (Cyber Safety Review Board, 2022). En tales escenarios, la capacidad defensiva radica en la aptitud técnica para detectar, correlacionar y notificar la amenaza dentro de ese margen. Las herramientas de gestión de vulnerabilidades de uso extendido automatizan esa correlación entre los repositorios públicos y el inventario de activos de la organización. El emparejamiento descansa habitualmente en los identificadores normalizados de producto (*Common Platform Enumeration*, CPE), concebidos por el NIST precisamente para que las herramientas identifiquen los productos instalados y apliquen políticas de vulnerabilidad de forma automatizada (Cheikes et al., 2011), y empleados como tales por implementaciones de uso corriente como OWASP Dependency-Track (OWASP Dependency-Track, s. f.). Es el patrón que este trabajo adoptó como punto de partida.

Para abordar esta problemática, este trabajo propuso el desarrollo de un *pipeline* automatizado de vigilancia de vulnerabilidades fundamentado en el motor de orquestación n8n. El sistema se diseñó para monitorear bases de datos públicas una vez por día, correlacionar las vulnerabilidades detectadas con un inventario interno de activos y enriquecer el análisis de criticidad incorporando la probabilidad técnica de explotación (*Exploit Prediction Scoring System*, EPSS) y atributos de exposición predefinidos. Sobre esa base, genera una priorización accionable, emite alertas tempranas y

establece la trazabilidad del ciclo de vida de la notificación utilizando una base de datos relacional en PostgreSQL.

Ese planteo, sin embargo, presuponía un comportamiento de la fuente pública que dejó de estar vigente. En abril de 2026, el NIST abandonó el objetivo de enriquecer la totalidad de los registros que recibe la NVD y adoptó un modelo basado en prioridades: se comprometió a completar los datos de las vulnerabilidades incluidas en el catálogo de vulnerabilidades explotadas conocidas (*Known Exploited Vulnerabilities*, KEV) que mantiene la *Cybersecurity and Infrastructure Security Agency* (CISA), de las que afectan software utilizado por el gobierno federal estadounidense y de las que afectan software designado como crítico (National Institute of Standards and Technology, 2026). El propio organismo no publicó una estimación de qué proporción del volumen anual representan esas tres categorías, de modo que la magnitud de la cobertura remanente debe establecerla cada organización sobre su propio inventario. Para el resto, según la política anunciada, los registros quedan categorizados como de prioridad mínima, sin programación de enriquecimiento inmediato, salvo que un usuario lo solicite expresamente al NIST. La distinción tiene consecuencias de diseño: un dato demorado se resuelve esperando o reintentando, mientras que un dato que no está previsto obliga a buscarlo en otra parte, y el problema de latencia se convierte en uno de arquitectura de fuentes. Además, aun cuando llega, el dato de correlación se incorpora con demora respecto de la publicación de la vulnerabilidad, un retraso que la NVD arrastra desde febrero de 2024 (sección 2.1) y que el apartado 5.4.3 mide sobre este caso. La correlación entre una vulnerabilidad y el inventario propio, que es precisamente el paso sobre el que se apoya la detección automatizada, dejó así de estar garantizada por la fuente.

Así ocurrió con el sistema desarrollado en este trabajo. Sus consultas por los identificadores del inventario dependían de ese dato: una vulnerabilidad que todavía no lo tenía quedaba fuera de la respuesta sin que el flujo registrara un solo error, de un modo indistinguible de la ausencia legítima de vulnerabilidades. En consecuencia, la arquitectura se reestructuró: dejó de consultar a la fuente por cada activo y pasó a ingerir la totalidad de lo publicado para resolver la correlación de forma local. Desde entonces, la correlación se resuelve por dos vías: la **vía formal**, que emplea el identificador CPE publicado por el NIST cuando existe, y, en su ausencia, la **vía de inferencia**, que deduce la correspondencia comparando los nombres de fabricante y producto declarados en el registro de la vulnerabilidad con los del inventario.

Esta investigación se sitúa en la convergencia de la gestión de vulnerabilidades y la automatización de procesos de seguridad operativa (SecOps). Su contribución, sin embargo, no reside en demostrar que un sistema de este tipo puede construirse con herramientas de código abierto, algo que la literatura ya documenta, sino en estudiar qué le ocurre cuando la fuente pública de la que depende modifica su comportamiento: qué capacidades pierde, cuáles pueden recuperarse mediante un rediseño y qué obliga a cambiar en su construcción.

1.2 Planteamiento del Problema

El problema que motivó esta investigación es la brecha temporal y organizativa que se abre entre la publicación pública de una vulnerabilidad y su efectiva notificación y remediación dentro de los entornos corporativos o institucionales. Esa brecha ha sido tradicionalmente consecuencia de la falta de implementación de mecanismos automatizados capaces de integrar, en tiempo real, las fuentes de inteligencia de amenazas con los inventarios de activos internos y de aplicar criterios de priorización contextualizados. A ello se sumó, en el período reciente, una circunstancia de otro orden: una de las condiciones que esos mecanismos requieren para operar —un flujo continuo y confiable de datos de correlación— perdió estabilidad.

El primero de los factores que agravan esa brecha es el volumen. La frecuencia de publicación en las bases de datos de vulnerabilidades genera un flujo continuo de información que vuelve inviable y no escalable la inspección manual. El efecto se agrava en infraestructuras heterogéneas, donde coexisten sistemas operativos, aplicaciones y contenedores con ritmos de actualización dispares, y donde sostener a mano un monitoreo continuo supone un uso ineficiente del capital humano especializado. Los procesos resueltos manualmente adolecen, además, de una trazabilidad débil, deficiencia que esta propuesta aborda mediante un registro centralizado y auditable en PostgreSQL, diseñado para documentar el ciclo de vida de la notificación y la transición de estados de cada vulnerabilidad detectada. El volumen de publicaciones desborda a las organizaciones que intentan seguirlo manualmente y, de hecho, desbordó también a los organismos encargados de procesarlo: el NIST enriqueció casi 42.000 registros CVE durante 2025, un 45 % más que en cualquier año previo, y aun así no logró sostener el ritmo de las presentaciones recibidas (National Institute of Standards and Technology, 2026).

De ese desborde se siguió un segundo factor, de naturaleza distinta por ser externo a la organización: proviene del ecosistema del que se abastece. Ante la imposibilidad de sostener el enriquecimiento universal, el NIST lo restringió a un subconjunto priorizado y, como se describió en la sección anterior, la correlación con el inventario dejó de estar garantizada por la fuente. Ello implica que la brecha puede reabrirse incluso en las organizaciones que ya automatizaron el proceso, y hacerlo de forma inadvertida: un sistema como el estudiado, privado de su dato de correlación, no informa un error, informa que no hay novedades.

El tercer factor concierne a la priorización. Conocer una vulnerabilidad no proporciona, por sí mismo, el contexto interno necesario para estimar su urgencia en una organización determinada, y durante años el orden de atención se estableció a partir de la severidad técnica declarada de cada vulnerabilidad, medida con el Common Vulnerability Scoring System (CVSS). Ese criterio perdió centralidad: la práctica del campo se desplazó hacia esquemas que incorporan la evidencia de explotación activa, la probabilidad estimada de explotación (EPSS) y el contexto del activo afectado —su exposición a redes externas y su relevancia para la continuidad del negocio—, y el desplazamiento alcanzó incluso a la normativa, que dejó de exigir el uso del CVSS como criterio de priorización en el ámbito federal civil estadounidense (véase la sección 2.4). Al volumen inabordable se agrega,

entonces, otra dificultad: decidir con información que proviene de varias fuentes y que no siempre está disponible cuando la decisión debe tomarse.

En ese escenario, la disyuntiva ya no se plantea entre el monitoreo manual y el automatizado. Una organización puede haber automatizado el proceso y quedar igualmente expuesta a ventanas de riesgo prolongadas, si el flujo que construyó descansa sobre un supuesto que la fuente dejó de cumplir. La pregunta que este caso permite examinar es, por lo tanto, qué le ocurrió a una automatización concreta cuando la NVD, la fuente sobre la que fue diseñada, modificó su comportamiento.

1.3 Preguntas de Investigación

El planteamiento anterior sitúa el problema en un caso concreto: una arquitectura de detección cuyo mecanismo de correlación dependía de un dato que la NVD dejó de garantizar. De allí se desprende la pregunta principal que guía esta investigación:

> *¿Qué efectos tuvo la reforma del enriquecimiento de la National Vulnerability Database, adoptada por el NIST en abril de 2026, sobre la arquitectura de detección automatizada desarrollada en este trabajo —basada en la correlación de vulnerabilidades con el inventario mediante identificadores CPE—, en qué medida su rediseño permitió recuperar la capacidad de detección comprometida, y con qué consecuencias para la priorización?*

Para desagregar esa pregunta en términos medibles sobre el artefacto construido, se derivan las siguientes preguntas secundarias:

- **Cobertura de correlación:** sobre las vulnerabilidades publicadas durante la ventana de recolección, ¿qué proporción de las correlaciones con el inventario alcanza cada vía —la del identificador formal del NIST, la del identificador declarado en el registro por quien lo publica, la del aportado por CISA y la vía de inferencia—, tanto en el momento de la detección como al cierre, y cuánto agrega su combinación respecto de depender solo del enriquecimiento de la NVD? La vía de CISA se incluye para contrastar sobre los datos recolectados una política que el organismo declara desde diciembre de 2024 y que documenta la sección 2.3: su aporte esperado es nulo, y lo que la pregunta somete a prueba es si esa política se sostuvo durante la ventana observada.
- **Precisión de la vía de inferencia:** cuando el identificador formal no está disponible, ¿con qué precisión establece la vía de inferencia la correspondencia entre una vulnerabilidad y un activo, y qué clase de error introduce?
- **Momento de la priorización:** ¿en qué medida el índice de riesgo calculado en el instante de la ingesta representa el riesgo efectivo de una vulnerabilidad recién publicada, y cómo varía esa representación conforme madura la información pública disponible sobre ella?
- **Ubicación del cuello de botella:** ¿el factor limitante del tiempo de detección reside en la capacidad de procesamiento del artefacto, en el tiempo que la NVD tarda en publicar el dato de correlación o en la cadencia con que se ejecuta el flujo?

- **Detección de fallas silenciosas:** en la arquitectura estudiada, donde varios defectos de construcción se manifestaron como ausencia de datos y no como errores, ¿qué mecanismos permitieron distinguir un resultado nulo legítimo de una falla?

1.4 Justificación e impacto de la investigación

La justificación operativa de este proyecto radica en la necesidad de transformar la gestión de vulnerabilidades, pasando de un paradigma reactivo y saturado a uno proactivo e impulsado por inteligencia de amenazas. En los entornos de seguridad contemporáneos, los analistas enfrentan una "fatiga de alertas" (Alahmadi et al., 2022) debido al volumen inmanejable de publicaciones diarias de CVE. Al automatizar la detección e integrar multidimensionalmente métricas de inteligencia de amenazas (impacto estático vía CVSS, probabilidad predictiva vía EPSS y confirmación de ataques en curso vía KEV) con el contexto interno de la organización (el nivel de exposición a Internet y la criticidad del activo), esta investigación propone una solución tecnológica orientada a mejorar la priorización y la toma de decisiones. El impacto que persigue en materia de seguridad es el acortamiento de la ventana que media entre la publicación de una vulnerabilidad y su puesta en conocimiento del responsable del activo, junto con una trazabilidad auditable de las acciones de notificación, requisito habitual en marcos de cumplimiento y auditorías de ciberseguridad.

Desde una perspectiva académica, el valor principal de esta tesis reside en documentar, sobre un caso concreto y medido, qué ocurrió con una arquitectura de detección automatizada cuando la NVD restringió el enriquecimiento del que dependía. El trabajo registra, sobre datos propios y fechados, el comportamiento de la fuente en los meses posteriores a la reforma, en un momento en que la literatura académica todavía no la había abordado, y sus conclusiones resultan de interés para toda implementación que dependa, como esta, de la correlación provista por la NVD. A ese aporte se suma el de un artefacto reproducible: la utilización de n8n permite que el flujo de orquestación sea exportado (vía JSON) y auditado nodo por nodo, lo que lo vuelve útil también como instrumento de aprendizaje. Gracias a su documentación, puede utilizarse en laboratorios universitarios, cátedras de operaciones de seguridad (SecOps) y como base para futuras líneas de investigación cuantitativa utilizando el registro histórico almacenado en PostgreSQL.

Finalmente, el proyecto presenta una justificación económica y de transferencia tecnológica. El diseño de la arquitectura se fundamenta íntegramente en el aprovechamiento de plataformas sin costo de licencia —PostgreSQL, de código abierto, y n8n, que se distribuye bajo una licencia propia de uso gratuito—, su despliegue estandarizado mediante contenedores (Docker) y el consumo de interfaces de programación de aplicaciones (API) de acceso público y gratuito (la de la NVD y la del *Forum of Incident Response and Security Teams*, FIRST). Esta decisión de diseño reduce las barreras económicas asociadas al licenciamiento de las soluciones comerciales de tipo SOAR (*Security Orchestration, Automation, and Response*). En consecuencia, el modelo propuesto resulta transferible a instituciones educativas, organizaciones gubernamentales y pequeñas o medianas empresas (pymes) con inventarios de escala comparable, con una inversión mínima de capital, siempre que los contenedores se ejecuten sobre el motor libre de Docker: su aplicación de escritorio

exige una suscripción paga a los organismos de gobierno y a las empresas grandes. Corresponde, sin embargo, precisar el alcance de ese criterio: existen fuentes comerciales que declaran una cobertura de correlación superior a la pública bajo modalidades comunitarias sin costo —entre ellas, VulnCheck NVD++ (Baines, 2024)—, y fueron deliberadamente excluidas del núcleo del artefacto, tanto para no introducir una dependencia sin garantía de continuidad —riesgo que, como muestra el propio caso estudiado, alcanza también a las fuentes públicas— como para preservar el criterio de emplear exclusivamente fuentes públicas y abiertas, que no equivale al de emplear fuentes sin costo.

1.5 Objetivo general

Desarrollar una Prueba de Concepto (PoC) de un sistema automatizado para la detección y notificación proactiva de vulnerabilidades en un entorno de activos simulado, mediante la orquestación con n8n de la API v2.0 de la National Vulnerability Database (NVD) y del análisis de probabilidad de explotación (EPSS vía FIRST), con el propósito de determinar qué efectos tuvo sobre ese sistema la reforma del enriquecimiento de la NVD adoptada en abril de 2026, en qué medida su rediseño —basado en la correlación local por la vía formal y la vía de inferencia— permitió recuperar la capacidad de detección comprometida y con qué consecuencias para la priorización.

1.6 Objetivos específicos

- **Modelar** una base de datos relacional en PostgreSQL que estructure el almacenamiento de vulnerabilidades y permita la correlación lógica entre los identificadores CVE/CPE y los activos del inventario simulado.
- **Construir** un *pipeline* de orquestación en la plataforma n8n que ingiera la totalidad de las vulnerabilidades publicadas en cada ventana temporal y resuelva localmente su correlación con el inventario, mediante la vía formal y, en su ausencia, la vía de inferencia.
- **Integrar** la capacidad de enriquecimiento de datos mediante la API de FIRST para evaluar el *Exploit Prediction Scoring System* (EPSS) de las vulnerabilidades, permitiendo una priorización basada en la probabilidad estimada de explotación.
- **Implementar** un mecanismo de notificación automatizado por correo electrónico que genere alertas proactivas según el nivel de riesgo, integrando el registro de este evento en la base de datos principal para asegurar su trazabilidad operativa.
- **Implementar**, como instrumento de medición, un flujo de reevaluación diferida que recalcule el Índice de Riesgo Compuesto de cada vulnerabilidad detectada con información madura, sin alterar el valor registrado en el momento de la detección, y contrastar ambos valores para determinar en qué medida el riesgo estimado al detectar difiere del estimado con información completa.
- **Medir** la cobertura de correlación alcanzada por cada vía durante la ventana de recolección, y validar la precisión de la vía de inferencia mediante una muestra de casos revisada caso por caso por el autor, con asistencia de un modelo de lenguaje.

- **Comparar** el tiempo que el artefacto tarda en procesar un hallazgo con el tiempo que la NVD tarda en publicar el dato de correlación y con la cadencia de ejecución del flujo, para determinar cuál de ellos gobierna la latencia de detección.
- **Documentar** los efectos de la reforma del enriquecimiento sobre la arquitectura original, los cambios de diseño que exigió y los modos de falla que se manifestaron durante la operación del artefacto, junto con los mecanismos que permitieron detectarlos.

1.7 Alcance y Limitaciones

El alcance de la presente investigación se circunscribe al diseño, desarrollo y validación analítica de una Prueba de Concepto (PoC) enfocada exclusivamente en la fase inicial del ciclo de gestión de vulnerabilidades: la detección, la correlación contextual y la notificación proactiva. A nivel tecnológico, el proyecto contempla la ingeniería de un *pipeline* automatizado orquestado mediante la plataforma n8n, la persistencia de los registros en PostgreSQL y el despliegue de toda la arquitectura en un entorno de pruebas aislado utilizando contenedores Docker. A nivel lógico y algorítmico, el sistema se limita a la integración y evaluación de un modelo de riesgo de cinco variables predefinidas: tres dimensiones de inteligencia externa (CVSS, KEV y EPSS) y dos dimensiones de contexto interno (criticidad operativa y exposición a Internet). El resultado final contemplado dentro del alcance es la generación de alertas priorizadas y la realización de las mediciones enunciadas en los objetivos específicos —cobertura y precisión de la correlación, evolución del índice de riesgo y descomposición de la latencia de detección—, sobre una ventana temporal de recolección declarada. El trabajo contempla además una capa de presentación —un servidor de aplicaciones y una interfaz web— que permite al analista consultar los hallazgos y registrar sobre ellos los estados de revisión. Esa capa acompaña a la Prueba de Concepto y no forma parte de su objeto de estudio: se ejecuta fuera del entorno contenerizado sobre el que se toman las mediciones, no interviene en la recolección, y ninguna de las mediciones que reporta el Capítulo 5 depende de ella, de modo que no figura entre los objetivos específicos.

Varias de las fronteras de este trabajo responden a decisiones deliberadas de alcance. El artefacto obtiene el dato de correlación de una única fuente pública, la NVD, y no incorpora fuentes comerciales; las otras dos vías que contempla la pregunta de cobertura —el identificador declarado en el registro por quien lo publica y el aportado por CISA— no llegan a través de esa fuente, por lo que se miden por fuera del artefacto, al cierre de la campaña; el inventario se mantiene fijo en treinta activos y no se amplía; la recolección se circunscribe a un único período, cuyas fechas y el uso que cada medición hace de sus distintos tramos se detallan en el Capítulo 3; y la validación caso por caso se acota, en la vía de inferencia, a una muestra de 65 casos estratificada por producto del inventario, sorteada entre los 2.018 casos distintos (cada caso es una vulnerabilidad y un producto del inventario) que no corresponden a errores ya confirmados; y en la vía formal, a la revisión completa de las 60 vulnerabilidades cuyos pares coinciden con el activo como producto afectado o carecen de dato en la consulta de cierre. Los errores ya confirmados antes de la revisión se reportan aparte y se suman a la tasa de cada vía (apartado 5.2.1 y Anexo E). Estas decisiones obedecen al nivel

y la duración previstos para el trabajo, y su declaración explícita busca delimitar qué conclusiones puede sostener la evidencia reunida.

Para garantizar el rigor metodológico y la factibilidad del estudio, se establecen fronteras operativas estrictas que delimitan las capacidades del proyecto. La limitación principal radica en que el sistema carece de funciones de remediación activa; no ejecuta la instalación física de parches, no modifica configuraciones en la infraestructura de red ni interactúa con terminales (*endpoints*) reales. En segundo lugar, dado que la arquitectura opera sobre un inventario tecnológico simulado, la variable de "exposición a Internet" no es el producto de un escaneo de puertos en tiempo real, sino un atributo estático predefinido en la base de datos. En tercer lugar, la interfaz de usuario no incorpora mecanismos de autenticación, autorización ni control de acceso basado en roles, dado que la PoC opera en un entorno de pruebas aislado y no pretende replicar las capas de seguridad perimetral de un sistema en producción. En cuanto al mecanismo de notificación, este solo evalúa la primera observación de cada par vulnerabilidad-activo, de modo que toda escalada posterior del riesgo resulta estructuralmente invisible para él; y emite una alerta por cada par y no por vulnerabilidad, por lo que la carga de notificación crece con el número de activos que comparten plataforma. Por último, el modelo de datos arrastra una colisión de nomenclatura: el valor «informativa» designa a la vez una categoría de prioridad y un estado de procesamiento, que son atributos distintos y residen en columnas distintas. No alcanzó a ningún dato, porque las dos columnas son independientes y ninguna consulta las confunde, y no se corrigió: hacerlo habría exigido modificar el artefacto congelado y reescribir las filas ya recolectadas.

El mecanismo de correlación presenta, además, límites que fueron medidos sobre datos propios y que se manifiestan en dos direcciones. La primera es la de las falsas alarmas: correlaciones que el sistema establece sin que la vulnerabilidad afecte realmente al activo. La vía de inferencia no evalúa si la versión instalada cae dentro del rango de versiones que la vulnerabilidad declara afectadas: sobre el servidor de repositorios del inventario, que corre GitLab 16.0.0, la vía correlacionó vulnerabilidades que el aviso del fabricante declaraba a partir de versiones posteriores a la instalada (apartado 5.2.3). Esa ceguera, sin embargo, no le es exclusiva. La vía formal compara únicamente el fabricante y el producto del identificador que publica el NIST, sin evaluar los rangos de versión que ese mismo registro declara ni distinguir los productos vulnerables de las plataformas sobre las que se ejecuta el software afectado; en consecuencia, también puede correlacionar un activo cuya versión no está afectada, o uno que figura en el registro solo como plataforma. La exigencia conjunta de coincidencia en fabricante y producto que aplica la vía de inferencia, por su parte, resulta necesaria pero no suficiente: como la comparación admite coincidencias parciales de cadena, cuando un fabricante nombra sus productos derivados con su propio nombre ambos términos se satisfacen sin que exista correspondencia real. Así ocurre con Jenkins, que publica las fallas de sus complementos con el nombre del producto, mientras el inventario no registra qué complementos tiene instalados cada servidor. El mismo mecanismo alcanzó al firewall, que quedó correlacionado con vulnerabilidades de Cisco IOS XR porque ese nombre contiene el de Cisco IOS (apartado 5.2.3).

La ceguera de versión y la correlación por productos derivados no se corrigieron dentro del artefacto, por decisión deliberada. Resolver la ceguera de versión exige interpretar los rangos que cada fabricante declara con convenciones propias —límites inclusivos y exclusivos, esquemas de versionado no numéricos, pisos ficticios— y definir qué hacer cuando esa interpretación falla, lo que constituye una decisión metodológica antes que técnica. La alternativa más simple, exigir coincidencia exacta de versión, se evaluó y se descartó: el campo de versión que publica la fuente suele indicar el piso de un rango y no la versión afectada, de modo que habría descartado también las correlaciones correctas. El caso de los productos derivados, por su parte, se detectó con la recolección ya en curso, cuando corregirlo habría partido la serie en dos versiones del artefacto. En ambos casos, el error se cuantifica mediante la muestra de validación, que registra, para cada correlación revisada, si es correcta y si la versión instalada cae dentro del rango afectado. La correlación por plataforma, en cambio, no respondió a una decisión: constituye una omisión del diseño, identificada al revisar el código del artefacto con la campaña en curso, que se cuantifica al cierre sin modificarlo.

La segunda dirección es la inversa: vulnerabilidades que afectan a un activo y que la vía de inferencia no logra correlacionar. Ocurre cuando el fabricante intercala texto adicional en el nombre del producto, como en la denominación que Microsoft emplea para las versiones de Windows 10, y cuando el registro público declara al fabricante como no disponible, como sucede con PostgreSQL. En ambos casos la correlación depende enteramente de que la vía formal disponga del dato, y la magnitud de esas pérdidas no es observable desde el propio artefacto, que solo registra lo que logró correlacionar. El apartado 5.2.4 la mide por fuera de él, contra lo que la NVD declaraba afectado al cierre.

Tampoco estas pérdidas se corrigieron. Recuperarlas habría exigido relajar la exigencia conjunta de fabricante y producto —aceptando coincidencias solo por producto cuando el fabricante no está declarado— o incorporar reglas particulares para la nomenclatura de fabricantes concretos. La primera alternativa expone al criterio a la clase de error que la exigencia conjunta previene: en una auditoría sobre 545 vulnerabilidades de una ventana anterior a la campaña, la comparación solo por producto habría generado tres falsos positivos, al emparejar productos de terceros cuyo nombre contiene el de un producto del inventario. La segunda convierte un criterio general en una colección de excepciones. Se optó por conservar el criterio y declarar la pérdida.

Las mediciones tienen, a su vez, un límite temporal. El trabajo no dispone de ejecuciones del sistema bajo el régimen previo de enriquecimiento, por lo que no puede contrastar su comportamiento contra el de ese régimen: que el diseño original habría funcionado bajo el modelo anterior es una inferencia a partir de su lógica, no una observación. Durante la campaña, además, el disparo automático dependió de que el entorno de ejecución local estuviera activo a la hora programada; cuando no lo estuvo, la corrida se ejecutó manualmente o se produjo con demora al reanudarse el equipo. Una corrida se perdió porque, con el equipo recién reactivado, el contenedor no pudo resolver el dominio de la NVD (sección 3.8). Las métricas se computan, por lo tanto, sobre corridas efectivas y no sobre días de calendario.

Otro límite concierne a la información que el artefacto conserva. No registra qué organización publicó cada puntaje de severidad, de modo que el trabajo solo puede deducir su origen por coincidencia de valores (apartado 5.3.2). Y la reconstrucción retrospectiva de la evolución del riesgo es exacta en los componentes cuyo historial publican las fuentes, pero solo aproximada en el de severidad, cuyo historial de revisiones no se consultó (sección 3.6).

Existe, además, una limitación inherente a la arquitectura propuesta: su eficacia depende de interfaces de programación de terceros que escapan al control de esta investigación. Esa dependencia resultó más profunda de lo que el planteo inicial suponía, pues, además de la disponibilidad del servicio y de sus límites de consumo, alcanza a la política de datos del proveedor, que determina qué información se publica y cuál no. Las restricciones operativas que esas interfaces mostraron durante la recolección se describen en la sección 3.9.

En el plano métrico, y al estar el alcance restringido a la detección y la notificación, se excluye el análisis de variables de resolución, tales como el Tiempo Medio de Remediación (MTTR) o el cumplimiento de acuerdos de nivel de servicio (SLA) de parcheo. Finalmente, los hallazgos quedan anclados a la ventana temporal declarada y a una política de enriquecimiento que podría modificarse nuevamente, de modo que su vigencia debe leerse con esa fecha a la vista.

1.8 Hipótesis

Primera hipótesis. Cobertura de correlación. Para el inventario estudiado, la combinación de las vías de correlación disponibles alcanza una proporción sustantiva de correlaciones que el identificador formal del NIST no alcanza por sí solo, y esa proporción es mayor en el momento de la detección que al cierre de la ventana, dado que el dato formal se incorpora con posterioridad a la publicación.

Segunda hipótesis. Madurez del dato en el momento de la priorización. Dado que la arquitectura observa las vulnerabilidades en los primeros días posteriores a su publicación, el Índice de Riesgo Compuesto que calcula en el momento de la ingesta subestima sistemáticamente su riesgo, y la magnitud de esa subestimación es función del tiempo transcurrido desde la publicación. El contraste se establece entre el índice persistido en el instante de la detección y el recalculado sobre la misma vulnerabilidad con información madura, de modo que la comparación recae sobre una misma unidad observada en dos momentos, a partir de valores efectivamente medidos.

Tercera hipótesis. Ubicación del cuello de botella. En la arquitectura estudiada, el factor limitante del tiempo de detección no reside en el procesamiento del *pipeline*, cuya latencia es menor en órdenes de magnitud: para las vulnerabilidades correlacionadas por la vía formal, lo gobierna la demora con que la NVD publica ese dato, y para las correlacionadas por la vía de inferencia, la cadencia de ejecución del disparador.

Las preguntas referidas a la precisión de la vía de inferencia y a la detección de fallas silenciosas son de carácter descriptivo y no se acompañan de hipótesis.

Toda cifra de latencia que se reporte en este trabajo debe leerse junto a dos limitaciones del instrumento que la produce. El campo en que la NVD informa la fecha de modificación refleja la última modificación del registro, sin distinguir de qué tipo fue ni conservar historial. Y la ventana de observación adoptada impide registrar los enriquecimientos más lentos, lo que sesga las medianas hacia abajo. En consecuencia, las latencias se reportan como órdenes de magnitud y no como estimaciones puntuales, con la excepción de la demora de la NVD, que el apartado 5.4.3 da también en valores puntuales, ya que la mide con el historial de cambios que publica la propia fuente y corrige así las dos limitaciones.

Capítulo 2: Marco Teórico

2.1 Estado del arte

La automatización de la gestión de vulnerabilidades ha recibido atención creciente en la literatura reciente. El motivo es una desproporción: el volumen de vulnerabilidades que se publican a diario excede lo que un equipo de seguridad puede revisar de forma manual. Los trabajos disponibles se ordenan en tres líneas. La primera estudia cómo automatizar el flujo de trabajo; la segunda, cómo decidir qué atender primero; la tercera, qué tan confiables son las fuentes públicas de las que ambas dependen.

La primera línea documenta las dificultades de automatizar el ciclo de principio a fin. Dissanayake et al. (2022) entrevistaron a diecisiete profesionales del sector salud y hallaron un patrón recurrente: las organizaciones acumulan herramientas parciales que no se integran entre sí. La automatización cubre así tramos sueltos del proceso y deja el resto librado al trabajo manual. Los autores señalan, además, que ciertos puntos conservan supervisión humana de manera deliberada, porque el despliegue desatendido de actualizaciones introduce riesgo operativo. Islam et al. (2019), en una revisión amplia de la literatura y de la práctica sobre orquestación de seguridad, ubican ese problema en un marco más general y destacan el papel de la inteligencia de amenazas actualizada para sostener los flujos automatizados.

Una segunda dificultad aparece cuando el sistema funciona y produce demasiadas alertas infundadas. Alahmadi et al. (2022) estudiaron el trabajo de los analistas en centros de operaciones de seguridad y describieron el efecto: validar una y otra vez alertas que no corresponden a nada termina por desensibilizar a quien las revisa. Su aporte más útil para este trabajo es una distinción. Una alerta incorrecta puede responder a comportamiento legítimo que el modelo no logra separar de un ataque, de modo que no siempre indica un defecto del sistema. De allí derivan cinco propiedades que una alerta debería reunir para resultar accionable, entre ellas ser explicable y estar contextualizada.

La investigación aquí presentada se inscribe en esa preocupación y adopta un enfoque *Human-in--the-Loop* (HITL). La detección algorítmica, orquestada con n8n, queda separada de la remediación, y la decisión sobre cada hallazgo permanece en manos del analista. La cuestión reaparece más adelante en carácter empírico, porque el propio artefacto produce falsos positivos y su medición forma parte de los resultados que se reportan en el Capítulo 5.

La segunda línea de estudio aborda el orden de atención. Existe acuerdo en que las métricas estáticas de severidad no alcanzan para fijarlo. Ahmadi Mehri et al. (2022) propusieron el modelo *Automated Context-Aware Vulnerability Risk Management* (ACVRM), que ajusta la urgencia de cada vulnerabilidad según factores ambientales y organizacionales que el puntaje CVSS no contempla. Dissanayake et al. (2022) aportan el fundamento empírico de esa necesidad: los escáneres no incorporan el contexto de la organización, y por eso la decisión de prioridad sigue recayendo en una persona. La sección 2.4 retoma la discusión con el detalle que exige la construcción del índice empleado en este trabajo.

La tercera línea toma como objeto a las fuentes públicas mismas. Nguyen y Massacci (2013) verificaron, con un método automático que rastrea cada corrección hasta el código, las versiones de Google Chrome que la NVD declaraba vulnerables, y encontraron varios errores en esos datos; al rehacer un estudio empírico sobre los datos corregidos, las conclusiones podían cambiar. Anwar et al. (2022) extendieron ese examen al conjunto de la base y hallaron inconsistencias en las fechas de publicación, en los nombres de fabricante y producto, y en los puntajes de severidad. Dong et al. (2019) compararon las versiones vulnerables que declara la NVD con las que mencionan la descripción textual y los informes externos de una misma vulnerabilidad: sobre 78.296 identificadores, algo menos del 60 % de esas descripciones e informes coincidía de forma estricta. Segal et al. (2026) modelaron el circuito de revisión de los avisos de seguridad de GitHub sobre más de 288.000 casos publicados entre 2019 y 2025, y hallaron que el tramo más lento de ese circuito está dominado por los avisos originados en la NVD.

Un trabajo de esa línea anticipa con precisión el problema que esta tesis documenta. Wåreus y Hell (2020), al proponer un método para asignar identificadores de producto de forma automática, advirtieron que cuando un registro carece de ese identificador resulta muy difícil descubrir la vulnerabilidad por medios automatizados. Lo escribieron seis años antes de que el NIST dejara de comprometerse a generar ese dato para todos los registros que recibe.

Comparar nombres para correlacionar sin el identificador formal no es un problema nuevo. Decidir si dos registros de fuentes distintas se refieren a lo mismo es lo que la literatura de datos llama vinculación de registros (Christen, 2012). En las vulnerabilidades, la dificultad está documentada. Sanguino y Uetz (2017) encontraron que el diccionario CPE y los registros CVE no coinciden entre sí, y que asignar identificadores en forma automática produce errores que una persona tiene que corregir. Jiang et al. (2025) midieron que el nombre del fabricante cambia de una fuente a otra en más de la mitad de los casos. La vía de inferencia de este trabajo usa la comparación más simple posible: da por coincidentes dos nombres cuando uno contiene al otro (sección 4.4). El Capítulo 5 mide qué costó esa simplicidad, y el apartado 7.1.2 propone alternativas.

De ese panorama se desprende el punto en que se sitúa esta investigación. La literatura ya documenta tres cosas: que automatizar el ciclo completo choca con barreras de integración antes que de herramientas, que la priorización exige ir más allá de la severidad técnica, y que los datos de la NVD arrastran defectos de completitud desde hace más de una década. Ninguno de esos trabajos anticipa un cambio deliberado de política, es decir, que el organismo responsable de la fuente abandone el objetivo de enriquecer la totalidad de los registros que recibe. La reforma que el NIST adoptó en abril de 2026 convirtió un problema crónico de calidad del dato en una restricción declarada de su alcance.

Sobre esa reforma no se identificaron, a septiembre de 2026, estudios académicos —revisados por pares o en calidad de preimpresión— que la analicen ni que examinen sus consecuencias sobre las arquitecturas que dependen de la correlación por CPE. El retraso de procesamiento que la precedió sí está documentado. Una evaluación federal del Departamento de Comercio de los Estados Unidos lo fecha en febrero de 2024 y consigna que erosionó la utilidad de la base y la confianza pública en

ella (U.S. Department of Commerce, Office of Inspector General, 2026); la brecha de cobertura que dejó fue medida también por proveedores del sector (Baines, 2024). La distinción delimita el aporte posible: el hecho está documentado, su análisis académico todavía no.

Ese es el vacío que la presente tesis ocupa. Su aporte consiste en documentar, con mediciones propias, qué le ocurrió a una arquitectura concreta cuando la fuente que sostenía su correlación cambió de política: qué capacidades perdió, cuáles recuperó mediante el rediseño y cuáles permanecen fuera de su alcance. El artefacto que sirve de caso evalúa sus hallazgos mediante cinco dimensiones: la severidad técnica (CVSS), la explotación confirmada (KEV), la probabilidad estimada de explotación (EPSS), la criticidad del activo y su exposición a Internet. Cada observación queda persistida en PostgreSQL, de modo que las cifras del Capítulo 5 puedan rastrearse hasta el registro que las sustenta.

El alcance de ese aporte es transitorio por su propia naturaleza. Se trata de un estudio de caso fechado, cuya originalidad proviene de la proximidad al hecho que documenta y cuya vigencia depende de que la política observada no vuelva a cambiar.

2.2 Gestión de vulnerabilidades (VM) y gestión de parches (PM)

La gestión de vulnerabilidades (*Vulnerability Management*, VM) es un proceso cíclico: la organización identifica los fallos de seguridad de su infraestructura, los clasifica, evalúa su gravedad, decide qué hacer con cada uno y reporta el resultado. Terminado el ciclo, vuelve a empezar. Los marcos de referencia que lo ordenan trabajan en dos planos distintos. La publicación especial 800-40 del NIST, en su cuarta revisión, trata el parcheo como parte del mantenimiento preventivo y recomienda que cada organización construya una estrategia propia, en lugar de resolver caso por caso (Souppaya & Scarfone, 2022). Los Controles Críticos de Seguridad del *Center for Internet Security* (CIS) van al detalle y fijan frecuencias mínimas: su séptimo control, dedicado a la gestión continua de vulnerabilidades, pide analizar la red interna de forma automática al menos cada tres meses, revisar lo expuesto a Internet todos los meses y aplicar los parches con esa misma frecuencia (Center for Internet Security, 2024).

La gestión de parches (*Patch Management*, PM) es la rama operativa de ese ciclo: consigue las actualizaciones, las prueba, las despliega y verifica que hayan quedado bien aplicadas. Entre una y otra suele abrirse una distancia práctica. Aunque el descubrimiento de vulnerabilidades suele estar automatizado, decidir cuáles atender primero es una tarea que suele resolverse a mano, y Dissanayake et al. (2022) documentaron esa dependencia como una de las barreras que impiden automatizar el ciclo completo. El despliegue no puede comenzar hasta que alguien termine de decidir qué parchear y en qué orden, de modo que la demora se acumula antes de que el trabajo técnico empiece.

Este proyecto se ubica en la fase inicial del ciclo y se limita a detectar y notificar. El flujo orquestado no reemplaza al analista, sino que trabaja antes que él: reúne la información pública sobre amenazas, la cruza contra el inventario y calcula un riesgo preliminar. Con eso emite alertas tempranas y deja registrado el estado de cada hallazgo, para que quien decide reciba el trabajo ya ordenado. Aplicar

los parches queda fuera del alcance. El tiempo que tarda el sistema en detectar, y qué factor gobierna esa demora, se examinan en el Capítulo 5.

2.3 Nomenclatura y bases de datos públicas (CVE, NVD y CPE)

El estándar *Common Vulnerabilities and Exposures* (CVE) le pone un nombre único a cada vulnerabilidad divulgada públicamente. Ese nombre resuelve un problema real: permite que dos herramientas distintas, o dos organizaciones distintas, sepan que están hablando de lo mismo. Un identificador, por sí solo, no alcanza para automatizar nada. Saber que existe CVE-2026-1234 no dice a qué productos afecta ni qué tan grave es.

Cada registro CVE lo redacta una CNA (*CVE Numbering Authority*), que suele ser el propio fabricante del producto afectado o una organización habilitada para ello. El formato en que se publica es el CVE Record Format, en su versión 5.2 desde octubre de 2025 (CVE Program, 2025). El esquema admite además la figura del publicador autorizado de datos (*Authorized Data Publisher*, ADP), que agrega información a un registro ya publicado sin tocar lo que escribió la CNA. CISA ocupa ese rol y aporta datos de priorización —si la vulnerabilidad se está explotando, si el ataque puede automatizarse y qué impacto técnico tiene—, pero no datos de correlación: desde diciembre de 2024 dejó de incorporar identificadores CPE a los registros que enriquece (Cybersecurity and Infrastructure Security Agency, 2026a).

La *National Vulnerability Database* (NVD) trabaja sobre esos registros y les agrega metadatos estructurados: puntajes de severidad (CVSS), referencias a boletines de parcheo, la marca de pertenencia al catálogo de vulnerabilidades explotadas conocidas (KEV) de CISA y, sobre todo para este trabajo, la lista de configuraciones afectadas expresadas con identificadores CPE. Ese último dato es el que permite cruzar una vulnerabilidad contra un inventario. Hasta abril de 2026 la NVD se proponía enriquecer todos los registros que recibía; desde entonces limita ese trabajo a un subconjunto priorizado, y dejó de emitir de forma rutinaria su propio puntaje de severidad cuando la CNA ya publicó uno (National Institute of Standards and Technology, 2026).

El estándar *Common Platform Enumeration* (CPE) es el que nombra a los productos. Un identificador CPE describe un sistema operativo, una aplicación o una plataforma de hardware con una estructura fija: fabricante, producto, versión y algunos campos más (Cheikes et al., 2011). Si el inventario de una organización guarda esos identificadores y el registro de la vulnerabilidad también los trae, el cruce se puede hacer de forma automática. Sobre esa idea se apoyaba el diseño original de este trabajo.

El cruce, sin embargo, no es una comparación exacta. Un registro CVE no declara un identificador suelto: declara un árbol de condiciones, con rangos de versiones abiertos o cerrados, exclusiones y combinaciones lógicas entre el producto vulnerable y las plataformas sobre las que corre. Interpretarlo bien exige leer esa estructura completa. Pashchenko et al. (2018) mostraron además que el CPE y los nombres con que el software se publica en los repositorios de paquetes tienen distinta granularidad, que esa diferencia produce coincidencias falsas, y que emparejar por nombre

produce además coincidencias perdidas. La precisión del cruce depende, entonces, de cuánto de esa estructura lea la herramienta que lo resuelve.

A eso se suma un problema de identidad. El diccionario oficial del NIST puede mantener más de una escritura para un mismo producto, y la que queda en desuso no desaparece. Windows Server 2022 aparece como producto `windows_server` con versión `2022`, y también como producto `windows_server_2022` sin versión; consultado para este trabajo, el diccionario marca la primera forma como deprecada y declara a la segunda como su reemplazo (National Institute of Standards and Technology, s. f.-b). La deprecación no se propaga a los registros ya publicados, de manera que los CVE viejos conservan la escritura original y ninguna de las dos formas recupera el conjunto completo. En el mismo corpus conviven, además, las dos formas de escritura que admite el estándar, la heredada de la versión 2.2 y la de la 2.3, que ubican los campos en posiciones distintas (Cheikes et al., 2011). Una herramienta que asuma un único formato descarta registros sin avisar.

De ahí se sigue una lectura que este trabajo retoma más adelante: el estándar creado para resolver la correlación es, él mismo, una fuente de fragmentación. El problema no se reduce a que el dato falte. Aun cuando el identificador existe y está publicado, puede no encontrarse porque quien lo publica y quien lo consulta lo escriben distinto.

Esa combinación tiene una consecuencia práctica sobre el diseño. La API de la NVD permite filtrar las consultas por identificador CPE, lo que evitaría cualquier lógica propia de correlación. Ese filtro compara el identificador pedido contra las configuraciones declaradas en el registro, que son justamente las que aporta el enriquecimiento. Solo alcanza a las vulnerabilidades ya enriquecidas. El Capítulo 3 describe cómo se resolvió la correlación una vez descartado ese camino.

2.4 Priorización: del CVSS al riesgo contextual y predictivo

El *Common Vulnerability Scoring System* (CVSS) mide la severidad técnica de una vulnerabilidad: cuán grave sería explotarla, con independencia de dónde esté instalada. Es una medida necesaria y, por sí sola, insuficiente para decidir el orden de atención. Dos vulnerabilidades con el mismo puntaje pueden tener urgencias muy distintas según el activo al que afecten y según lo que esté ocurriendo afuera.

La primera dimensión que falta es interna. Un fallo en el servidor de base de datos que sostiene la operación no pesa lo mismo que el mismo fallo en una máquina de laboratorio aislada. La segunda es externa: importa si existe código de explotación público y si hay reportes de ataques en curso. Ahmadi Mehri et al. (2022) formalizaron esa idea en el modelo ACVRM, que ajusta la urgencia de cada vulnerabilidad según el contexto del entorno en que reside.

La evidencia empírica sobre el rendimiento del criterio de severidad es consistente. Allodi y Massacci (2014) mostraron que solo una fracción pequeña de las vulnerabilidades publicadas llega a explotarse, y que la severidad declarada predice mal cuáles. Shimizu y Hashimoto (2026) lo cuantificaron sobre las 28.377 vulnerabilidades publicadas entre el 1 de abril de 2022 y el 30 de abril de 2023, con las 90 que registraron explotación confirmada en informes de proveedores como

conjunto de referencia. Atender todas las que superan el umbral de severidad alta, fijado en 7,0 sobre 10, obliga a revisar 16.182 registros, y apenas uno de cada doscientos de ellos pertenece a ese conjunto. Ese criterio recupera el 90 % de las vulnerabilidades explotadas, a costa de una relación entre señal y ruido muy baja.

Para incorporar la probabilidad de explotación, este trabajo integra el *Exploit Prediction Scoring System* (EPSS), propuesto por Jacobs et al. (2021) y publicado hoy por el *Forum of Incident Response and Security Teams* (FIRST) (Forum of Incident Response and Security Teams, s. f.). El EPSS estima, mediante modelos entrenados sobre inteligencia de amenazas, qué probabilidad tiene una vulnerabilidad de ser explotada en los treinta días siguientes. Mientras el CVSS informa cuánto daño podría hacer, el EPSS informa cuán probable es que alguien lo intente.

Existe un tercer enfoque de priorización, distinto de los puntajes. El modelo SSVC (*Stakeholder-Specific Vulnerability Categorization*) del Software Engineering Institute resuelve el orden de atención mediante un árbol de decisión que combina, entre otros puntos, el estado de explotación, la utilidad del ataque para el adversario —que incluye si puede automatizarse— y el impacto técnico, en lugar de un número (Spring et al., 2021). El artefacto de este trabajo registra el dato de explotación que publica CISA bajo ese modelo, aunque no lo incorpora al cálculo del índice.

El desplazamiento alcanzó también a la normativa. En junio de 2026 CISA emitió la directiva operativa vinculante 26-04, que revocó las dos directivas anteriores sobre remediación de vulnerabilidades (Cybersecurity and Infrastructure Security Agency, 2026b). Una de ellas, la 19-02, era la que fijaba plazos de parcheo según el puntaje CVSS (Cybersecurity and Infrastructure Security Agency, 2019); al revocarla, el ámbito federal civil estadounidense dejó de exigir ese puntaje como criterio de priorización, según establece la guía de implementación de la directiva vigente (Cybersecurity and Infrastructure Security Agency, 2026c). La directiva vigente ordena priorizar según la exposición del activo, la existencia de explotación conocida, la posibilidad de automatizar el ataque y el impacto técnico.

El Índice de Riesgo Compuesto que emplea este trabajo se inscribe en ese paradigma sin adoptar su instrumento. Coincide con la directiva en tres de sus cuatro variables: la explotación conocida, la exposición del activo y el impacto técnico, que la propia directiva describe como análogo al concepto de severidad del puntaje CVSS (Cybersecurity and Infrastructure Security Agency, 2026b). Se aparta en que resuelve la prioridad con un puntaje en lugar de la tabla de combinaciones discretas que usa la directiva, informada por el modelo SSVC, deja fuera la automatización del ataque, y suma dos elementos que la directiva no contempla: la probabilidad estimada de explotación y la criticidad operativa del activo. La sección 3.6 define su forma exacta.

FIRST advierte de manera expresa que multiplicar el puntaje EPSS por una medida ordinal como el CVSS no produce un puntaje de riesgo con significado, porque mezcla una probabilidad calibrada con una escala sin calibración empírica (Forum of Incident Response and Security Teams, s. f.). El índice empleado en este trabajo suma en lugar de multiplicar, pero combina esas mismas dos escalas, y tampoco pretende ser una estimación de riesgo. En el sentido que usan los marcos de

evaluación de riesgos, el riesgo es función del impacto adverso que produciría un evento y de su probabilidad de ocurrencia (Joint Task Force Transformation Initiative, 2012). El índice no combina esas dos magnitudes medidas para la organización, sino indicadores de distinta naturaleza sobre la vulnerabilidad y el activo. Funciona como una heurística de ordenamiento operativo, destinada a establecer en qué orden conviene atender los hallazgos, y no como una medición de riesgo en sentido estadístico.

2.5 Automatización en ciberseguridad y el modelo Human-in-the-Loop

La automatización de las operaciones de seguridad pasó de los *scripts* sueltos a las plataformas de orquestación SOAR, empujada por volúmenes de datos que superan lo que un equipo puede revisar. Automatizar el ciclo completo, sin embargo, tiene un límite claro: aplicar cambios a sistemas en producción sin que nadie los revise puede romper aquello que se intenta proteger.

Dissanayake et al. (2022) encontraron ese límite en la práctica: las organizaciones que estudiaron querían automatizar el ciclo entero y chocaban con dificultades de integración y con riesgos operativos que no estaban dispuestas a asumir. La respuesta que propone la literatura mantiene a la persona dentro del circuito y la ubica en los puntos donde la decisión pesa.

El reparto de tareas es el siguiente. Las que son deterministas y de alto volumen —ingerir lo publicado en la fuente, normalizar identificadores, cruzar el inventario y calcular el índice— quedan del lado del motor de orquestación. La validación final, el cambio de estado de una vulnerabilidad y la autorización para desplegar un parche quedan del lado del analista. La arquitectura de este trabajo sigue ese reparto: automatiza la visibilidad y el ordenamiento, y no ejecuta ninguna acción sobre los activos.

En este trabajo el enfoque prevé una interfaz web complementaria, fuera del objeto de estudio (sección 1.7), que conecta el motor con el analista. Cada vulnerabilidad detectada recorre un ciclo de seis estados que se reparte entre los dos. El flujo escribe los tres primeros sin intervención humana: DETECTADA al encontrarla, y luego NOTIFICADA o INFORMATIVA según el índice supere o no el umbral de alerta. Los tres restantes los fija el analista desde la interfaz: EN_REVISION cuando toma el caso, y REMEDIADA o DESCARTADA según cómo lo cierre. Solo estas últimas transiciones dejan una fila propia en la tabla de auditoría, de modo que el recorrido de la decisión humana puede reconstruirse después; las que ejecuta el flujo actualizan el registro sin conservar el valor anterior.

Queda una distinción que el artefacto registra sin utilizarla. Cada correlación se guarda con el nivel de confianza que le corresponde según la vía por la que se estableció, porque el identificador formal que publica el NIST y la inferencia a partir de los nombres declarados no ofrecen la misma garantía. Ese dato acompaña al hallazgo, pero el enrutamiento de la alerta se decide únicamente por el umbral del índice: el nodo de triaje compara el valor calculado contra 0,40 y nada más. La interfaz sí lo pone al alcance del analista: muestra por qué vía se estableció cada correlación y si una inferencia se confirmó después por la vía formal, y permite filtrar los hallazgos por vía.

2.6 Gestión de activos tecnológicos (ITAM) y su rol en SecOps

Una arquitectura de detección solo puede pronunciarse sobre los activos que su inventario registra. La gestión de activos de TI (*IT Asset Management*, ITAM) y su especialización en seguridad son el cimiento de cualquier proceso de orquestación. Los Controles del CIS dedican sus dos primeros controles al inventario de dispositivos y de software, y el primero declara su propósito: conocer con exactitud la totalidad de los activos que hay que vigilar y proteger (Center for Internet Security, 2024). Ese inventario delimita el alcance de todo lo que venga después, porque un activo que no está registrado no queda cubierto por ningún control posterior.

La inteligencia de amenazas externa no tiene valor accionable sin algo contra qué cruzarla. Una base de datos de gestión de configuraciones (*Configuration Management Database*, CMDB) o un inventario estructurado cumplen esa función. El problema práctico es de normalización: los nombres con que una organización registra su parque rara vez coinciden con los que usan los repositorios públicos, y las diferencias aparecen en el fabricante, en la versión y en la arquitectura.

En este trabajo el entorno de gestión de activos se materializa en un inventario simulado y estructurado en tablas relacionales. Dos de los cinco componentes del índice salen de ahí: la criticidad asignada al servidor y su nivel de exposición. El identificador del producto cumple una función anterior y distinta, porque es lo que hace posible el cruce con la vulnerabilidad. Si está mal escrito, el cruce no ocurre y el fallo es silencioso. En el diagnóstico previo de este trabajo, corregir la nomenclatura de los cinco productos de Microsoft del inventario llevó de cero a 1.766 las correlaciones que esos productos obtienen por el identificador que la propia CNA declara dentro del registro, sobre los 23.144 publicados entre mayo y julio de 2026. Esa medición se resuelve por completo sobre una copia local del repositorio de registros, sin intervención de la API, de manera que la corrección de nomenclatura es su única causa posible (véase el Capítulo 9). Un inventario cuidado no elimina los errores, dado que el propio artefacto produce falsas coincidencias que el Capítulo 5 cuantifica. Lo que cambia es el punto de partida.

2.7 Orquestación tecnológica y reproducibilidad metodológica

La arquitectura necesitaba un motor capaz de hablar con varias API y con una base de datos relacional, sin construir para eso una aplicación desde cero. Se eligió n8n, una plataforma de automatización *low-code* que se distribuye bajo una licencia propia de uso gratuito (*Sustainable Use License*) y permite armar flujos conectando nodos: disparadores por tiempo, peticiones HTTP, funciones en JavaScript y consultas a la base (n8n GmbH, 2025).

La elección se apoya en tres propiedades útiles para un trabajo de investigación. La primera es la reproducibilidad: n8n exporta la topología completa del flujo en un archivo JSON, de modo que otra persona puede revisar nodo por nodo qué hace el sistema y volver a montarlo. El Capítulo 9 incluye esos archivos.

La segunda es la extensibilidad, y este trabajo la puso a prueba. El diseño original consultaba una sola fuente; cuando esa fuente cambió su política, hubo que invertir el sentido del flujo —de

consultar por cada activo a ingerir todo lo publicado— y construir dentro del artefacto la lógica de correlación que antes resolvía el servidor. Conviene precisar el alcance de la propiedad: sumar una fuente nueva resulta sencillo mientras el modelo de datos se mantenga; cuando lo que cambia es de dónde sale el dato que sostiene el cruce, la modificación alcanza al núcleo del flujo.

La tercera es la auditabilidad. El motor deja un registro de ejecución de cada transacción entre nodos, y esos registros permiten reconstruir qué procesó cada corrida y depurar el comportamiento del flujo. Las mediciones de latencia, en cambio, se apoyan en las marcas temporales que el sistema persiste en la base, descritas en la sección siguiente.

2.8 Bases de datos relacionales y trazabilidad empírica

Usar un motor de base de datos relacional, en este caso PostgreSQL, resuelve algo más que el almacenamiento (PostgreSQL Global Development Group, s. f.). La base aporta la estructura y la integridad referencial que permiten modelar el inventario y vincularlo con las vulnerabilidades detectadas, de manera que cada hallazgo quede ligado a un activo concreto del inventario.

Guardar los datos de forma estructurada habilita después el análisis. Con una consulta se puede preguntar, por ejemplo, cuántas vulnerabilidades con probabilidad de explotación por encima de cierto valor afectaron a determinados activos durante una ventana de tiempo. Sobre esa posibilidad se apoyan las mediciones del Capítulo 5.

El diseño de las tablas registra el recorrido de cada hallazgo con varias marcas temporales. Tres de ellas describen la detección: la fecha en que la vulnerabilidad se publicó en la NVD, el momento en que el flujo la ingirió y el momento en que se persistió la alerta. Las escribe la corrida que detecta el hallazgo y ninguna corrida posterior las modifica, lo que permite descomponer la latencia en tramos y atribuir cada demora a su origen. Otras dos marcas registran lo que sí cambia con el tiempo: la fecha de la última intervención humana sobre el registro y la de la última actualización de los datos externos. Esas se actualizan por diseño, de modo que la trazabilidad del sistema es auditable y no inmutable.

A esas tres marcas se suman las que registran el comportamiento de la fuente. Cuando un hallazgo que se había correlacionado por inferencia recibe después el identificador formal del NIST, el sistema anota la fecha de última modificación que la NVD declara en ese momento y la corrida en que lo advirtió. La primera permite estimar cuánto tardó la fuente en incorporar el dato; la segunda funciona como rastro de auditoría y no como medida, porque su resolución depende de cada cuánto se ejecuta el flujo. La sección 1.8 declara el límite del instrumento: esa fecha refleja la última modificación del registro, cualquiera haya sido, y no necesariamente la que incorporó el identificador.

El resultado es un repositorio persistente y consultable. Esa base sostiene la verificación de los resultados de este trabajo y queda disponible para estudios posteriores sobre el mismo material.

2.9 Descentralización del dato de correlación

Los apartados anteriores describieron el ecosistema tal como funciona y los estándares que lo ordenan. Esta sección trata lo que cambió en él durante el desarrollo de este trabajo, porque ese cambio es el objeto mismo de la investigación.

El dato que vincula una vulnerabilidad con un producto dejó de tener un consolidador único. En el modelo anterior la NVD lo generaba para todos los registros que recibía, y una herramienta podía apoyarse en esa fuente sin preguntarse de dónde venía. Hoy el trabajo está repartido. La CNA escribe el registro y declara los productos afectados con sus propios términos. El NIST limita el enriquecimiento al subconjunto de registros que prioriza (National Institute of Standards and Technology, 2026); como ese enriquecimiento es el que aporta el identificador CPE, los registros restantes quedan sin ese dato. Y CISA, cuyo papel de publicador autorizado se describió en la sección 2.3, aporta datos de priorización sin agregar correlación (Cybersecurity and Infrastructure Security Agency, 2026a). Ninguna de las dos fuentes federales garantiza hoy el dato sobre el que se apoyaba la arquitectura original.

Esa descripción de la política no reemplaza a la medición. El artefacto resuelve la correlación por dos vías, el identificador formal que publica el NIST y la inferencia a partir de los nombres declarados, de modo que el aporte del identificador que publica la CNA y el de CISA se miden por fuera de él, sobre el corpus local y al cierre de la campaña, según detalla la sección 1.7. El Capítulo 5 reporta lo que efectivamente aportó cada una durante la ventana observada.

Conviene distinguir la desaparición de la dispersión. La información sobre qué productos afecta una vulnerabilidad sigue estando, aunque su forma depende de quién la escriba. Algunas CNA publican identificadores CPE dentro del propio registro, en el bloque que el formato reserva para los productos afectados; otras se limitan a nombrar fabricante y producto en texto libre. La API pública de la NVD transporta los nombres de fabricante y producto, pero no los identificadores que declara la CNA, que se leen en el registro que publica el programa CVE (National Institute of Standards and Technology, s. f.-a). Lo que dejó de existir es la garantía de que ese dato llegue normalizado para todos los registros, y esa garantía era la que sostenía el diseño original.

Distintos proveedores midieron la magnitud del hueco, con la salvedad de que todos ellos venden alguna forma de solución al problema que cuantifican. VulnCheck informó que, a noviembre de 2024, su servicio había asignado identificadores CPE al 76,95 % de los CVE publicados ese año, y situó la cobertura del NIST en el 41,35 %. Sobre el subconjunto de 997 registros que ambas fuentes terminaron identificando, dentro de los 3.189 que analizó, tomado entre el 11 de octubre y el 8 de noviembre de 2024, informó además que su asignación llegaba en promedio más de cuatro días antes (Baines, 2024). Son datos autoinformados, no auditados por terceros y anteriores a la reforma. Vulners publicó en abril de 2026 un análisis sobre 103.434 registros publicados entre febrero de 2024 y abril de 2026, que compara cuatro orígenes del dato de configuración: la NVD, la CNA, el programa de enriquecimiento de CISA y su propia capa. De ese conjunto, 20.477 tenían configuración consul-

table únicamente en los datos de Vulners, 18.544 únicamente en los de la NVD, y apenas 27 tenían configuración cargada en las cuatro (Uchakin, 2026).

La lectura que interesa a este trabajo no es cuál fuente cubre más. Es que las fuentes resultan complementarias y no intercambiables: cada una alcanza registros que las otras no, de modo que ninguna sustituye a las demás y combinarlas exige reconciliar nomenclaturas distintas. La divergencia entre lo que declara la CNA y lo que publica la NVD está documentada además para otros campos del registro, como los componentes del puntaje de severidad, que una preimpresión reciente cuantifica (Zhang et al., 2026).

Para una arquitectura como la estudiada, el efecto es un traslado de responsabilidad. La API de la NVD resuelve la comparación del lado del servidor: contrasta el identificador consultado con los criterios de coincidencia que declara el registro, con sus rangos de versión, y permite restringir la respuesta a los productos marcados como vulnerables, dejando fuera las plataformas que solo alojan al software afectado (National Institute of Standards and Technology, s. f.-a). Esa capacidad sigue existiendo; lo que dejó de estar es el dato sobre el que operaba. Con el rediseño la comparación pasó a ejecutarse dentro del artefacto, que la resuelve de forma simplificada, sin leer los rangos de versión ni el marcador que distingue una cosa de la otra. La sección 1.7 declara esa limitación y el Capítulo 5 la cuantifica.

El traslado no afecta por igual a todos los activos. Que la correlación dependa de cómo cada fabricante nombre sus productos hace que la cobertura varíe según el parque instalado, y esa variación pasa a ser una propiedad del inventario antes que del flujo. El Capítulo 5 retoma la cuestión al reportar la cobertura desagregada por activo.

Capítulo 3: Marco Metodológico

3.1 Tipo de investigación

Este trabajo se clasifica como una investigación aplicada, según los lineamientos de Hernández Sampieri et al. (2014), y a la vez de desarrollo tecnológico.

Es aplicada porque no busca producir conocimiento abstracto sino intervenir sobre un problema operativo documentado: revisar a mano las vulnerabilidades que se publican a diario es lento, costoso y propenso al error, y satura al analista que debe hacerlo. La investigación toma los fundamentos de la gestión de riesgos y los orienta hacia un fin práctico, la mejora de las operaciones de seguridad (SecOps).

Es de desarrollo tecnológico porque su núcleo consiste en diseñar, construir y evaluar un artefacto funcional. Ese artefacto es una Prueba de Concepto (PoC) que integra fuentes públicas de inteligencia de amenazas con una base de datos relacional. El trabajo no se limita a describir cómo debería funcionar un sistema de notificación: construye uno y observa cómo se comporta.

A esas dos clasificaciones se suma una tercera, que se incorporó con la investigación ya en marcha. La reforma del enriquecimiento de la NVD alcanzó al artefacto mientras se lo construía y modificó el objeto de estudio. Desde entonces el trabajo funciona además como un estudio de caso: documenta qué le ocurrió a una arquitectura concreta cuando la fuente pública de la que dependía cambió su comportamiento, qué capacidades perdió, cuáles recuperó con un rediseño y cuáles no. El artefacto deja de ser únicamente el resultado del trabajo y pasa a ser también el instrumento con el que se observa ese efecto.

Esa doble función del artefacto ordena el resto del capítulo. Las secciones que siguen describen primero el enfoque y el diseño de la investigación, luego el entorno sobre el que opera el sistema y las variables que procesa, y por último las técnicas con que se recogieron los datos, las herramientas empleadas, la arquitectura que resultó del rediseño y el procedimiento efectivamente ejecutado.

3.2 Enfoque metodológico

El trabajo adopta un enfoque **cuantitativo**. La elección responde a la naturaleza del problema: lo que se quiere establecer se cuenta y se mide, no se interpreta. Las preguntas que guían la investigación —qué proporción de las correlaciones alcanza cada vía, con qué precisión, en qué momento madura la información que alimenta la priorización y dónde reside el factor que limita el tiempo de detección— se responden contando registros y comparando marcas temporales.

Los datos provienen de una sola fuente: lo que el propio artefacto persiste en PostgreSQL mientras opera. Cada hallazgo deja una fila con sus cinco variables, con la vía por la que se estableció la correlación y con las marcas temporales de su recorrido. Cada corrida deja además una fila de auditoría que registra cuántos registros se ingirieron, cuántos correlacionaron y por cuál de las dos vías.

Esa condición tiene una contrapartida. El instrumento que mide es el mismo sistema que se evalúa, y en un flujo armado sobre un motor de orquestación los defectos rara vez se manifiestan como errores: se manifiestan como datos que no aparecen. Una corrida que correlaciona de menos se ve igual que un día tranquilo. De ahí que la verificación no pueda apoyarse solo en lo que el artefacto informa, y que varias de las mediciones comprometidas para el cierre de la recolección se resuelvan por fuera de él, sobre los datos ya persistidos o contra la fuente pública. El Capítulo 5 desarrolla la cuestión sobre los casos concretos en que ocurrió.

3.3 Diseño de investigación

La investigación adopta un diseño no experimental y longitudinal, de alcance descriptivo y explicativo, organizado como un estudio de caso instrumental (Stake, 1995) sobre un artefacto construido para este trabajo. El sistema opera durante una ventana declarada sobre el flujo real de vulnerabilidades publicadas, y lo que se analiza es el registro de lo que hizo con ellas. El caso es instrumental porque el interés no se agota en el artefacto: lo que se busca establecer a través de él es qué le ocurre a una arquitectura de detección automatizada cuando la fuente pública que le proveía el dato de correlación restringe ese servicio.

La unidad de análisis es el par vulnerabilidad-activo. Una misma vulnerabilidad que alcanza a cuatro servidores del inventario produce cuatro unidades, cada una con su propio índice de riesgo, porque el índice incorpora la criticidad y la exposición del activo. De esa definición depende qué está contando cada cifra del trabajo: la cobertura de correlación se calcula sobre vulnerabilidades distintas, el volumen de hallazgos y de notificaciones sobre pares, y el rendimiento del flujo sobre corridas efectivas. El Capítulo 5 declara, para cada cifra que reporta, cuál de esas tres unidades está contando.

El entorno de evaluación se construye sobre un inventario simulado de activos, diseñado para reproducir las características estructurales de una infraestructura organizacional. Incluye servidores, estaciones de trabajo y activos publicados en Internet, con niveles de criticidad diferenciados según su función. Trabajar sobre un entorno simulado permite controlar las variables del sistema y repetir las mediciones, a costa de limitar la generalización de los resultados. La sección 3.4 detalla su composición y los criterios con que se la fijó.

El artefacto se implementa como un flujo de orquestación que se ejecuta una vez por día. En cada corrida ingiere las vulnerabilidades publicadas en una ventana de tres días, las cruza contra el inventario, consulta la probabilidad de explotación en una fuente externa, calcula el índice de riesgo y decide si emite una notificación. Es el patrón de funcionamiento de las plataformas comerciales de orquestación de seguridad, reducido a lo que la pregunta de investigación necesita.

Lo que el diseño mide se desprende de las hipótesis formuladas en la sección 1.8, y son tres cosas distintas. La primera es la cobertura de correlación: qué proporción de los vínculos entre vulnerabilidad e inventario alcanza cada vía, tomada en el momento de la detección y al cierre de la ventana. La segunda es la distancia entre el índice de riesgo calculado al detectar y el recalculado sobre la misma vulnerabilidad con información madura, que es un contraste de una unidad consigo misma

en dos momentos. La tercera es la comparación entre tres intervalos temporales: lo que tarda el artefacto en procesar un hallazgo, lo que tarda la fuente en publicar el dato de correlación y cada cuánto se ejecuta el flujo. Las variables que alimentan el índice se operacionalizan en la sección 3.5 y su forma de combinación se define en la 3.6.

Dos precisiones sobre el material recolectado completan el diseño. La primera es que el artefacto quedó congelado antes de abrir la ventana de recolección y no se modificó durante ella, salvo por una excepción declarada que la sección 3.12 detalla con su fecha y su fundamento. El 1 de septiembre de 2026 se agregaron además al esquema, para la reevaluación diferida, columnas en la tabla de telemetría y una tabla nueva, que el flujo de recolección no lee ni escribe (sección 3.12). Sin ese congelamiento, las filas recogidas en distintos momentos responderían a versiones distintas del sistema y no serían comparables entre sí.

La segunda concierne a las corridas previas a la apertura de la ventana. Las ejecuciones de los días iniciales se declaran período de estabilización y quedan fuera del análisis, por los motivos que enumera la sección 3.12. El alcance de esa exclusión, sin embargo, no es uniforme: depende de qué mida cada análisis. Los defectos de ese período son de tres clases. Los de cobertura incompleta inhabilitan toda afirmación de que la cohorte del período sea el censo de lo detectable. Los de instrumentación temporal inhabilitan todo intervalo de procesamiento, porque la marca que cierra el procesamiento no se escribía. Y los de registro de promoción inhabilitan toda medición del momento en que una correlación inferida recibe confirmación formal. Ninguno de los tres alcanza, en cambio, a si un par vulnerabilidad-activo es correcto: esa propiedad se verifica contra el aviso del fabricante y no depende de a qué hora corrió el flujo. Tampoco alcanzan al índice que el flujo calculó para cada par, que coincide con el de la fórmula congelada. Por eso esas filas se admiten en la muestra de validación de la vía de inferencia y en el contraste entre el índice registrado al detectar y el recalculado al cierre, y se excluyen de todo lo demás.

En cuanto a la validez interna, la principal amenaza proviene de la dependencia de interfaces de terceros. Durante la recolección se verificaron tres restricciones concretas de esas interfaces, que describe la sección 3.9, y las tres se atendieron dentro del artefacto. A eso se suma una segunda amenaza, de otro orden: el disparador programado depende de que el entorno local esté activo a la hora prevista, de modo que la cadencia efectiva fue irregular. La sección 3.8 fija la unidad sobre la que se computan las métricas.

El esquema relacional resguarda la integridad de lo persistido. Una restricción de unicidad sobre el par vulnerabilidad-activo impide que la superposición de ventanas genere filas duplicadas, y las restricciones de rango sobre los puntajes rechazan valores fuera de escala. Cada corrida deja además, en su fila de auditoría, cuántos registros recibió, cuántas páginas llegaron y si la respuesta quedó truncada, lo que permite verificar después que ninguna corrida quedó por debajo del total que la fuente declaraba. La sección 3.7 precisa el alcance de esa verificación.

Respecto de la validez externa, el inventario simulado limita la generalización a entornos reales, donde la diversidad de configuraciones y la existencia de controles no modelados influyen sobre el

comportamiento del sistema. A esa limitación conocida se agrega una que el propio trabajo midió y que resulta más específica: la cobertura de correlación no es una propiedad del flujo sino del parque sobre el que se aplica. Como el vínculo entre una vulnerabilidad y un activo se establece a partir de cómo el fabricante nombra sus productos, dos inventarios del mismo tamaño pueden obtener coberturas muy distintas según qué fabricantes los compongan. El Capítulo 5 reporta la cobertura desagregada por activo por esa razón.

Sobre la validez de constructo, el Índice de Riesgo Compuesto (IRC) es un modelo heurístico y una aproximación operativa al concepto de riesgo priorizable. Su validez no supone que capture todas las variables que intervienen en un escenario real de ataque, como los controles compensatorios no documentados o las particularidades de configuración de cada entorno. Se lo considera adecuado para los fines de este trabajo porque integra indicadores respaldados por el estado del arte —la severidad técnica, la probabilidad estimada de explotación y la evidencia de explotación confirmada — y los ancla al contexto del entorno evaluado mediante la criticidad y la exposición del activo.

El alcance de esa validez determina qué puede afirmar el Capítulo 5. Conforme a lo establecido en la sección 2.4 y según detalla la sección 3.6, el índice es una heurística de ordenamiento operativo. El trabajo no sostiene que su valor represente con determinada precisión la urgencia real de una vulnerabilidad. Lo que evalúa es un asunto más acotado y verificable con los datos disponibles: en qué medida ese valor, calculado en el instante en que el sistema detecta la vulnerabilidad, difiere del que se obtiene cuando la información pública sobre ella ya maduró.

3.4 Dimensionamiento y justificación del entorno simulado

La validación empírica del sistema se ejecuta sobre un entorno tecnológico simulado, concebido como escenario controlado de evaluación. Esa forma de montarlo permite fijar las variables relevantes del modelo y repetir las mediciones en condiciones equivalentes.

El entorno se delimitó a un conjunto fijo de treinta activos. El número no busca representatividad estadística: define una configuración acotada, suficiente para observar el comportamiento del mecanismo de priorización, que evalúa cada hallazgo por separado y cuyo costo no depende del tamaño del inventario. Originalmente pesó también un límite técnico, porque el diseño anterior consultaba a la NVD una vez por activo; el rediseño lo eliminó, y el inventario se mantuvo igual ya como decisión de alcance.

A cada activo se le asignaron de manera predefinida las dos variables de contexto interno que el modelo requiere: el nivel de criticidad organizacional —crítica, alta, media o baja— y el estado de exposición a Internet. La parametrización se apoya en marcos de referencia consolidados en la gestión de servicios y la seguridad de la información, como ITIL (AXELOS, 2019) e ISO/IEC 27001 (International Organization for Standardization & International Electrotechnical Commission, 2022), con el propósito de emular un entorno corporativo verosímil. Esos marcos orientan las categorías, pero no prescriben cuántos activos asignar a cada una: las distribuciones que siguen son una decisión de este trabajo.

Para la criticidad se adoptó una escala ordinal de cuatro niveles, que permite discriminar el impacto operativo de cada activo con la granularidad que necesita el cálculo del Índice de Riesgo Compuesto (IRC). Su distribución sigue una estructura piramidal: tres activos en categoría crítica, seis en alta, doce en media y nueve en baja. La configuración refleja la premisa de que los sistemas indispensables para la continuidad del negocio son una minoría, mientras que los de soporte y los entornos no productivos constituyen el grueso de la infraestructura.

Para la exposición a Internet se definió una distribución de seis activos accesibles públicamente y veinticuatro restringidos a la red interna. La proporción se alinea con arquitecturas de red perimetral de uso extendido, en las cuales solo un subconjunto acotado de servicios se publica en zonas desmilitarizadas y el resto permanece segmentado.

Cada activo lleva, finalmente, un identificador CPE que representa su plataforma tecnológica —entre otras, distribuciones de Linux, versiones de Windows Server, un servidor web Apache y un motor PostgreSQL— junto con un alias descriptivo que facilita su identificación en la interfaz. Ese identificador es el que hace posible el cruce con los registros publicados, conforme a lo descrito en la sección 2.3. Varios activos comparten plataforma, y esa repetición es deliberada: las flotas reales son homogéneas, porque las estaciones de un área se adquieren juntas y los servidores de un mismo servicio corren la misma versión. La homogeneidad es además lo que vuelve observable la multiplicación de hallazgos sobre activos que comparten producto, dado que la correspondencia se resuelve activo por activo. La correlación que habilita, sin embargo, no es exacta: el registro de una vulnerabilidad no declara un identificador suelto sino un árbol de condiciones con rangos de versiones, y el artefacto lo resuelve de forma simplificada. La sección 1.7 declara el error que esa simplificación introduce y el Capítulo 5 lo cuantifica.

Asignar esos identificadores resultó menos directo de lo previsto, y la dificultad forma parte de lo que el trabajo documenta. Antes de abrir la recolección se ejecutó un diagnóstico sobre el inventario, descrito en el Anexo A, que detectó ocho identificadores defectuosos sobre los veinte productos declarados, con incidencia sobre trece de los treinta activos: cuatro figuraban como deprecados en el diccionario oficial del NIST, que declaraba su reemplazo, y cuatro no existían en él. Los ocho se corrigieron antes de comenzar. Que construir un inventario con identificadores correctos exija consultar el diccionario producto por producto no es un percance de este trabajo: es una manifestación concreta del problema de identidad que describe la sección 2.3, observada sobre un inventario de treinta activos.

El modelado del inventario impone, además, un límite que el trabajo midió. El inventario anota cada activo con el nombre de su producto principal, y hay vulnerabilidades que se publican por debajo de ese nivel: las del núcleo de Linux se emiten con fabricante y producto propios, y el inventario declara las distribuciones instaladas sin declarar el núcleo, de modo que no hay contra qué cruzarlas aunque esos servidores efectivamente lo usen. Aquí el criterio de correlación opera como debe y la correspondencia no se establece, porque lo que falta es información del inventario. El límite no se corrigió: se identificó con la recolección ya en curso, y ampliar el inventario en ese punto habría

partido la serie en dos versiones del entorno, con filas anteriores y posteriores no comparables entre sí. Se declara como limitación, y el Capítulo 7 lo retoma como recomendación de modelo de datos.

Otras vulnerabilidades se publican por encima del producto, agrupadas en un aviso que reúne las de sus complementos, y el inventario tampoco registra qué complementos corre cada activo. Ese caso no produce el mismo efecto que el anterior ni obedece a la misma causa. La correspondencia sí se establece, y se establece mal: como la comparación de nombres admite coincidencias parciales, el nombre del complemento contiene el del producto y la vía de inferencia da por afectado a un activo que no lo está. El origen está entonces en el criterio de correlación y no en el modelado del entorno. La sección 1.7 expone por qué el criterio no se modificó, y el apartado 5.2.3 cuantifica el caso.

El desglose tabular completo del inventario, con la asignación individual de atributos y nomenclatura técnica, se presenta en el Capítulo 4.

3.5 Operacionalización de variables

El modelo de priorización se desglosa en cinco variables independientes. Tres corresponden a la inteligencia de amenazas externa, que el orquestador captura en cada corrida, y dos al contexto interno, que residen en el esquema relacional. La tabla siguiente define cada una en términos conceptuales y operacionales, con el tratamiento técnico que recibe en la base de datos y el rango de valores que admite.

Tabla 1

Operacionalización de las variables del modelo de priorización

Variable	Definición conceptual	Definición operacional	Tipo	Rango
Severidad estática (CVSS)	Impacto técnico intrínseco de la vulnerabilidad, con independencia del entorno en que resida	El flujo recorre las métricas del registro en el orden v3.1, v3.0, v4.0 y v2, y toma el puntaje base de la primera versión que encuentre. Si ninguna está presente, persiste cero	Cuantitativa de naturaleza ordinal	0,0 a 10,0
Explotación confirmada (KEV)	Constancia, publicada por CISA, de que la vulnerabilidad registra explotación activa	Presencia del campo con que la NVD informa la fecha de incorporación al catálogo de vulnerabilidades explotadas conocidas	Cualitativa dicotómica	Verdadero / Falso
Explotación predictiva (EPSS)	Probabilidad estimada de que la vulnerabilidad sufra intentos de explotación en los treinta días siguientes	Petición a la interfaz pública de FIRST, emitida una vez por cada par vulnerabilidad--activo	Cuantitativa continua	0,00 a 1,00
Criticidad del activo	Importancia del activo afectado para la continuidad operativa	Peso normalizado que el esquema calcula como columna generada a partir del nivel ordinal asignado en el inventario, leído al inicio de cada corrida	Cualitativa ordinal, normalizada	0,25 · 0,50 · 0,75 · 1,00
Exposición a Internet	Condición de red que determina si el activo es accesible desde fuera de la organización	Atributo predefinido en el inventario para el activo asociado a la vulnerabilidad	Cualitativa dicotómica	Verdadero / Falso

Nota. Operacionalización de las cinco variables del modelo de priorización. Las tres primeras se capturan de fuentes externas en cada corrida; las dos últimas residen en el inventario simulado descrito en la sección 3.4. El rango de la criticidad corresponde a los cuatro niveles baja, media, alta y crítica, ya normalizados al intervalo que emplea la fórmula de la sección 3.6.

Entre los datos que el artefacto registra sin utilizarlos en el cálculo, uno condiciona la lectura de los resultados: la vía por la que se estableció la correlación, con el nivel de confianza que le corresponde. Cada hallazgo se guarda indicando si el vínculo con el activo se resolvió por la vía formal, que emplea el identificador CPE publicado por el NIST, o por la vía de inferencia, que compara los

nombres de fabricante y producto declarados en el registro. Es la variable sobre la que se formula la primera hipótesis de la sección 1.8, y las dos vías no ofrecen la misma garantía. La sección 3.10 describe cómo opera cada una.

Dos precisiones sobre el puntaje de severidad completan la operacionalización, porque delimitan lo que el trabajo puede afirmar sobre esa variable. La primera es que la ausencia de puntaje se persiste como cero y no como valor nulo. El estándar admite un puntaje de cero, aunque es raro, y el flujo no lo distingue de la ausencia. En esta campaña no hubo ninguno: las 224 vulnerabilidades registradas con cero tenían severidad al cierre; la sección 3.8 fija cómo se trata ese valor en el análisis. La segunda es que el flujo toma el primer elemento del arreglo de métricas dentro de la versión que encontró, sin registrar qué organización emitió el puntaje ni preferir la marcada como principal. Puntajes provenientes de la CNA, de CISA y del NIST entran a la base sin distinguirse entre sí, de modo que la base no registra quién emitió cada uno. El apartado 5.3.2 lo deduce por coincidencia de valores, una igualdad que indica el origen pero no lo prueba.

3.6 Definición formal del Índice de Riesgo Compuesto (IRC)

El Índice de Riesgo Compuesto (IRC) es una función escalar que combina las cinco variables operacionalizadas en la sección anterior y devuelve un único número. Ese número ordena los hallazgos y decide cuáles se notifican: reduce información de origen heterogéneo —tres variables externas y dos del inventario— a una escala común sobre la que pueden compararse entre sí.

El cálculo se aplica a todos los pares que la etapa de correlación produce, sin filtro previo de severidad. Un hallazgo cuyo puntaje de severidad sea bajo se persiste igual, con su índice calculado, de modo que el conjunto completo de lo correlacionado queda disponible para el análisis posterior. Lo que la etapa de correlación descarta, en cambio, no se persiste: de las vulnerabilidades ingeridas que no alcanzan a ningún activo queda el conteo en la fila de auditoría, y no la lista de sus identificadores.

La función de agregación es lineal y ponderada. Cada variable se transforma antes al intervalo [0,1], de modo que todas entren al cálculo en la misma escala. La normalización es la siguiente:

- **CVSSnorm** = CVSS / 10
- **EPSS**= valor original provisto por la API (ya definido en [0,1])
- **KEV**= 1 si existe explotación activa confirmada, 0 en caso contrario
- **CRITnorm** = valor precalculado extraído de la columna generada (peso_normalizacion) en la tabla de referencia de PostgreSQL (donde Baja=0,25, Media=0,50, Alta=0,75, Crítica=1,0)
- **EXP** = 1 si el activo está expuesto a Internet, 0 en caso contrario

La normalización de la criticidad no la resuelve el orquestador: el esquema relacional la calcula en una columna generada, de modo que el flujo lee el peso ya normalizado.

Para operativizar el cálculo, el Índice de Riesgo Compuesto se define formalmente mediante la siguiente función de agregación:

$$\text{IRC} = (w1 \times \text{CVSSnorm}) + (w2 \times \text{EPSS}) + (w3 \times \text{KEV}) + (w4 \times \text{CRITnorm}) + (w5 \times \text{EXP})$$

Los coeficientes w1, w2, … , w5 representan los pesos asignados a cada dimensión del modelo y deben cumplir la condición de normalización:

$$w1 + w2 + w3 + w4 + w5 = 1$$

La agregación lineal se adoptó por su uso extendido en modelos de decisión multicriterio, donde se la conoce como modelo de suma ponderada (Triantaphyllou, 2000), y porque su cálculo puede descomponerse y auditarse término por término. Supone independencia entre las variables, lo que constituye una simplificación: la probabilidad de explotación y la evidencia de explotación confirmada están relacionadas entre sí. La simplificación se acepta para los fines de esta Prueba de Concepto (PoC).

Respecto a la asignación de los pesos ponderados, estos se definen explícitamente de la siguiente manera:

- **w1 (CVSSnorm) = 0,15**
- **w2 (EPSS) = 0,25**
- **w3 (KEV) = 0,30**
- **w4 (CRITnorm) = 0,20**
- **w5 (EXP) = 0,10**

Los coeficientes son una decisión de este trabajo, orientada por la literatura sobre gestión de vulnerabilidades basada en riesgo. El modelo toma como referencia los criterios de priorización del marco Stakeholder-Specific Vulnerability Categorization (SSVC) (Spring et al., 2021) y los lineamientos del Exploit Prediction Scoring System (Forum of Incident Response and Security Teams, s. f.). Ambos enfoques sostienen que la severidad técnica no alcanza por sí sola para priorizar, y dan un lugar central a los indicadores asociados al comportamiento del adversario: la probabilidad de explotación y la evidencia de ataques en curso.

En este sentido, el modelo asigna mayor ponderación a la variable KEV (0,30), en línea con el catálogo de vulnerabilidades explotadas de la Cybersecurity and Infrastructure Security Agency (2024), que CISA recomienda usar como insumo de la priorización; tratar la explotación activa confirmada como el principal criterio de urgencia es una decisión de este trabajo. A continuación, se prioriza la probabilidad predictiva EPSS (0,25), incorporando una dimensión prospectiva basada en modelos estadísticos. La criticidad del activo (0,20) introduce el contexto organizacional como modulador del impacto, mientras que la severidad técnica CVSS (0,15) se mantiene como referencia estructural, aunque con menor peso relativo. Finalmente, la exposición a Internet (0,10) actúa como factor de ajuste vinculado a la accesibilidad del vector de ataque.

Estos pesos constituyen una parametrización fundamentada y no valores universales. No se modificaron durante la investigación. Fijar los pesos o el umbral después de observar cómo se

distribuyeron los resultados equivale a elegir el resultado; mantenerlos permite leer el comportamiento del índice como un hallazgo del trabajo.

El resultado del cálculo del IRC es un valor continuo en el intervalo [0,0, 1,0], el cual se utiliza para clasificar las vulnerabilidades en distintos niveles de prioridad operativa. A efectos de la presente implementación, se establecen umbrales de clasificación iniciales de carácter heurístico:

- **IRC ≥ 0,70** ⟶ Prioridad Crítica
- **0,40 ≤ IRC < 0,70** ⟶ Prioridad Alta
- **IRC < 0,40** ⟶ Prioridad Informativa

Los dos puntos de corte se fijaron antes de abrir la recolección y se mantuvieron sin cambios, por el mismo motivo que los pesos. Son de carácter heurístico y el trabajo no sostiene que separen con exactitud lo urgente de lo que no lo es; lo que sostiene es que la posición del corte se declaró de antemano y no se movió a la luz de los datos.

De los cinco pesos, el de la exposición a Internet es el que menos respaldo encuentra en la literatura revisada. La directiva operativa 26-04 de CISA la incluye entre los cuatro criterios con que ordena la remediación (Cybersecurity and Infrastructure Security Agency, 2026b), y los Controles del CIS piden revisar todos los meses lo expuesto a Internet, frente a la revisión trimestral que fijan para la red interna (Center for Internet Security, 2024). El índice, en cambio, le asigna el peso más bajo del modelo. La discrepancia se advirtió al cierre de la recolección, al contrastar los pesos con la literatura del Capítulo 2. Para medir cuánto depende de esa elección la decisión de notificar, el índice de todos los hallazgos persistidos se recalcula bajo un escenario alternativo que duplica ese peso, de 0,10 a 0,20. Los otros cuatro ceden 0,025 cada uno para que la suma siga siendo 1: la severidad queda en 0,125, la probabilidad de explotación en 0,225, la explotación confirmada en 0,275 y la criticidad en 0,175, de modo que el orden entre ellos se conserva. El recálculo emplea los valores registrados en el momento de la detección, que son los que el sistema usó para decidir, y se repite con los valores recalculados al cierre de la campaña. En ambos casos se resuelve por completo sobre la base de datos, sin ejecutar el flujo ni alterar ninguna fila. El escenario no reemplaza la parametrización del artefacto, que se mantiene como se declaró: muestra qué habría notificado el sistema con otra. El Capítulo 5 informa el resultado.

Conforme a lo establecido en la sección 2.4, el Índice de Riesgo Compuesto funciona como una heurística de ordenamiento operativo y no como una estimación de riesgo calibrada: FIRST advierte de manera expresa que multiplicar la probabilidad de explotación por una medida ordinal como el puntaje de severidad no produce una estimación de esa clase (Forum of Incident Response and Security Teams, s. f.); el índice suma en lugar de multiplicar, pero combina las mismas dos escalas. Lo que el índice ofrece es un criterio único, explícito y reproducible para decidir en qué orden atender los hallazgos, con la ventaja de que su cálculo puede descomponerse y auditarse componente por componente.

Esa posibilidad de descomponerlo es la que habilita la segunda pregunta que el trabajo formula sobre el índice: cuánto se aparta el valor calculado en el momento de la detección del que se obtiene

con información madura. La comparación exige reconstruir el índice hacia atrás, y no todos sus componentes lo admiten en la misma medida. La probabilidad de explotación puede reconstruirse día por día, porque FIRST publica su serie histórica (Forum of Incident Response and Security Teams, 2026b); el estado de explotación confirmada también, porque CISA registra la fecha en que cada vulnerabilidad ingresó al catálogo (Cybersecurity and Infrastructure Security Agency, 2024). La criticidad y la exposición no cambian, de modo que se aplican hacia atrás como constantes. El puntaje de severidad es el único que este trabajo no reconstruyó día por día: la NVD publica un historial de cambios que registra las revisiones del puntaje, pero se lo consultó solo para fechar la llegada de la configuración (apartado 5.4.3). Se dispone por lo tanto de dos puntos —la detección y el cierre—, suficientes para establecer si cambió y en cuánto, insuficientes para decir cuándo. El efecto de esa aproximación está acotado: la severidad pesa 0,15 sobre 1,00, de modo que aplicar el valor de cierre hacia atrás desplaza la curva a lo sumo en esa magnitud, y solo en el caso extremo de que el puntaje hubiera recorrido la escala entera. En la campaña, ningún puntaje ya publicado cambió entre la detección y el cierre: la severidad solo cambió en los 395 pares que llegaron sin ella (apartado 5.3.2).

3.7 Técnicas de recolección de datos

La recolección prescinde de la intervención humana: la ejecuta el propio artefacto mediante procedimientos programáticos. Se organiza en tres dimensiones —la ingesta de inteligencia de amenazas, la consulta del contexto interno y la captura de telemetría de desempeño— y se apoya en dos puntos de consulta externos, aunque las fuentes de origen de los datos que recoge son tres: la NVD redistribuye dentro de su propia respuesta los datos que produce CISA, de modo que el artefacto consulta a la NVD y a FIRST, y recibe información originada en la NVD, en CISA y en FIRST.

Para la **ingesta de inteligencia de amenazas**, el orquestador interroga la interfaz v2.0 de la NVD pidiendo las vulnerabilidades publicadas dentro de una ventana temporal, y obtiene de cada registro el puntaje de severidad, la pertenencia al catálogo de explotación conocida, el punto de decisión sobre explotación de CISA y los datos que permiten resolver la correlación. De manera separada consulta la interfaz de FIRST para obtener la probabilidad estimada de explotación de cada vulnerabilidad correlacionada.

La ventana abarca tres días de calendario: comienza a las 00:00 de dos días antes de la corrida y termina a las 23:59 del día en curso. Como el flujo se ejecuta a media tarde, el último tramo de esa ventana todavía no ocurrió en el momento de la consulta, de modo que cada vulnerabilidad entra en dos o tres corridas consecutivas según se haya publicado antes o después de la hora de ejecución. La superposición es deliberada y responde a un criterio de tolerancia a fallas: si una corrida no se ejecuta, la anterior y la siguiente cubren entre las dos su ventana y no se abre un hueco en la serie. Los conteos absolutos quedan por lo tanto inflados, de manera simétrica para lo ingerido y para lo correlacionado, y las cifras de cobertura se reportan como proporción por corrida y no como totales acumulados del período.

Los dos límites se expresan en tiempo universal coordinado, que es el huso en que la fuente publica sus marcas, y se derivan de la fecha local de la corrida. En las corridas ejecutadas después de las 21:00 locales ambas fechas dejan de coincidir, y el límite superior queda ubicado unas horas antes del momento de la consulta. Ocurrió dos veces durante la recolección, el 3 y el 5 de septiembre de 2026, en ambos casos en corridas manuales que repusieron la ejecución del día. El tramo que así queda por encima del límite superior vuelve a caer dentro de la ventana de la corrida siguiente, que abarca los dos días anteriores, de modo que la superposición lo cubre por construcción y no por una compensación medida.

La superposición no genera filas repetidas. Antes de persistir, el flujo consulta si el par vulnerabilidad-activo ya existe.

La interfaz de la NVD entrega como máximo dos mil registros por respuesta e informa el total disponible; el resto solo llega si se piden las páginas siguientes, y no pedirlas no produce error (National Institute of Standards and Technology, s. f.-a). El artefacto lo atiende con dos medidas, ambas incorporadas con la reestructuración. La primera es un testigo de truncamiento: cada corrida registra en su fila de auditoría cuántas vulnerabilidades recibió, cuántas páginas llegaron y si la respuesta quedó incompleta, de modo que una pérdida sería detectable sobre el dato ya persistido. El testigo terminó de completarse durante el período de estabilización, y las veintiocho corridas de la recolección lo llevan entero, según detalla el Anexo D. El testigo compara el total que la fuente declara en su primera página contra la cantidad de registros efectivamente recibidos, de modo que detecta un faltante neto y no una pérdida registro por registro. Esa comparación tiene un punto ciego: el total declarado puede cambiar mientras se recorren las páginas, y si crece, un faltante quedaría compensado dentro del mismo balance. Ocurrió una vez durante la recolección: el 9 de septiembre de 2026 la corrida recibió 2.466 registros contra los 2.448 que la primera página declaraba, porque la fuente publicó nuevos registros entre una página y la siguiente. El testigo no señala ese caso, dado que solo se activa cuando lo recibido queda por debajo de lo declarado. La segunda es el recorrido paginado de la respuesta, acotado a cinco páginas por corrida. Entre las dos medidas, el artefacto ingiere hasta diez mil registros por ejecución y deja constancia de si ese techo se alcanzó.

Para la **consulta del contexto interno**, al comenzar cada corrida el flujo lee el inventario mediante una consulta al esquema relacional y obtiene, para cada uno de los treinta activos, su identificador de plataforma, su nivel de exposición y el peso de criticidad ya normalizado. Ese conjunto es el que la etapa de correlación compara después contra cada vulnerabilidad ingerida, según describe la sección 3.10.

Para la **captura de telemetría**, el sistema instrumenta su propio recorrido registrando marcas temporales en la base de datos. Son tres las que describen la detección: la fecha en que la vulnerabilidad se publicó en la NVD, el momento en que el flujo la ingirió —una sola marca por corrida, estampada cuando comienza el procesamiento— y el momento en que se cerró su procesamiento y se persistió su estado, que el flujo escribe tanto si emite una notificación como si no. La marca de ingesta se estampa al comenzar la etapa de correlación, una vez completada la descarga de

la ventana. El intervalo que va de esa marca al cierre del procesamiento mide, por lo tanto, el trabajo que el artefacto hace sobre los registros ya obtenidos, y deja fuera el tiempo de descarga, que es del orden de decenas de segundos por corrida. A esas tres se suman dos que registran el comportamiento de la fuente: cuando una correlación establecida por inferencia recibe después el identificador formal, el sistema anota la fecha de última modificación que la NVD declara en ese momento y la corrida en que lo advirtió.

La recolección se abrió el 30 de agosto de 2026, primera corrida posterior a la publicación de la versión congelada del artefacto, y se cerró el 26 de septiembre de 2026, con una extensión de veintiocho días de calendario. Las corridas anteriores a esa fecha se declaran período de estabilización y quedan excluidas con el alcance descrito en la sección 3.3. El criterio de cierre se fijó de antemano mediante tres condiciones, todas evaluables sin mirar resultados: cubrir por completo la ventana de mayor densidad de publicación del mes, contar con al menos tres corridas efectivas posteriores a ella para observar promociones de fuente, y acumular un volumen mínimo de pares suficiente para extraer la muestra de validación. La ventana de mayor densidad fue el 8 de septiembre de 2026, con 1.571 vulnerabilidades publicadas, y se ingirieron las 1.571. La segunda condición exigía al menos tres corridas efectivas posteriores a la del 11 de septiembre, la primera cuya ventana ya no alcanza ese día, y hubo catorce. La tercera exigía sesenta pares nuevos desde la apertura, y el 15 de septiembre ya se habían acumulado 3.798, frente a los 3.848 del cierre. Ese umbral se fijó antes de definir la muestra, de 65 casos, y el volumen acumulado superó con holgura las dos cifras. Las tres quedaron cumplidas con la corrida del 15 de septiembre. Las condiciones fijan un mínimo y no una fecha: el cierre del 26 de septiembre se eligió por calendario, para completar cuatro semanas desde la apertura. Que el criterio de parada no dependa de los resultados es lo que impide elegir el momento de detenerse en función de si las cifras favorecen.

Cerrada la recolección, la NVD se reconsultó el 3 de octubre de 2026 sobre el período completo, en una sola consulta que no toca el flujo ni lo recolectado, de modo que todas las vulnerabilidades quedan observadas en el mismo instante. Una reconsulta anterior, del 30 de septiembre, aporta solo la cifra de retiradas de la Tabla 7. El resultado se contrasta con dos registros de cada corrida: lo que la NVD devolvió en ese momento, que conserva el historial de ejecuciones del orquestador, y la lista de vulnerabilidades que la corrida correlacionó, que queda en su fila de auditoría. El primer contraste establece qué proporción de las vulnerabilidades ingeridas terminó recibiendo el dato de correlación formal. La ventana de tres días impide ver los enriquecimientos que llegan más tarde, y la reconsulta reduce ese sesgo sin eliminarlo: las vulnerabilidades publicadas al final del período llegan a ella con siete días de antigüedad, y las del comienzo con treinta y seis. Para fechar la llegada de ese dato, el 13 de octubre de 2026 se consultó además el historial de cambios que la NVD publica para cada vulnerabilidad. Ese historial registra el momento exacto en que se agregó la configuración, de modo que la demora de la fuente se mide también en las vulnerabilidades que ya habían salido de la ventana. Ninguna perdió el dato formal entre la ingesta y la reconsulta, de modo que esa proporción se lee como un piso. Quince vulnerabilidades publicadas el 26 de septiembre, después de la última corrida, no entraron en ninguna ventana y quedan fuera de toda cifra de cobertura.

El segundo contraste establece la cobertura de detección: qué parte de lo que la NVD terminó vinculando con algún activo del inventario había detectado el artefacto. La referencia es la NVD y no la exposición real del inventario: lo que la NVD no vinculó con ningún activo queda fuera de la medición. Se calcula con dos criterios. El primero es la regla del propio artefacto, que toma cualquier producto nombrado en el registro, y mide cuánto alcanzó a ver el sistema tal como está construido. El segundo cuenta solo el producto que la NVD marca como vulnerable y no la plataforma sobre la que se ejecuta (la sección 5.1 precisa la distinción). Ese criterio mide la detección contra lo que efectivamente afectaba a los activos. Como el artefacto no hace esa distinción, según declara la sección 1.7, los pares que la vía formal persistió solo por la plataforma se informan aparte, como error de esa vía. Ambos criterios se calculan por vulnerabilidad y por par, porque una vulnerabilidad cuenta como detectada aunque haya alcanzado a uno solo de los activos afectados, y esa unidad oculta los activos a los que no llegó.

La reconsulta permite además contrastar la vía de inferencia con el dato formal que llegó después. Un par inferido cuyo activo la NVD terminó enumerando como producto afectado coincide con la vía formal; uno cuya vulnerabilidad la NVD analizó sin enumerar ese activo queda señalado como posible falso positivo. El contraste no reemplaza la validación caso por caso de la sección 3.12, por dos motivos: la vía formal tampoco evalúa la versión, y lo que la NVD todavía no analizó queda sin contrastar. La regla de inferencia se reaplicó además el 2 de octubre de 2026 sobre los nombres de fabricante y producto vigentes, para establecer si su insumo cambia después de la publicación como cambia el dato formal. El Capítulo 5 informa todos estos resultados.

3.8 Criterios de cómputo y exclusiones

Las decisiones que siguen determinan qué cuenta cada cifra del Capítulo 5 y qué material queda fuera de cada medición. La exclusión de mayor alcance —el período de estabilización previo a la apertura de la recolección— se describe en la sección 3.3, junto al argumento de validez que la funda.

Unidad de cómputo. Las métricas se calculan sobre corridas efectivas y no sobre días de calendario. El artefacto opera sobre infraestructura local —el orquestador y la base de datos se ejecutan en contenedores sobre un equipo anfitrión—, de modo que la ejecución de cada corrida diaria depende de la disponibilidad de ese equipo a la hora programada. Ante una interrupción de esa disponibilidad se adoptó el criterio de suplir la corrida de forma manual dentro del mismo día, preservando la continuidad de la serie. El criterio se aplicó en todos los casos salvo uno. El 12 de septiembre de 2026 el disparo automático se produjo y el flujo falló a los diez segundos, sin dejar fila de auditoría ni persistir ningún par, y la corrida no se repuso. La falla fue del entorno y no del flujo: con el equipo recién reactivado de una suspensión, el contenedor no pudo resolver el dominio de la NVD. No se perdieron vulnerabilidades, porque la superposición de las ventanas de tres días hizo que todo lo que esa corrida debía consultar lo ingirieran las corridas del 11 y del 13 de septiembre. Es el único día de la ventana de recolección sin corrida registrada. El artefacto está congelado, y por lo tanto la versión que ejecuta un disparo automático y la que ejecuta uno manual son la misma: el modo de disparo no altera lo que el sistema hace, y las corridas manuales son datos válidos de la recolección.

De las veintiocho corridas de la recolección, veintiuna se dispararon de forma automática y siete se ejecutaron a mano. Lo que sí queda afectado es el instante de ejecución, y por eso toda medición anclada a la hora de la corrida se lee con esa salvedad. El 1 de septiembre de 2026 se registraron dos corridas sobre la misma ventana: la automática y, ocho minutos después, una manual. Ambas recibieron los mismos 739 registros y correlacionaron el mismo par. La segunda no alteró los datos de la investigación, porque antes de escribir el flujo consulta si el par ya existe, según describe la sección 3.10, y la base conserva una única fila de ese par, escrita por la primera. Sí dejó su propia fila de auditoría, que repite la anterior. Por eso las métricas por corrida se computan sobre la primera, y las veintiocho corridas de la recolección equivalen a veintisiete corridas efectivas.

Fuente de cada cifra. Dos tablas registran lo que el sistema encontró, y no cuentan lo mismo. La tabla de auditoría deja una fila por corrida, con las vulnerabilidades que esa corrida correlacionó y los conteos por vía; como la ventana abarca tres días, una misma vulnerabilidad aparece en todas las corridas que la correlacionaron. La tabla de telemetría deja una fila por par vulnerabilidad-activo, escrita la primera vez que el par aparece, con su índice y su prioridad. Cada cifra del Capítulo 5 sale de la tabla que registra lo que esa cifra cuenta: las cifras por corrida y por vía, de la auditoría; las de pares, prioridades, índices y notificaciones, de la telemetría. Los totales de la campaña por vulnerabilidad pueden leerse en cualquiera de las dos, porque ambas registran el mismo conjunto. En adelante, cada cifra indica de qué tabla proviene. La auditoría tiene además un límite: su lista guarda solo las vulnerabilidades que la corrida correlacionó y no todas las que ingirió, de modo que lo que entró en cada ventana se reconstruye desde el historial de ejecuciones del orquestador o volviendo a consultar a la NVD, como describe la sección 3.7.

Convención temporal. La base de datos opera en tiempo universal coordinado y el entorno de ejecución en el huso local, tres horas por detrás. Las columnas de fecha almacenan el instante sin declarar huso, de modo que toda consulta que agrupe por día convierte al huso local antes de truncar la fecha. Los parámetros con que se consulta a la fuente siguen otra convención, descrita en la sección 3.7. La regla no admite excepciones: toda marca de instante que el sistema persiste —tanto las que escribe el orquestador como las que genera el motor de base de datos— queda en tiempo universal coordinado y requiere la misma conversión. Las dos columnas que registran una fecha de calendario y no un instante, detalladas en el Anexo C, quedan fuera de la regla porque no expresan hora.

Vulnerabilidades retiradas. Parte de los registros que ingiere el flujo vienen marcados como retirados por el organismo que los publicó, sea por duplicación o por error. No traen fabricante, ni producto, ni identificador de plataforma, de modo que no pueden correlacionar por ninguna de las dos vías. No se depuran: se conservan en el denominador y su proporción se declara junto a toda cifra de cobertura del Capítulo 5, tanto en el momento de la ingesta como al cierre, porque el organismo emisor puede retirar una vulnerabilidad después de que el flujo la ingirió. Excluirlos habría exigido cambiar los parámetros de la consulta y habría vuelto incomparables las cifras de la recolección con las del diagnóstico previo, que tampoco los excluía.

Ausencia de puntaje de severidad. Según se indicó en la sección 3.5, el flujo persiste un cero cuando la respuesta no trae puntaje. Para el cálculo del índice y para determinar si cruzó el umbral, esa ausencia vale cero y no se excluye ninguna fila: un cero deja la fila contable, mientras que un valor nulo la borraría del análisis y no permitiría clasificarla ni como que cruzó ni como que no. El recálculo del cierre aplica el mismo criterio, de modo que la diferencia entre el índice de la detección y el del cierre refleja la maduración del dato y no un cambio en la regla de cálculo.

Ausencia de probabilidad de explotación. El flujo consulta ese valor una vez por par y persiste cero cuando la respuesta no trae dato. FIRST actualiza sus estimaciones una vez por día (Forum of Incident Response and Security Teams, 2026b), de modo que una cohorte de uno a tres días puede contener registros que todavía no lo tienen asignado. El índice de esos pares se calcula con el componente en cero, lo que corresponde al estado de la información en el momento de la detección. A esa ausencia se suma una limitación de precisión: la columna de la tabla de campaña almacena cuatro decimales, de modo que un valor real inferior a 0,00005 también queda registrado como cero. Un cero persistido no distingue, por lo tanto, una probabilidad ausente de una probabilidad real muy baja. La distinción es recuperable, porque la interfaz de FIRST admite consultar el valor histórico de una vulnerabilidad para una fecha determinada, y al cierre se estableció para cada par. De los 3.848 pares de la recolección, 53 registraron cero, y en los 53 el cero es ausencia de dato: FIRST publicó su primera estimación el día siguiente a la ingesta, y el valor más bajo de sus series históricas es 0,00101, muy por encima del límite de redondeo.

Filas excluidas del tiempo de procesamiento. Dos conjuntos de filas salen del cálculo del intervalo de procesamiento interno, y de ninguna otra medición. El primero son las siete filas de la corrida del 3 de septiembre de 2026, que se interrumpió a mitad de ejecución al caducar la credencial de acceso al servicio de correo y se completó ejecutando a mano, uno por uno, los nodos restantes del flujo: la marca de cierre de esas filas se escribió durante esa intervención, veintisiete minutos más tarde, de modo que el intervalo mide la reparación y no el procesamiento. Todo el resto de esas filas es válido y entra al análisis sin salvedad. El segundo conjunto corresponde a las corridas anteriores a la incorporación del control de ritmo entre peticiones, el 9 de septiembre de 2026, que se ejecuta dentro del intervalo medido y lo ensancha: las corridas previas y posteriores no son comparables entre sí, de modo que el intervalo se reporta solo sobre las posteriores y declarando que incluye esa espera. La corrida que el servicio de FIRST interrumpió ese día, según relata la sección 3.12, no se reparó nodo por nodo: se repitió completa con el flujo ya modificado, y sus filas cuentan entre las posteriores.

3.9 Herramientas tecnológicas e infraestructura

Las herramientas se seleccionaron por ser de uso gratuito, interoperables entre sí y auditables. Toda la arquitectura local se desplegó sobre tecnologías de contenerización, de modo que el entorno pueda reconstruirse con exactitud a partir de sus archivos de configuración. Los componentes principales del sistema son los siguientes:

- **Motor de contenerización (Docker).** Se implementó Docker (Docker Inc., s. f.) como capa de infraestructura para el despliegue del entorno de pruebas. El orquestador y la base de datos se ejecutan así en entornos aislados y estandarizados. Esa aislación separa el sistema de la configuración del sistema operativo anfitrión y permite que la arquitectura sea replicada por otros investigadores a partir de un único archivo de configuración.
- **Motor de orquestación (n8n).** Ejecutado como un contenedor independiente, n8n (n8n GmbH, 2025) es la plataforma *low-code* que conecta al resto de los componentes. Se seleccionó porque resuelve con nodos propios las peticiones HTTP, el procesamiento de las respuestas JSON y la programación de la ingesta recurrente. Aloja el *pipeline* que procesa y cruza las cinco variables del modelo de priorización.
- **Sistema de gestión de bases de datos relacionales (PostgreSQL).** Desplegado en su propio contenedor y conectado internamente con n8n, PostgreSQL (PostgreSQL Global Development Group, s. f.) actúa como motor de persistencia. Para aislar los datos operativos se implementó una base específica para esta investigación, ***secops_research_db***, separada lógicamente de la base interna del orquestador. Almacena el inventario de activos simulados con sus variables estáticas de criticidad y exposición, y registra el histórico de vulnerabilidades procesadas. Es el componente sobre el que se apoya la trazabilidad auditable del recorrido de cada hallazgo, descrita en la sección 2.8.
- **Interfaz v2.0 de la National Vulnerability Database (NVD).** Mantenida por el NIST y documentada en su manual público (National Institute of Standards and Technology, s. f.-a), es la fuente primaria de la recolección. De ella se obtienen el puntaje de severidad, los datos que permiten resolver la correlación con el inventario y, redistribuido dentro de la misma respuesta, el contenido que aporta CISA: la pertenencia al catálogo de explotación conocida y el punto de decisión sobre explotación.
- **Interfaz de administración (pgAdmin).** Desplegado como servicio auxiliar dentro del entorno contenerizado, facilita la gestión gráfica y la inspección directa del motor PostgreSQL. Se empleó para auditar registros, depurar y verificar el esquema durante el desarrollo y la validación de la PoC.
- **Interfaz de FIRST (datos de EPSS).** Provee el valor continuo de probabilidad estimada de explotación, que completa la dimensión de inteligencia externa del modelo (Forum of Incident Response and Security Teams, s. f.). Sus endpoints públicos no admiten autenticación, y el acceso a límites ampliados está reservado a organizaciones miembro de FIRST (Forum of Incident Response and Security Teams, 2026a).
- **Capa de presentación (FastAPI y React).** Un servidor de aplicaciones desarrollado en Python con FastAPI (Ramírez, s. f.) expone los datos de vulnerabilidades, activos y auditoría mediante una interfaz RESTful. Sobre él, una aplicación web construida con React (Meta Platforms, Inc., s. f.) y TypeScript —con Vite (VoidZero Inc. & Vite contributors, s. f.) como herramienta de construcción y Tailwind CSS (Tailwind Labs, Inc., s. f.) para el sistema de estilos— y servida localmente por el

servidor de desarrollo de Vite, le permite al analista consultar los hallazgos priorizados y registrar sobre ellos los estados de revisión. A diferencia del orquestador y la base de datos, corre fuera del entorno de contenedores de la investigación (sección 1.7).

Las dos interfaces externas imponen restricciones operativas que condicionaron el diseño del flujo, y que cualquier implementación que consulte estas fuentes en volumen va a encontrar.

La primera es el techo de respuesta de la NVD, descrito en la sección 3.7, que obliga a recorrer la respuesta por páginas.

La segunda es el límite de ritmo de esa misma interfaz. El NIST declara un máximo de cinco peticiones cada treinta segundos, en ventana móvil, para el acceso sin clave, y de cincuenta con clave registrada, y recomienda además espaciar las peticiones varios segundos (National Institute of Standards and Technology, 2025). A ese límite documentado se suma uno que no lo está: el servicio de mitigación de automatismos que la NVD tiene delante de su interfaz se activa por volumen sostenido aun operando holgadamente por debajo del techo publicado. Durante este trabajo, una secuencia que emitía hasta treinta peticiones cada treinta segundos —un cuarenta por ciento por debajo del límite con clave— fue interrumpida tras unos doce minutos de tráfico continuo, con una respuesta que no provenía de la interfaz sino del servicio de mitigación. El flujo incorpora por eso un intervalo entre peticiones y reintento automático.

La tercera concierne al servicio de FIRST, que limita sus endpoints públicos a mil peticiones por minuto, pide expresamente evitar peticiones concurrentes y advierte que el comportamiento abusivo puede quedar bloqueado de forma temporal sin aviso previo, devolviendo un código de estado 429 (Forum of Incident Response and Security Teams, 2026a). Lo observado durante la recolección difiere de esa descripción: el bloqueo se manifestó como un rechazo de conexión sin código de estado alguno, indistinguible a primera vista de una caída del servicio, lo que desvía el diagnóstico. El flujo incorpora un control de ritmo entre peticiones para operar dentro de esa condición.

La orquestación de estas herramientas dentro de un ecosistema contenerizado permite operar el modelo de cinco variables sin costos de licenciamiento y sobre componentes que otro investigador puede desplegar a partir de los archivos incluidos en el Capítulo 9.

3.10 Descripción de la Arquitectura de Flujos

La arquitectura se implementa como un flujo de orquestación asíncrona sobre n8n. Su diseño actual es el resultado de una reestructuración: el flujo original operaba guiado por el inventario y ese principio dejó de ser viable con un enriquecimiento demorado. La forma del flujo vigente se explica entera por ese cambio, de modo que la descripción parte de él.

El diseño original partía del inventario. Consultaba los treinta activos en la base, construía con sus identificadores de plataforma una solicitud por cada uno y le pedía a la NVD las vulnerabilidades que afectaban a ese producto publicadas en una ventana de tres días (parámetros `cpeName`, `pubStartDate` y `pubEndDate`). Quien resolvía la correspondencia era el servidor de la fuente,

comparando el identificador pedido contra las configuraciones declaradas en cada registro. Como esas configuraciones son justamente lo que aporta el enriquecimiento, y el enriquecimiento llega con demora o no llega, una vulnerabilidad sin configuración quedaba fuera de la respuesta. No devolvía un error: devolvía silencio, que en un sistema de detección es indistinguible de la ausencia legítima de vulnerabilidades. La sección 2.3 explica por qué filtrar del lado del servidor solo alcanza a las vulnerabilidades ya enriquecidas.

El rediseño invirtió el sentido del flujo. En lugar de preguntar por cada activo, el sistema ingiere todo lo que se publicó en la ventana y resuelve la correspondencia. La correlación deja de ser un servicio que se consume y pasa a ser una capacidad del artefacto. La inversión tuvo un costo. Para los productos que el inventario identifica con su versión, el servidor de la fuente comparaba esa versión contra los rangos declarados en cada registro; el flujo vigente no la evalúa por ninguna de sus dos vías, por los motivos que expone la sección 1.7, y el Anexo A documenta la verificación de ese comportamiento. La distinción entre el producto vulnerable y la plataforma sobre la que se ejecuta, en cambio, tampoco la hacía la consulta anterior.

El flujo vigente se dispara una vez por día, a hora fija, y recorre seis etapas.

Lectura del inventario. El flujo comienza consultando el esquema relacional y obteniendo los treinta activos con su identificador de plataforma, su nivel de exposición y su peso de criticidad ya normalizado. El inventario sigue siendo lo primero que el sistema mira, pero ya no para construir la consulta externa: para tener contra qué comparar lo que traiga.

Ingesta de la ventana. Una única solicitud a la interfaz de la NVD pide las vulnerabilidades publicadas dentro de la ventana de tres días que define la sección 3.7, autenticada con la clave que el organismo provee para ampliar el límite de peticiones. La respuesta se recorre por páginas, hasta un máximo de cinco por corrida (sección 3.7). El testigo de truncamiento no registró truncamiento en ninguna de las veintiocho corridas de la recolección, cuyo volumen máximo fue de 2.804 registros recibidos en dos páginas, algo más de la cuarta parte del techo de diez mil. Esa necesidad de paginar es consecuencia directa de la inversión y no una optimización: el patrón anterior emitía consultas acotadas que nunca se acercaban al techo de la respuesta, mientras que concentrar la ventana completa en una sola consulta convierte ese techo en un límite operativo del artefacto.

Registro de la corrida. De la respuesta se desprende una rama de auditoría que se ejecuta haya o no correlaciones. Registra cuántas vulnerabilidades declara la ventana, cuántas se recibieron efectivamente, cuántas páginas llegaron, si la respuesta quedó truncada, cuántas correlacionaron y por cuál vía, junto con la lista de sus identificadores. Esa fila permite distinguir después una corrida sin coincidencias de una corrida que falló, y es la fuente de las cifras de cobertura por corrida.

Correlación local. Es la etapa que el rediseño incorporó. Para cada vulnerabilidad ingerida, el flujo extrae el puntaje de severidad, la pertenencia al catálogo de explotación conocida, el punto de decisión sobre explotación y la descripción, y arma dos conjuntos de datos de correspondencia. Después compara esa vulnerabilidad contra cada uno de los treinta activos y decide, activo por activo, si hay correspondencia y por cuál vía.

El orden de esa decisión es el que define la cascada. Primero se prueba la **vía formal**: si el identificador de plataforma del activo coincide en fabricante y producto con alguno de los que publica el NIST, el par se registra con esa procedencia y con confianza formal. Si no coincide, se prueba la **vía de inferencia**: se comparan los nombres de fabricante y de producto, normalizados a minúsculas y sin separadores, exigiendo coincidencia en ambos términos. La comparación admite contención en cualquier dirección, de modo que un nombre contenido dentro de otro se considera coincidencia. Si ninguna de las dos vías resuelve, el par se descarta y no queda registro de él.

Ninguna de las dos vías considera la versión, y el Capítulo 4 detalla cómo se construye cada comparación. Las dos establecen, por lo tanto, que el activo corre el producto afectado, y no que corra una versión comprendida en el rango que la vulnerabilidad declara.

La comparación por inferencia incorpora un resguardo de longitud mínima, que se aplica sobre los nombres que declara el registro de la vulnerabilidad: se descarta la comparación cuando el fabricante que el registro declara tiene menos de cuatro caracteres, o el producto menos de tres. El umbral no es arbitrario. Por un lado, los registros que declaran al fabricante como no disponible normalizan a una cadena de dos caracteres capaz de coincidir con cualquier nombre que la contenga. Por otro, el límite se fijó al borde del inventario vigente: para que un activo pueda correlacionar, el registro tiene que nombrar su fabricante y su producto, y los más cortos que el inventario contiene tienen cuatro y tres caracteres respectivamente. Un umbral mayor descartaría esos registros y con ellos a los activos que les corresponden, y ampliar el inventario con un producto más corto obligaría a revisar la decisión.

Que la decisión se tome activo por activo, y no vulnerabilidad por vulnerabilidad, tiene una consecuencia: una misma vulnerabilidad puede quedar vinculada a sus activos por las dos vías, resolviendo por la formal los activos que el NIST enumeró y por la de inferencia los que quedaron fuera de esa enumeración. Las dos vías no compiten por el mismo registro; se reparten sus activos. El mecanismo admite que eso ocurra dentro de una misma corrida, pero en la recolección no ocurrió: ninguna corrida vinculó una vulnerabilidad a sus activos por las dos vías. Ocurrió entre corridas consecutivas, sobre ocho vulnerabilidades de Windows publicadas el 8 de septiembre de 2026. La corrida del día siguiente, anterior a la enumeración del NIST, las vinculó por inferencia a una parte de los activos afectados. La del 10 de septiembre, con la enumeración ya publicada, vinculó por la vía formal al resto y registró la confirmación formal de los primeros. El Capítulo 5 reporta el caso, incluido por qué la inferencia no alcanzó a todos.

El trabajo declara cuatro fuentes posibles de correlación y el artefacto opera con dos. Las otras dos —el identificador que la CNA declara dentro del registro y el que puede aportar CISA en su rol de publicador autorizado— no llegan por este camino: la interfaz de la NVD reescribe el registro de origen y no expone el campo en que la CNA publica ese dato, y CISA aporta datos de priorización y no de correlación. Su contribución se mide por fuera del artefacto, sobre una copia local del repositorio de registros y al cierre de la recolección, según declara la sección 1.7.

Enriquecimiento y cálculo. Cada par resultante de la correlación se enriquece con la probabilidad estimada de explotación, mediante una consulta a la interfaz de FIRST emitida con un intervalo mínimo entre peticiones. Con las cinco variables disponibles se calcula el Índice de Riesgo Compuesto según la función definida en la sección 3.6 y se asigna la categoría de prioridad correspondiente.

Persistencia y triaje. Antes de escribir, el flujo consulta si el par ya existe en la base, y de ahí se abren dos caminos. Si el par es nuevo, se persiste con todas sus variables y se evalúa contra el umbral de notificación: los que lo alcanzan derivan al mecanismo de notificación por correo electrónico descrito en la sección 3.11 y quedan marcados como notificados; los que no, quedan registrados como informativos. En ambos casos se escribe la marca que cierra el procesamiento.

Si el par ya existía, en cambio, se deriva a una rama de registro de promoción. Esa rama existe por un motivo que el diseño original no podía prever: bajo el régimen anterior la vulnerabilidad llegaba ya enriquecida, con su correlación resuelta y sus datos de priorización completos, de modo que un par ya persistido no tenía nada nuevo que aportar en las corridas siguientes ni era esperable que lo tuviera dentro de una ventana de tres días. Con enriquecimiento diferido eso dejó de ser cierto, y esa rama pasó a ser el único punto del artefacto donde puede registrarse que una correlación establecida por inferencia recibió después confirmación formal. Cuando eso ocurre, la rama anota la fuente que confirmó, la fecha de última modificación que la NVD declara en ese momento y la corrida en que se advirtió, sin sobrescribir la procedencia original. La distinción es deliberada: el campo de procedencia conserva el significado de fuente de detección inicial, de modo que la primera hipótesis siga midiendo con qué vía se detectó una vulnerabilidad y no con cuál se la conoce hoy.

Un segundo circuito, disparado por evento, reprocesa bajo demanda una vulnerabilidad contra un activo determinado a pedido de la capa de presentación. Durante la recolección compartió el lienzo con el flujo periódico sin intervenir en él: no se invocó en ninguna oportunidad, y al cierre se lo trasladó a un lienzo propio. El Capítulo 9 incluye las exportaciones de ambos, junto con la del flujo de reevaluación diferida.

La siguiente figura representa la secuencia operativa del sistema: la lectura del inventario, la ingesta de la ventana completa, la correlación local con sus dos vías, el enriquecimiento externo y la bifurcación hacia la notificación, el registro informativo o el registro de promoción.

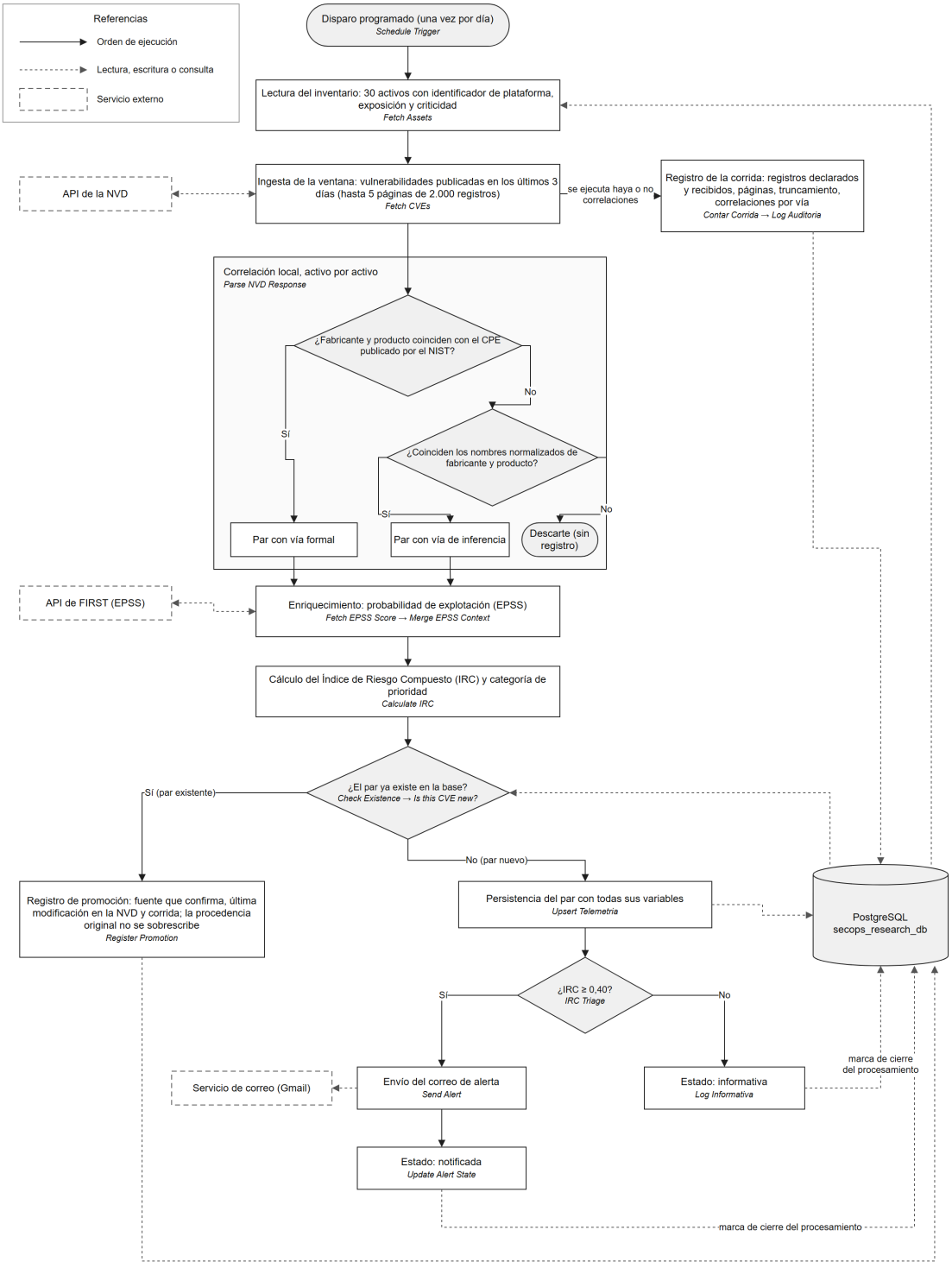


Figura 1. Arquitectura de flujos del sistema de notificación automatizada de vulnerabilidades. Elaboración propia a partir del flujo publicado en n8n, cuya exportación se incluye en el Capítulo 9.

3.11 Mecanismo de notificación y estructura de las alertas

Dentro del paradigma con la persona en el circuito, el sistema emplea el correo electrónico como canal de comunicación entre el motor de orquestación y el analista. La decisión prioriza la disponibilidad y la permanencia de la información: la alerta llega a una herramienta que el analista ya usa a

diario y queda archivada sin depender de que el sistema siga en línea. En el entorno de la Prueba de Concepto las notificaciones se dirigen a una única casilla predefinida, sin reparto por responsable de activo.

Estructura del mensaje

El asunto del correo identifica la categoría de prioridad asignada, el identificador de la vulnerabilidad y el identificador interno del activo afectado, de modo que el destinatario puede ordenar su bandeja por prioridad y por vulnerabilidad sin abrir los mensajes. El cuerpo se compone de una tabla con ese identificador de activo, el identificador de la vulnerabilidad, la categoría de prioridad junto al valor del índice que la determinó, el puntaje de severidad y la probabilidad estimada de explotación; debajo, la descripción oficial publicada por la NVD y el enlace al registro completo.

Enrutamiento

La emisión del correo está supeditada al valor del índice. El nodo de triaje evalúa una única condición: si el índice alcanza o supera 0,40, el hallazgo deriva al envío y queda registrado como notificado; si no lo alcanza, se registra como informativo y no genera correo. Las dos categorías que superan el umbral —alta y crítica— comparten esa misma rama y reciben el mismo formato de mensaje, de modo que la distinción entre ambas se comunica por el asunto y por el valor del índice.

Los hallazgos que no alcanzan el umbral se persisten igual, con todas sus variables, y quedan disponibles para el análisis posterior.

El mecanismo opera sobre pares y no sobre vulnerabilidades. Una misma vulnerabilidad que alcanza a varios activos del inventario genera una notificación por cada uno, porque el índice que decide el envío incorpora la criticidad y la exposición de cada activo y puede dar resultados distintos. En un inventario de treinta activos el efecto está acotado; en uno de mayor escala, un boletín de un fabricante con muchos productos instalados produciría una avalancha de mensajes. La recomendación 7.3.4 propone agrupar los avisos por vulnerabilidad.

3.12 Procedimiento

La ejecución de la investigación se desarrolló en siete fases. Las tres primeras corresponden al plan original; la cuarta es la que lo reorientó; la quinta, la capa de presentación complementaria, se desarrolló en paralelo a la tercera, y las dos últimas corresponden al diseño resultante.

Fase 1: Despliegue de la infraestructura contenerizada

El procedimiento comenzó configurando el entorno de pruebas con Docker. Se redactó un archivo de composición que instancia, de manera aislada y controlada, los contenedores del motor de base de datos y del orquestador.

Fase 2: Modelado y población del entorno simulado

Con la base operativa se diseñó el esquema relacional, definiendo las tablas que sostienen el inventario y el registro de eventos, y se poblaron los treinta activos del entorno simulado. A cada uno se le asignaron su nivel de criticidad, su estado de exposición a Internet y su identificador de

plataforma, conforme a los criterios de distribución de la sección 3.4. El detalle tabular completo se documenta en el Capítulo 4.

Fase 3: Construcción del pipeline inicial y puesta a prueba

En el orquestador se construyó el primer flujo automatizado, guiado por inventario: consultaba los activos en la base, armaba con sus identificadores una solicitud por cada uno y pedía a la NVD las vulnerabilidades correspondientes, enriqueciendo después con la probabilidad estimada de explotación.

Las pruebas de ese flujo en agosto de 2026, con ventanas de 90 y 100 días, devolvieron vacío en 18 de los 30 activos sin que el flujo registrara ningún error. Ese resultado no aísla el efecto de la fuente, porque los diez activos de Microsoft, todos vacíos, tenían identificadores defectuosos (fase siguiente). Una vez corregidos, la misma consulta devolvió 5.487 pares y dejó vacíos ocho activos. Lo que no se resuelve con esa corrección es la demora del dato frente a una ventana de tres días (sección 3.10). Desde entonces el comportamiento del flujo se verificó contra la fuente y contra la base de datos, y no contra la interfaz del orquestador, criterio que se mantuvo durante toda la recolección.

Fase 4: Diagnóstico previo y reestructuración

Antes de modificar nada se ejecutó un diagnóstico sobre una copia local del repositorio público de registros, descrito en el Anexo A, con dos propósitos: establecer si el inventario producía volumen suficiente de correlaciones para sostener un análisis, y verificar que sus identificadores recuperaran efectivamente las vulnerabilidades que les correspondían. El diagnóstico detectó ocho identificadores defectuosos, que se corrigieron en la base y en el archivo de inicialización del esquema.

Con ese resultado se reestructuró el flujo. Se invirtió el sentido de la ingesta, se construyó dentro del artefacto la lógica de correlación descrita en la sección 3.10, se incorporó el recorrido paginado de la respuesta y se ampliaron las columnas del registro de telemetría para acompañar el nuevo diseño. El alcance de esa reestructuración fue acotado: el esquema relacional no se reconstruyó, se le agregaron siete columnas sobre la estructura existente, y el motor, la base de datos y el modelo de priorización se conservaron sin cambios. Lo que se rehízo fue el modo de obtener el dato de correlación.

Fase 5: Desarrollo de la interfaz de usuario y el servidor de aplicaciones

Se desarrolló en junio de 2026, mientras se construía el flujo inicial, la capa de presentación descrita en la sección 3.9: un servidor de aplicaciones conectado a la base de datos ya poblada y una interfaz web. La comunicación entre ambos se resolvió con una interfaz de programación para la consulta y un canal WebSocket para la actualización. Esta fase no modificó el flujo de recolección ni el esquema de datos.

Fase 6: Estabilización, congelamiento y recolección

Las primeras corridas del flujo reestructurado se declararon período de estabilización y quedaron fuera del análisis: hasta esa fecha el flujo continuaba ajustándose, de modo que sus registros no son

comparables uno a uno con los posteriores para todos los fines. La sección 3.3 fija el alcance con que esa exclusión se aplica a cada tipo de medición. El Anexo D del Capítulo 9 detalla las corridas comprendidas en el período, los ajustes que las afectaron y las filas que dejaron en la base.

Corregidos esos puntos, el artefacto se publicó en su versión definitiva y se declaró congelado: sin modificaciones hasta el cierre de la recolección, salvo eventualidad crítica que pusiera en riesgo la propia recolección. El congelamiento queda fechado por el registro de versiones del orquestador, y los cambios se verificaron contra la base en la primera corrida posterior a su publicación. La recolección se abrió con la primera corrida siguiente, el 30 de agosto de 2026, y se extendió hasta el 26 de septiembre de 2026, conforme al criterio de la sección 3.7.

Durante la recolección se produjo una eventualidad de la clase prevista y el flujo de recolección se modificó una sola vez, el 9 de septiembre de 2026. Ese día, la ventana de mayor densidad de publicación del mes produjo un volumen de pares muy por encima de lo habitual, y el nodo que consulta la probabilidad de explotación —dimensionado contra el caudal observado hasta entonces — fue rechazado por el servicio externo a mitad de corrida. La disyuntiva era conservar el congelamiento y perder íntegramente esa ventana, cuya cobertura era condición de cierre, o intervenir sobre puntos que no alteraran los datos. Se optó por lo segundo: se incorporó un intervalo mínimo entre peticiones en ese nodo, se renombró un nodo condicional para alinearlo con su significado real y se publicó una corrección de parseo pendiente en una rama que no participa de la recolección. Ninguno de los tres cambios altera la lógica de cálculo ni los datos de salida: el renombre es cosmético, la corrección de parseo está en una rama ajena, y el control de ritmo cambia cuándo llegan las peticiones y no qué devuelven. La única discontinuidad que se declara es sobre el intervalo de procesamiento interno, que ese control ensancha y que por eso se reporta solo sobre las corridas posteriores, según indica la sección 3.8. El artefacto volvió a estado congelado al día siguiente, bajo el mismo criterio.

Fase 7: Reevaluación diferida, validación y extracción de telemetría

Sobre los datos reunidos se ejecutaron tres procedimientos, ninguno de los cuales modifica el flujo de recolección ni las filas que este escribió.

El primero es la reevaluación diferida. Un flujo separado, de disparo manual, lee las vulnerabilidades distintas detectadas durante el período, las reconsulta a la NVD y a FIRST, recalcula el índice con información madura y lo persiste en columnas nuevas, sin sobrescribir ninguna de las originales. Esas columnas y la tabla que guarda la serie diaria de la probabilidad de explotación se agregaron al esquema el 1 de septiembre de 2026, con la recolección en curso. El flujo corrió ese día como prueba y otra vez el 10 de septiembre, y la corrida del 1 de octubre, la única que usa el Capítulo 5, reescribió los valores de ambas; la serie diaria conserva las filas que esas corridas capturaron. El flujo de recolección no lee ni escribe ninguna de esas estructuras, de modo que la ampliación no alcanza al congelamiento descrito en la fase anterior. Ese contraste entre el índice registrado al detectar y el recalculado al cierre es el instrumento de la segunda hipótesis. Su diseño se apoya en una propiedad de las fuentes: FIRST publica la serie histórica de la probabilidad de explotación (Forum of Incident

Response and Security Teams, 2026b) y CISA registra la fecha en que cada vulnerabilidad ingresó a su catálogo (Cybersecurity and Infrastructure Security Agency, 2024), de modo que la evolución de esos dos componentes se reconstruye hacia atrás y no hace falta haberla capturado día por día. Sobre esa base se descartó la alternativa de mantener un segundo proceso corriendo en paralelo durante toda la recolección, que habría sumado sus propios modos de falla sin aportar información que no fuera recuperable.

El segundo es la validación caso por caso de la correlación. Cada correlación revisada se contrasta con el registro que publicó la CNA y, cuando hace falta, con el aviso de seguridad del fabricante, anotando tres cosas: si la correspondencia entre la vulnerabilidad y el activo es correcta, si la versión instalada cae dentro del rango que el aviso declara afectado, y si la coincidencia de nombres fue completa o parcial. En las dos vías, el juicio se preparó con asistencia de un modelo de lenguaje, Claude Opus 5.5, y otra instancia del mismo modelo, sin acceso a ese juicio, revisó los mismos casos; en la vía de inferencia, otro modelo, Claude Sonnet 5.5, repitió la revisión a ciegas (apartado 5.2.1). La vía de inferencia se revisa por muestra. Sus pares se agrupan en casos —una vulnerabilidad y un producto del inventario—, porque los activos que comparten producto reciben la misma respuesta, y se sortean 65 casos. La selección se sortea y no se elige, porque escoger a criterio recoge los casos llamativos, que no representan ni a los aciertos ni a los errores; y como el volumen se concentra sobre unos pocos productos, el sorteo se reparte por producto en lugar de operar sobre el conjunto entero (apartado 5.2.1). Los siete casos del firewall quedan fuera del sorteo y se revisan todos, porque antes de sortear ya se sabía que eran errores. La vía formal se juzga completa (Anexo E), y por la misma razón que la inferencia: el artefacto aplica al identificador del NIST su propia regla, de modo que revisar esos pares mide lo que el artefacto hizo con el dato y no la calidad del dato (sección 1.7).

El tercero es la extracción de telemetría. Mediante consultas al esquema relacional se obtienen las cifras de cobertura por vía y por activo, la distribución del índice y sus componentes, los intervalos temporales descritos en la sección 3.7 y el contraste entre el índice inicial y el final. El Capítulo 5 reporta esos resultados.

3.13 Cronograma de actividades

El desarrollo de esta investigación no siguió el cronograma previsto en el anteproyecto. Aquel plan contemplaba diez semanas organizadas en cuatro fases consecutivas, desde el despliegue del entorno hasta la evaluación final, y suponía un flujo de trabajo que consultaba a la NVD en función del inventario de activos. La reforma del enriquecimiento, adoptada antes de que comenzara la construcción del flujo original, obligó a intercalar dos etapas que el plan no contemplaba: un diagnóstico sobre el estado efectivo de las fuentes y la reestructuración del flujo. El cronograma que sigue registra la ejecución real, no la planificada.

La tabla ordena las etapas en el tiempo y consigna sus hitos verificables. Las fechas exactas provienen del registro de versiones del orquestador y de las marcas temporales de la base de datos; las que se expresan por mes corresponden a tramos de desarrollo cuya delimitación precisa no quedó registrada.

Tabla 2

Cronograma de ejecución de la investigación

Etapa	Período	Hito verificable
Anteproyecto y diseño original	Abril de 2026	Formulación del problema, los objetivos y las hipótesis iniciales
Reforma del enriquecimiento de la NVD	15 de abril de 2026	El NIST restringe el enriquecimiento a un subconjunto priorizado de registros
Despliegue, modelado y construcción del flujo inicial	Mayo y junio de 2026	Contenedores en operación, esquema relacional definido, inventario de treinta activos poblado y primer flujo guiado por inventario en ejecución
Desarrollo de la capa de presentación	Junio de 2026	Servidor de aplicaciones e interfaz web construidos y conectados a la base
Puesta a prueba y diagnóstico previo	Agosto de 2026	Consultas con resultado vacío sin error registrado; diagnóstico sobre el corpus publicado entre el 1 de mayo y el 31 de julio de 2026; corrección de ocho identificadores del inventario
Reestructuración del flujo	Agosto de 2026	Inversión del sentido de la ingesta, correlación local, recorrido paginado y ampliación del esquema en siete columnas
Estabilización	23 al 28 de agosto de 2026	Corridas excluidas del análisis conforme a la sección 3.3
Congelamiento del artefacto	29 de agosto de 2026	Publicación de la versión definitiva en el registro de versiones del orquestador
Recolección	Del 30 de agosto al 26 de septiembre de 2026	Veintiocho corridas sobre ventana de tres días; única modificación declarada el 9 de septiembre de 2026
Cierre y análisis	Posterior al cierre de la recolección	Reevaluación diferida (probada el 1 y el 10 de septiembre), validación de la correlación y extracción de telemetría

Nota. Cronograma de ejecución efectiva de la investigación. Las fechas de las etapas de estabilización, congelamiento y recolección se verifican contra el registro de versiones del orquestador y contra las marcas temporales persistidas en la base de datos. Las etapas expresadas por mes corresponden a tramos de desarrollo previos a la apertura de la recolección, cuya delimitación diaria no fue registrada y no condiciona ninguna medición del Capítulo 5; los meses surgen de las fechas de los archivos de trabajo del proyecto.

El desvío respecto del plan original no se limita al calendario. Tres de los entregables previstos en la última fase del anteproyecto —la medición del tiempo medio de detección según su definición original, el coeficiente de variación calculado sobre ella y la comparación contra métricas de la industria— dejaron de ser alcanzables cuando esa definición perdió validez: medía en un solo

intervalo el procesamiento del artefacto y la demora con que la NVD publica el dato de correlación, que la organización no controla. Los reemplazan las mediciones enunciadas en la sección 3.3, que separan esos dos intervalos y se apoyan en la instrumentación efectivamente disponible.

Capítulo 4: Desarrollo de la Investigación

Este capítulo documenta el artefacto en la versión con que se cerró la recolección. Esa versión se publicó el 29 de agosto de 2026 y se mantuvo sin modificaciones hasta el cierre del 26 de septiembre, con la única excepción de la intervención del 9 de septiembre que declara la sección 3.12: la incorporación de un intervalo mínimo entre peticiones a la interfaz de FIRST, que la sección 4.5 consigna y que las corridas anteriores a esa fecha no ejecutaban. El esquema sumó el 1 de septiembre las estructuras de la reevaluación diferida, que tampoco usa el flujo de recolección (sección 3.12). Describe el entorno contenerizado, el esquema relacional, el inventario de los treinta activos, el criterio con que el sistema establece la correspondencia entre una vulnerabilidad y un activo, y los puntos del flujo donde el sistema decide. Los criterios que fundamentan cada una de esas definiciones se exponen en el Capítulo 3. Las exportaciones completas de los dos flujos, el archivo de inicialización del esquema y el archivo de composición del entorno se incluyen en el Capítulo 9.

4.1 El entorno contenerizado

Un único archivo de composición define tres servicios sobre una red interna de tipo puente. Cada servicio se ejecuta en su propio contenedor, publica un puerto hacia el equipo anfitrión y conserva su estado en un volumen con nombre, de modo que los datos sobreviven a la recreación del contenedor.

Tabla 3

Servicios del entorno contenerizado

Servicio	Imagen	Puerto	Volumen	Función
`db`	`postgres:16`	5432	`postgres_data`	Motor de persistencia. Aloja la base interna del orquestador y la base de la investigación
`n8n`	`n8nio/n8n:2.26.8`	5678	`n8n_data`	Motor de orquestación. Ejecuta los dos flujos y conserva su historial de ejecuciones
`pgadmin`	`dpage/pgadmin4:9.16`	8080	`pgadmin_data`	Panel de administración de la base, empleado para inspección y consulta directa

Nota. Servicios definidos en el archivo de composición del entorno. Las versiones consignadas son las que estuvieron en ejecución durante la recolección. El puerto indicado es el publicado hacia el equipo anfitrión; entre sí, los contenedores se comunican por la red interna. Fuente: `docker-compose.yml`*, incluido en el Capítulo 9.*

Ninguna credencial figura en el archivo de composición. Los nombres de usuario, las contraseñas, la clave de cifrado del orquestador y el secreto de sesión se declaran como variables de entorno y se resuelven desde un archivo local excluido del control de versiones. El Capítulo 9 incluye la plantilla de ese archivo, con los nombres de las variables y sin sus valores.

El arranque está condicionado. El orquestador y el panel de administración declaran una dependencia sobre el estado de salud del contenedor de la base, que se sondea cada diez segundos ejecutando

`pg_isready`, con un tiempo límite de cinco segundos por sonda y hasta cinco intentos fallidos antes de darlo por caído. Ninguno de los dos inicia hasta que la base acepta conexiones, lo que evita que el flujo arranque contra un motor todavía no disponible.

Las dos bases residen en la misma instancia de PostgreSQL y están separadas lógicamente. El orquestador guarda su propio estado —definición de los flujos, credenciales cifradas e historial de ejecuciones— en la base `n8n_internal`. Los datos de la investigación residen en `secops_research_db`. La retención del historial de ejecuciones se mantuvo habilitada durante toda la recolección, de modo que cada corrida conserva en el orquestador la traza de lo que ejecutó, además de las filas que escribió en la base de investigación.

La inicialización de la base se reparte en dos archivos. Un guion de shell, que la imagen ejecuta una única vez al crear el volumen de datos, crea la base de investigación si no existe y a continuación aplica sobre ella el archivo SQL que contiene el esquema y el inventario. La división responde a una restricción del mecanismo de inicialización de la imagen, que ejecuta los archivos SQL dentro de una transacción implícita: la creación de una base no admite ese contexto. Ambos pasos abortan ante el primer error, de modo que una inicialización incompleta no queda operativa. Los dos archivos llegan al contenedor montados desde el directorio del entorno: el guion, en el directorio que la imagen recorre al inicializar, y el archivo SQL, en una ruta auxiliar desde donde el guion lo aplica.

El huso horario del orquestador se fija en `America/Argentina/Buenos_Aires`, y es el que interpreta la hora del disparador programado. El motor de base de datos no declara huso propio y opera en tiempo universal coordinado, de modo que toda marca temporal que el motor genera queda registrada en ese huso, tres horas por delante de la hora local de ejecución. La sección 3.8 fija la convención de conversión que se aplica en consecuencia.

4.2 El esquema de datos

El esquema de la base de investigación se compone de cinco tablas.

Tabla 4

Tablas del esquema de datos

Tabla	Qué registra	Filas	Escrita por
`criticidad_niveles`	Escala ordinal de criticidad organizacional y su peso normalizado	4, fijas	Inicialización
`activos`	Inventario simulado, con criticidad, exposición e identificador de plataforma	30, fijas	Inicialización
`telemetria_vulnerabilidades`	Un registro por par vulnerabilidad-activo detectado, con sus variables, sus marcas temporales y su estado	Variable	Flujo diario y reevaluación diferida
`auditoria_acciones`	Un registro por corrida, con los conteos de ingesta y correlación	Una por corrida	Flujo diario
`epss_serie_diaria`	Serie histórica diaria de la probabilidad estimada de explotación	Variable	Reevaluación diferida

Nota. Tablas del esquema `secops_research_db`. La columna «Filas» indica si el contenido es fijo —poblado en la inicialización y no modificado durante la recolección— o si crece con la operación del sistema. Fuente: `init-db.sql`, incluido en el Capítulo 9.

Tabla de referencia de criticidad. Contiene cuatro filas, una por nivel, identificadas con los enteros 1 a 4 en orden ascendente de criticidad. Su columna de peso es generada y almacenada: el motor la calcula como el identificador del nivel dividido por cuatro, lo que produce los valores 0,25, 0,50, 0,75 y 1,00. Esa columna es la fuente del componente de criticidad del Índice de Riesgo Compuesto (IRC) definido en la sección 3.6, que el resto de este capítulo llama simplemente el índice, y el flujo la lee ya calculada.

Inventario. Cada activo registra su nombre de equipo, un alias descriptivo, su identificador de plataforma, su nivel de criticidad y su estado de exposición. La criticidad se almacena como clave foránea hacia la tabla de referencia, lo que impide registrar un nivel inexistente y permite recuperar el peso normalizado con una sola operación de reunión. La exposición es booleana y no admite nulos. El identificador de plataforma tampoco, y se almacena con los once atributos del estándar, que con el prefijo `cpe:2.3` suman trece campos. La tabla lleva un índice sobre esa columna; la consulta que ejecuta el flujo recupera las treinta filas y no lo emplea.

Telemetría. Es la tabla central del trabajo. Registra un par vulnerabilidad-activo por fila, y una restricción de unicidad sobre esas dos columnas es la que hace del par la unidad de registro: la misma vulnerabilidad sobre dos activos ocupa dos filas, y la misma vulnerabilidad sobre el mismo activo no puede duplicarse. Sus columnas se agrupan en siete conjuntos:

- **Identificación del par:** el identificador de la vulnerabilidad (CVE) y la clave foránea hacia el activo.

- **Variables del modelo:** el puntaje de severidad (CVSS), la probabilidad estimada de explotación (EPSS), la pertenencia al catálogo de explotación conocida (KEV), el índice calculado y la categoría de prioridad asignada. Junto a ellas se registra el punto de decisión sobre explotación que publica CISA, que se persiste sin entrar en el cálculo.
- **Marcas temporales:** la fecha de publicación en la fuente, el momento de ingesta, el momento en que se cerró el procesamiento del par, la fecha de última modificación que la fuente declaraba, la marca que registra la intervención del analista y la que deja la reevaluación diferida al actualizar la fila.
- **Estado del hallazgo:** una columna con seis valores admitidos, que comienza en «detectada» y recorre las transiciones descritas en la sección 2.5, junto al identificador del mensaje enviado cuando el par derivó en notificación. Uno de sus valores, «informativa», coincide con el nombre de una de las categorías de prioridad y designa algo distinto: la prioridad clasifica el hallazgo, el estado registra qué hizo el sistema con él.
- **Procedencia de la correlación:** la vía por la que se estableció, el nivel de confianza que le corresponde y tres columnas que registran la confirmación formal posterior de una correlación establecida por inferencia.
- **Datos descriptivos:** la descripción publicada por la fuente y los enlaces al registro de la vulnerabilidad y a su probabilidad estimada de explotación.
- **Valores de cierre:** seis columnas que la reevaluación diferida escribe con la información madura, sin sobrescribir ninguna de las variables registradas en la detección. La única columna original que ese flujo modifica es la marca temporal que deja constancia de su propio paso.

La definición completa de la tabla, columna por columna, se incluye en el Capítulo 9.

Las restricciones de dominio acotan cada columna al rango que le corresponde: el puntaje de severidad entre 0 y 10, la probabilidad de explotación y el índice entre 0 y 1, y las columnas categóricas a su lista de valores admitidos. La prioridad admite tres valores, la vía de correlación cuatro, el nivel de confianza dos y el estado seis. La columna que registra la confirmación formal posterior admite las tres vías formales y excluye la de inferencia, de modo que no puede registrar como confirmación la misma vía que se confirma.

Dos decisiones de precisión condicionan lo que la tabla distingue. La probabilidad estimada de explotación se almacena con cuatro decimales, de modo que un valor real inferior a 0,00005 queda registrado como cero; la sección 3.8 fija cómo se trata esa ambigüedad. El índice se almacena con la misma precisión con que se calcula, cuatro decimales, y la comparación contra el umbral opera sobre el valor ya redondeado.

Auditoría. Registra acciones sobre el sistema con una estructura genérica: tipo de acción, tipo de entidad afectada, identificador de esa entidad, marca temporal y un documento JSON con los datos del caso. El flujo diario escribe en ella una fila por corrida, cuyo tipo de acción es la ingesta de la ventana y cuya entidad es la ejecución, identificada con el número que le asigna el orquestador. El documento JSON de esa fila registra cuántas vulnerabilidades declaró la ventana, cuántas se

recibieron efectivamente, cuántas páginas llegaron, si la respuesta quedó truncada, cuántas vulnerabilidades distintas correlacionaron, cuántos pares se produjeron, cuántas correlacionaron por cada vía y la lista ordenada de sus identificadores.

Los conteos por vía y el conteo total se calculan de manera independiente. Cada vía mantiene su propio conjunto de identificadores distintos y el total mantiene el conjunto de todos ellos, de modo que una vulnerabilidad que alcance activos por las dos vías figura en los dos conteos parciales y una sola vez en el total. La suma de los conteos por vía puede por lo tanto superar al total, y solo coincide con él en las corridas sin solapamiento. En la recolección todas lo fueron: en las veintiocho corridas la suma de los conteos por vía iguala al total, de modo que sumarlos no cuenta ninguna vulnerabilidad dos veces.

Serie diaria de probabilidad de explotación. Registra la probabilidad estimada y su percentil, un valor por vulnerabilidad y por fecha, con una restricción de unicidad sobre ese par que impide duplicar una fecha ya capturada. Almacena el valor con cinco decimales, uno más que la tabla de telemetría: conserva así la precisión completa de la fuente, mientras que la columna de campaña conserva la comparabilidad con el valor registrado en la detección.

4.3 El inventario de activos simulados

La tabla siguiente presenta los treinta activos del entorno simulado con la asignación individual de atributos que la sección 3.4 fundamenta.

Tabla 5

Inventario de activos del entorno simulado

Nombre de equipo	Alias	Identificador de plataforma	Criticidad	Expuesto
`srv-db-main`	PostgreSQL 16 - Base de Datos Principal	`cpe:2.3:a:postgresql:postgresql:16.0:*:*:*:*:*:*:*`	Crítica	No
`srv-erp-core`	Servidor ERP Core (Crown Jewel)	`cpe:2.3:o:canonical:ubuntu_linux:22.04:*:*:*:lts:*:*:*`	Crítica	No
`fw-edge-01`	Firewall Perimetral - Edge 01	`cpe:2.3:o:cisco:ios:15.4:*:*:*:*:*:*:*`	Crítica	Sí
`srv-web-prod1`	Servidor Web Producción 1	`cpe:2.3:a:apache:http_server:2.4.50:*:*:*:*:*:*:*`	Alta	Sí
`srv-web-prod2`	Servidor Web Producción 2	`cpe:2.3:a:apache:http_server:2.4.50:*:*:*:*:*:*:*`	Alta	Sí
`srv-ad-01`	Active Directory - Controlador Dominio 01	`cpe:2.3:o:microsoft:windows_server_2022:-:*:*:*:*:*:*:*`	Alta	No
`srv-ad-02`	Active Directory - Controlador Dominio 02	`cpe:2.3:o:microsoft:windows_server_2022:-:*:*:*:*:*:*:*`	Alta	No
`srv-n8n-worker`	Servidor n8n - Workflow Automation	`cpe:2.3:a:nodejs:node.js:18.0.0:*:*:*:*:*:*:*`	Alta	No
`srv-db-replica`	PostgreSQL - Réplica Base de Datos	`cpe:2.3:a:postgresql:postgresql:16.0:*:*:*:*:*:*:*`	Alta	No

Nombre de equipo	Alias	Identificador de plataforma	Criticidad	Expuesto
srv-vpn-gw	VPN Gateway - Acceso Remoto	cpe:2.3:a:openvpn:openvpn:2.5.4:*:*:*:*:*:*:*	Media	Sí
srv-mail-relay	Servidor Relay de Correo	cpe:2.3:a:exim:exim:4.95:*:*:*:*:*:*:*	Media	Sí
ws-dev-01	Estación Desarrollo 01	cpe:2.3:o:canonical:ubuntu_linux:22.04:*:*:*:lts:*:*:*	Media	No
ws-dev-02	Estación Desarrollo 02	cpe:2.3:o:canonical:ubuntu_linux:22.04:*:*:*:lts:*:*:*	Media	No
ws-dev-03	Estación Desarrollo 03	cpe:2.3:o:microsoft:windows_11_22h2:-:*:*:*:*:*:*:*	Media	No
srv-ci-cd	Servidor CI/CD - Integración Continua	cpe:2.3:a:jenkins:jenkins:2.401:*:*:*:*:*:*:*	Media	No
srv-git-repo	Servidor Git - Repositorio Código Fuente	cpe:2.3:a:gitlab:gitlab:16.0.0:*:*:*:*:*:*:*	Media	No
srv-monitor-01	Servidor Monitoreo - Observabilidad	cpe:2.3:a:zabbix:zabbix:6.0.0:*:*:*:*:*:*:*	Media	No
srv-log-01	Servidor Logs - SIEM Centralizado	cpe:2.3:a:elastic:elasticsearch:8.8.0:*:*:*:*:*:*:*	Media	No
srv-backup-01	Servidor Backup - Respaldo Centralizado	cpe:2.3:o:debian:debian_linux:11.0:*:*:*:*:*:*:*	Media	No
srv-fs-01	Servidor Archivos (File Server) 01	cpe:2.3:o:microsoft:windows_server_2019:-:*:*:*:*:*:*:*	Media	No
srv-fs-02	Servidor Archivos (File Server) 02	cpe:2.3:o:microsoft:windows_server_2019:-:*:*:*:*:*:*:*	Media	No
srv-wiki-pub	Wiki Pública - Documentación	cpe:2.3:a:atlassian:confluence:8.2.0:*:*:*:*:*:*:*	Baja	Sí
ws-hr-01	Estación RRHH 01	cpe:2.3:o:microsoft:windows_10_22h2:-:*:*:*:*:*:*:*	Baja	No
ws-hr-02	Estación RRHH 02	cpe:2.3:o:microsoft:windows_10_22h2:-:*:*:*:*:*:*:*	Baja	No
ws-finance-01	Estación Finanzas 01	cpe:2.3:o:microsoft:windows_10_22h2:-:*:*:*:*:*:*:*	Baja	No
ws-finance-02	Estación Finanzas 02	cpe:2.3:o:microsoft:windows_10_22h2:-:*:*:*:*:*:*:*	Baja	No
ws-mkt-01	Estación Marketing 01	cpe:2.3:o:apple:macos:13.0:*:*:*:*:*:*:*	Baja	No
ws-mkt-02	Estación Marketing 02	cpe:2.3:o:apple:macos:13.0:*:*:*:*:*:*:*	Baja	No
srv-print-01	Servidor Impresión - Print Server	cpe:2.3:o:microsoft:windows_server_2016:-:*:*:*:*:*:*:*	Baja	No
srv-test-01	Servidor Testing - QA	cpe:2.3:o:canonical:ubuntu_linux:20.04:*:*:*:lts:*:*:*	Baja	No

Nota. Inventario completo del entorno simulado, en el orden en que reside en la base de datos. El alias es la etiqueta descriptiva que emplea la capa de presentación y no participa de ninguna operación del flujo. El identificador de plataforma es el CPE definido en la sección 2.3, y se transcribe con sus trece campos, incluidos los comodines. La columna «Expuesto» corresponde al atributo de exposición a Internet definido en la sección 3.5. Fuente: bloque de población del inventario en `init-db.sql`, contrastado fila por fila contra el export de la tabla `activos` de la base en operación.

La distribución de criticidad es de tres activos críticos, seis altos, doce medios y nueve bajos, y la de exposición de seis activos publicados contra veinticuatro internos, conforme a los criterios de la sección 3.4. Los activos se reparten en doce aplicaciones y dieciocho sistemas operativos, según el componente del identificador que declara el tipo de plataforma.

Los treinta activos declaran veinte identificadores de plataforma distintos: trece corresponden a un único activo y siete se repiten en más de uno, cubriendo entre ellos diecisiete activos. El grupo más numeroso lo forman las cuatro estaciones de trabajo que declaran la misma versión de Windows 10, seguido por las tres instalaciones de Ubuntu 22.04. Esa repetición tiene un efecto directo sobre el volumen de salida: como la correspondencia se resuelve activo por activo, una vulnerabilidad que alcance una plataforma compartida produce tantos pares como activos la declaren, y tantas notificaciones como pares superen el umbral.

4.4 El criterio de correlación

La correspondencia entre una vulnerabilidad y un activo se resuelve dentro del artefacto, sobre el conjunto completo de vulnerabilidades ingeridas en la ventana y contra los treinta activos leídos al comienzo de la corrida. Es la etapa que la sección 3.10 identifica como correlación local, y se implementa en un único nodo de código.

Antes de comparar, el nodo extrae de cada registro las variables que la sección 3.5 operacionaliza —el puntaje de severidad y la pertenencia al catálogo de explotación conocida— junto con el punto de decisión sobre explotación, la descripción y las fechas de publicación y de última modificación. En esa misma etapa estampa la marca de ingesta, una sola para toda la corrida, fijada al comenzar el recorrido, que todos los pares que produzca llevarán idéntica.

La comparación opera sobre dos conjuntos construidos a partir de cada registro. El primero reúne los identificadores de plataforma que el NIST declara en el bloque de configuraciones. El segundo reúne los pares de nombres de fabricante y producto que la respuesta transporta en su bloque de producto afectado: son nombres en texto llano y no el identificador de plataforma que declara la CNA, que la respuesta no expone, según indica la sección 3.10. Contra el primero se prueba la vía formal; contra el segundo, la de inferencia.

```
para cada activo del inventario:
    (fabricante, producto, version) <-
        descomponer su identificador de plataforma
    claves[activo] <- clave(fabricante, producto),
                      clave(fabricante, producto, version)
    fabricante_n[activo] <- normalizar(fabricante)
    producto_n[activo]   <- normalizar(producto)
```

```
para cada vulnerabilidad de la ventana:

    claves_formales <- vacio
    para cada identificador declarado en el bloque de configuraciones:
        agregar a claves_formales:
            clave(fabricante, producto)
            clave(fabricante, producto, version)

    nombres <- pares (normalizar(fabricante), normalizar(producto))
               que el registro declara en texto

    para cada activo del inventario:

        si alguna de las claves del activo figura en claves_formales:
            registrar el par, via formal, confianza formal
            pasar al activo siguiente

        fab  <- fabricante_n[activo]
        prod <- producto_n[activo]
        para cada (f, p) en nombres:
            si longitud(f) < 4 o longitud(p) < 3:
                pasar al par de nombres siguiente
            si (fab contiene f o f contiene fab)
               y (prod contiene p o p contiene prod):
                registrar el par, via y confianza inferidas
                pasar al activo siguiente

        descartar: el par no se registra ni deja constancia individual

donde
    clave(terminos): concatenar los terminos, pasarlos a
        minusculas, separarlos en palabras por guion bajo,
        guion, punto y espacio, descartar las vacias y los
        comodines, ordenarlas alfabeticamente y unirlas
    normalizar(t): pasar a minusculas y suprimir todo
        caracter que no sea letra o digito
```

Figura 2. Criterio de correlación entre una vulnerabilidad y un activo del inventario, en pseudocódigo. Elaboración propia a partir del nodo de correlación del flujo publicado en n8n, cuya exportación se incluye en el Capítulo 9.

Tres propiedades del criterio se siguen de esa definición y condicionan lo que el trabajo afirma sobre la cobertura.

La primera es que la vía formal no compara identificadores completos, sino conjuntos de palabras, y construye dos por cada identificador: uno con fabricante y producto, otro que agrega la versión. Las dos son necesarias porque la fuente declara la versión de dos maneras: como valor literal, cuando el aviso afecta a una versión puntual, y como comodín, cuando delimita un rango mediante campos separados. El comodín no sobrevive a la normalización, de modo que en ese caso las dos claves del registro coinciden entre sí y la correspondencia se resuelve por fabricante y producto. Ninguna de las dos evalúa el rango declarado, y de ahí que un activo correlacione con una vulnerabilidad que declare su mismo fabricante y producto aunque la versión instalada no esté comprendida en él. Tampoco lee la marca con que el NIST separa el producto que tiene la falla del sistema operativo sobre el que ese producto corre: los dos entran al conjunto, de modo que un activo cuyo producto

es ese sistema operativo correlaciona con una falla que no lo afecta. Es la resolución simplificada del árbol de condiciones que la sección 3.4 declara, y la muestra de validación descrita en la sección 3.12 incluye pares de esta vía para medir su efecto.

La segunda es que las palabras se ordenan alfabéticamente antes de compararse, de modo que la correspondencia no depende del orden en que la fuente las declare.

La tercera es que el resguardo de longitud se aplica sobre los nombres que declara el registro, no sobre los del inventario. Un nombre de fabricante de menos de cuatro caracteres, o de producto de menos de tres, no se compara con ningún activo, lo que descarta las cadenas breves capaces de quedar contenidas en cualquier nombre. Los valores del umbral son los que admite el inventario vigente, según fundamenta la sección 3.10.

El nodo etiqueta cada par con la vía por la que se resolvió y con su nivel de confianza. Emite dos de las cuatro vías que el esquema admite: la que corresponde al identificador publicado por el NIST y la de inferencia. Las otras dos quedan disponibles en el dominio de la columna y sin escritura durante la recolección, conforme a lo expuesto en la sección 3.10.

4.5 Los puntos de decisión del flujo

El flujo diario se compone de diecisiete nodos, distribuidos sobre las seis etapas que describe la sección 3.10.

Tabla 6

Nodos del flujo diario por etapa

Etapa	Nodos	Qué ejecutan
Lectura del inventario	2	Disparo programado y consulta de los treinta activos con su exposición y su peso de criticidad
Ingesta de la ventana	1	Consulta paginada a la interfaz de la NVD
Registro de la corrida	2	Cómputo de los conteos de la corrida y escritura de la fila de auditoría
Correlación local	1	Criterio de la sección 4.4
Enriquecimiento y cálculo	3	Consulta a la interfaz de FIRST, reunión con el par de origen y cálculo del índice
Persistencia y triaje	8	Consulta de existencia, escritura del par, registro de promoción, evaluación del umbral, envío del correo y registro del estado

Nota. Distribución de los diecisiete nodos del flujo diario sobre las seis etapas definidas en la sección 3.10. La descripción funcional de cada etapa está en esa sección; esta tabla indica cuántos nodos la implementan. Fuente: exportación del flujo, incluida en el Capítulo 9.

La consulta a la fuente se emite una sola vez por corrida, aunque el nodo reciba las treinta filas del inventario, porque está configurada para ejecutarse una única vez con independencia del número de elementos que la alcanzan. Pide las vulnerabilidades publicadas dentro de la ventana, con dos mil registros por respuesta, y recorre hasta cinco páginas separadas por seis segundos, con reintento automático y cinco segundos de espera entre intentos. La consulta a la interfaz de FIRST se emite

una vez por par, de a un elemento y con un intervalo mínimo de ciento veinte milisegundos entre peticiones.

La rama de auditoría se desprende de la salida de la ingesta, la misma que recibe la etapa de correlación, de modo que se ejecuta en toda corrida, haya o no correspondencias. El orquestador recorre las ramas de a una, y esta corre recién cuando la de correlación terminó con todos sus pares; si aquella se interrumpe, la fila no se escribe hasta que la corrida se completa, como ocurrió el 3 de septiembre (sección 5.5). Lee el resultado de la correlación para componer sus conteos y tolera su ausencia registrando ceros, con lo cual una corrida sin correspondencias deja igualmente su fila.

El flujo decide en cuatro puntos. Los demás nodos transportan, transforman o escriben.

La correlación decide si cada par existe y por cuál vía, conforme al criterio de la sección 4.4. Es la única decisión del flujo que descarta material sin dejar constancia individual: de las vulnerabilidades que no alcanzan a ningún activo queda el conteo en la fila de auditoría y no la lista de sus identificadores.

La consulta de existencia decide si el par ya está registrado. Un nodo cuenta las filas de la tabla de telemetría que coinciden en vulnerabilidad y activo, y un nodo condicional evalúa si ese conteo es cero. Cuando lo es, el par es nuevo y se escribe con todas sus variables; cuando no lo es, el par se deriva a la rama de registro de promoción. El nodo de conteo está configurado para emitir siempre un elemento y para continuar ante un error, de modo que una falla de esa consulta no interrumpe la corrida.

El triaje decide si el hallazgo se notifica. Evalúa una sola condición sobre el índice ya calculado y redondeado: si alcanza o supera 0,40, el par deriva al envío del correo y su estado pasa a notificada, registrando además la marca de cierre del procesamiento y el identificador que devuelve el servicio de correo; si no lo alcanza, el estado pasa a informativa y se registra la misma marca de cierre. Las dos ramas escriben, de modo que todo par nuevo queda con su procesamiento cerrado.

El mensaje tiene la estructura y el destinatario que describe la sección 3.11.

El registro de promoción decide si corresponde anotar que una correlación establecida por inferencia recibió confirmación formal. La operación actualiza la fila solo cuando se cumplen cuatro condiciones a la vez: que la fila corresponda a ese par, que su vía registrada sea la de inferencia, que la vía con que se acaba de detectar no lo sea, y que no exista ya una confirmación anotada. Cuando actualiza, escribe la vía que confirmó, la fecha de última modificación que la fuente declaraba en ese momento y la marca del instante en que se advirtió, sin modificar la columna de procedencia original. Esa columna conserva por lo tanto el significado de vía de detección inicial.

Capítulo 5: Resultados

Este capítulo responde las cinco preguntas secundarias de la sección 1.3, una por sección y en el mismo orden. En el camino contrasta las tres hipótesis de la sección 1.8. La sección 5.6 agrega la evaluación del tramo de notificación, que ninguna pregunta aborda por separado.

Cada hipótesis cierra con uno de tres veredictos: la evidencia la sostiene, no la sostiene o no permite contrastarla. El veredicto se acompaña de la cifra que lo funda y del límite que lo condiciona. No se aplican pruebas de significación, porque el trabajo es un estudio de caso, según declara la sección 3.3: las cifras describen lo que ocurrió en este artefacto y con este inventario durante la campaña.

Salvo indicación en contrario, las cifras corresponden a la campaña de recolección y siguen los criterios de cómputo de la sección 3.8. El diagnóstico de mayo a julio, descrito en el Anexo A, se cita solo como antecedente, y sus cifras no se comparan con las de la campaña.

5.1 Cobertura de correlación: qué vulnerabilidades alcanzó el artefacto y cuáles se le escaparon

Esta sección mide qué parte de las vulnerabilidades de la campaña correlacionó el artefacto con el inventario, con qué respaldo de la NVD, y cuáles se le escaparon. Varias de esas medidas dependen de una distinción que la NVD hace en la configuración de cada vulnerabilidad. Un producto figura como afectado cuando es el que tiene la vulnerabilidad, y como plataforma cuando es el sistema sobre el que se ejecuta el producto afectado. Una falla de un navegador, por ejemplo, puede declarar el navegador como afectado y macOS como plataforma: macOS no es vulnerable, pero aparece en la configuración. La regla del artefacto no distingue los dos papeles y correlaciona con ambos.

Criterio de esta sección. Una correlación tiene respaldo formal solo cuando la NVD declara afectado el producto del activo. Un activo que figura solo como plataforma no queda expuesto por esa vulnerabilidad, y su correlación cuenta como sin respaldo. Las tablas que dependen de esta distinción muestran también la cifra con la regla del artefacto, para que la diferencia quede a la vista.

5.1.1 Cuántas de las vulnerabilidades ingeridas correlacionaron con el inventario

Durante la campaña, el flujo ingirió 14.456 vulnerabilidades distintas. De ellas, 1.018 correlacionaron con al menos un activo del inventario: el 7,0 %. Esas 1.018 vulnerabilidades son el conjunto sobre el que se mide la cobertura en el resto de esta sección.

Tabla 7

Recorrido de las vulnerabilidades ingeridas durante la campaña

Paso	Vulnerabilidades	% sobre las ingeridas
Ingeridas por el flujo durante la campaña	14.456	100,0
Retiradas por quien las publicó, al momento de la ingesta	131	0,9
Retiradas por quien las publicó, al 30 de septiembre	142	1,0
Correlacionadas con al menos un activo del inventario	1.018	7,0
Correlacionadas que figuran como retiradas al cierre	0	0,0

Nota. Recorrido de las vulnerabilidades ingeridas durante la campaña de recolección. Las vulnerabilidades se cuentan como identificadores distintos. El estado de retirada al momento de la ingesta proviene del historial de ejecuciones del orquestador; el del 30 de septiembre, de la reconsulta a la NVD de esa fecha; el del cierre, de la consulta del 3 de octubre de 2026. Fuente: historial de ejecuciones del orquestador, tabla de auditoría y consultas a la NVD descritas en la sección 3.7.

Parte de las vulnerabilidades ingeridas fueron retiradas por quien las publicó. Una vulnerabilidad retirada no trae fabricante ni producto, de modo que no puede correlacionar con ningún activo, según establece la sección 3.8. Al momento de la ingesta estaban retiradas 131; al 30 de septiembre, 142. Ninguna de las 1.018 correlacionadas figura como retirada al cierre, de modo que las retiradas no alteran ninguna cifra de cobertura.

5.1.2 Cuántas de las correlaciones tenían respaldo de la NVD al detectar y al cierre

Una correlación tiene respaldo formal cuando la NVD publicó, para esa vulnerabilidad, una configuración que declara afectado el producto del activo. Sin ese respaldo, la correlación la estableció la vía de inferencia, o la vía formal sobre un activo que figura solo como plataforma. Este apartado mide qué parte de las 1.018 vulnerabilidades correlacionadas tenía respaldo formal en dos momentos. El primero es la detección: el período en que la vulnerabilidad estuvo dentro de la ventana de tres días que revisa el flujo. El segundo es el cierre: la consulta a la NVD del 3 de octubre de 2026. La medida se da por vulnerabilidad y por par vulnerabilidad-activo. Una vulnerabilidad que alcanza a cinco activos cuenta una vez como vulnerabilidad y cinco veces como par.

Tabla 8

Correlaciones con y sin respaldo formal de la NVD, al detectar y al cierre

Momento y respaldo	Regla del artefacto: vulnerabilidades	Regla del artefacto: pares	Solo producto afectado: vulnerabilidades	Solo producto afectado: pares
Correlacionadas por el artefacto	1.018 (100,0 %)	3.848 (100,0 %)	1.018 (100,0 %)	3.848 (100,0 %)
Al detectar: con respaldo formal	181 (17,8 %)	656 (17,0 %)	140 (13,8 %)	574 (14,9 %)
Al detectar: sin respaldo formal	837 (82,2 %)	3.192 (83,0 %)	878 (86,2 %)	3.274 (85,1 %)
Al cierre: con respaldo formal	955 (93,8 %)	3.780 (98,2 %)	914 (89,8 %)	3.698 (96,1 %)
Al cierre: sin respaldo formal	63 (6,2 %)	68 (1,8 %)	104 (10,2 %)	150 (3,9 %)

Nota. Correlaciones establecidas por el artefacto durante la campaña, según tuvieran o no respaldo formal de la NVD en cada momento. Con la regla del artefacto, una correlación tiene respaldo cuando la configuración nombra el producto del activo en cualquier papel; contando solo el producto afectado, cuando lo declara afectado. «Al detectar» comprende todas las corridas en que la vulnerabilidad estuvo dentro de la ventana del flujo; «al cierre» corresponde a la consulta del 3 de octubre de 2026. Fuente: tabla de telemetría, tabla de auditoría, historial de ejecuciones del orquestador y consulta de cierre a la NVD.

Al detectar, la NVD respaldaba 140 de las 1.018 vulnerabilidades (13,8 %). Las 878 restantes (86,2 %) no tenían respaldo formal, y casi todas las correlacionó la vía de inferencia. Por par, la proporción es parecida: 574 pares con respaldo y 3.274 sin él.

Al cierre, la situación se invierte. La NVD respalda 914 de las 1.018 vulnerabilidades (89,8 %), y 104 (10,2 %) siguen sin respaldo. Por par, quedan sin respaldo 150 de 3.848 (3,9 %). La sección 5.2 examina esos 150 pares, porque una correlación sin respaldo puede ser correcta o puede ser un falso positivo.

Las dos reglas difieren en 82 pares, de 41 vulnerabilidades, en los dos momentos. Son vulnerabilidades de programas que se ejecutan sobre macOS, en las que la NVD declara a macOS solo como plataforma. La vía formal las correlacionó con las dos estaciones que corren ese sistema; con el criterio de esta sección, esos pares no tienen respaldo.

El artefacto no registró la cifra al detectar: se calculó después, a partir del historial de ejecuciones del orquestador, que conserva lo que la NVD devolvió en cada corrida. El cálculo coincide con lo que registra la base. Con la regla del artefacto, los 656 pares con respaldo al detectar son los 439 que el artefacto registró por la vía formal más los 217 que registró por inferencia y vio confirmados por la vía formal en una corrida posterior.

5.1.3 Qué vulnerabilidades se le escaparon al artefacto

El apartado anterior partió de lo que el artefacto correlacionó. Este recorre el camino inverso: toma todo lo que la NVD vincula con el inventario en la consulta de cierre y mide qué parte detectó el artefacto. Como en el apartado anterior, la tabla da las dos medidas.

Tabla 9

Cobertura del artefacto frente a lo que la NVD vincula con el inventario

Medida	Regla del artefacto	Solo producto afectado
Vulnerabilidades que la NVD vincula con algún activo	1.009	924
Detectadas por el artefacto	955 (94,6 %)	914 (98,9 %)
No detectadas	54	10
Pares que la NVD vincula	5.998	5.810
Detectados por el artefacto	3.780 (63,0 %)	3.698 (63,6 %)
No detectados	2.218	2.112

Nota. Cobertura del artefacto respecto de lo que la NVD vincula con el inventario en la consulta del 3 de octubre de 2026. La regla del artefacto cuenta un producto tanto si la NVD lo declara afectado como si lo declara plataforma; la segunda columna cuenta solo los declarados afectados. Se consideran las vulnerabilidades publicadas hasta la última corrida de la campaña. Fuente: consulta de cierre a la NVD, tabla de telemetría y tabla de auditoría.

Por vulnerabilidad, el artefacto detectó casi todo: 914 de 924 (98,9 %), y 955 de 1.009 con su propia regla (94,6 %). Por par, la cobertura cae a cerca de dos tercios: 63,6 % y 63,0 %. La tabla siguiente muestra sobre qué activos recaen los pares no detectados, con las dos medidas.

Tabla 10

Pares no detectados por el artefacto, por activo

Activo	Regla del artefacto	Solo producto afectado
ws-hr-01 (Windows 10)	532	528
ws-hr-02 (Windows 10)	532	528
ws-finance-01 (Windows 10)	532	528
ws-finance-02 (Windows 10)	532	528
ws-mkt-01 (macOS)	40	0
ws-mkt-02 (macOS)	40	0
srv-ad-01, srv-ad-02, srv-fs-01, srv-fs-02 y ws-dev-03 (2 cada uno)	10	0
Resto de los activos (19)	0	0
Total	2.218	2.112

Nota. Pares vulnerabilidad-activo que la NVD vincula con el inventario en la consulta del 3 de octubre de 2026 y que el artefacto no detectó, por activo. La regla del artefacto cuenta un producto tanto si la NVD lo declara afectado como si lo declara plataforma; la tercera columna cuenta solo los declarados afectados. Fuente: consulta de cierre a la NVD y tabla de telemetría.

Las dos medidas difieren en 106 pares, y ninguno es una pérdida real. En todos ellos, el producto del activo figura en la configuración solo como plataforma. El inventario registra para esos activos

solo el sistema operativo, de modo que nada indica que tengan instalado el programa afectado. Si el artefacto los hubiera detectado, habría notificado una vulnerabilidad que no expone al activo, es decir, un falso positivo.

Con el criterio de esta sección, los 2.112 pares no detectados recaen todos sobre las cuatro estaciones con Windows 10, 528 en cada una. Fuera de ellas, el artefacto detectó todos los pares que la NVD vincula. La vía de inferencia no reconoce la denominación que Microsoft usa para las versiones de Windows 10, como anticipa la sección 1.7. Además, ninguna de esas 528 vulnerabilidades tenía configuración formal mientras estuvo dentro de la ventana del flujo. Ninguna de las dos vías podía correlacionarlas con esas estaciones.

La medida por vulnerabilidad casi no registra esa pérdida. De las 528 vulnerabilidades, 518 se detectaron sobre otro activo, como los servidores Windows, y por eso cuentan como detectadas. Solo 10 no se detectaron sobre ningún activo, y son fallas del propio Windows 10. Por eso la cobertura se informa en las dos unidades.

5.1.4 En qué activos se concentran las correlaciones

Las 3.848 correlaciones de la campaña no se reparten de forma pareja entre los treinta activos. Diecinueve activos registraron al menos un par y once no registraron ninguno. La tabla siguiente muestra, para cada activo, cuántos pares registró y cuántos tenían respaldo formal al detectar y al cierre, con el criterio de esta sección.

Tabla 11

Pares registrados por activo, con y sin respaldo formal

Activo	Producto en el inventario	Pares	Al detectar: con respaldo	Al detectar: sin respaldo	Al cierre: con respaldo	Al cierre: sin respaldo
srv-ad-01	Windows Server 2022	640	51	589	639	1
srv-ad-02	Windows Server 2022	640	51	589	639	1
srv-fs-01	Windows Server 2019	615	50	565	614	1
srv-fs-02	Windows Server 2019	615	50	565	614	1
srv-print-01	Windows Server 2016	553	46	507	552	1
ws-mkt-01	macOS 13.0	263	83	180	221	42
ws-mkt-02	macOS 13.0	263	83	180	221	42
srv-ci-cd	Jenkins 2.401	53	0	53	10	43
ws-hr-01	Windows 10 22H2	39	39	0	39	0
ws-hr-02	Windows 10 22H2	39	39	0	39	0
ws-finance-01	Windows 10 22H2	39	39	0	39	0
ws-finance-02	Windows 10 22H2	39	39	0	39	0
srv-git-repo	GitLab 16.0.0	24	1	23	24	0

Activo	Producto en el inventario	Pares	Al detectar: con respaldo	Al detectar: sin respaldo	Al cierre: con respaldo	Al cierre: sin respaldo
srv-vpn-gw	OpenVPN 2.5.4	8	0	8	0	8
fw-edge-01	Cisco IOS 15.4	7	0	7	0	7
srv-mail-relay	Exim 4.95	4	0	4	4	0
srv-log-01	Elasticsearch 8.8.0	4	3	1	4	0
srv-wiki-pub	Confluence 8.2.0	2	0	2	0	2
srv-n8n--worker	Node.js 18.0.0	1	0	1	0	1
Activos sin pares (11)	—	0	0	0	0	0
Total		3.848	574	3.274	3.698	150

Nota. Pares vulnerabilidad-activo registrados por el artefacto durante la campaña, por activo, según tuvieran respaldo formal de la NVD al detectar y al cierre. Un par tiene respaldo cuando la NVD declara afectado el producto del activo. «Al detectar» comprende todas las corridas en que la vulnerabilidad estuvo dentro de la ventana del flujo; «al cierre» corresponde a la consulta del 3 de octubre de 2026. Fuente: tabla de telemetría, historial de ejecuciones del orquestador y consulta de cierre a la NVD.

Cinco servidores Windows concentran 3.063 de los 3.848 pares (79,6 %): los dos controladores de dominio, los dos servidores de archivos y el servidor de impresión. Sobre esos mismos cinco recae también la mayor parte de lo que no tenía respaldo al detectar: 2.815 de 3.274 pares (86,0 %). Al cierre, la NVD respalda todos sus pares salvo uno en cada servidor.

Las cuatro estaciones con Windows 10 son el caso contrario. Todos sus pares tenían respaldo desde la detección, porque la inferencia no reconoce la denominación de su sistema operativo y solo la vía formal pudo correlacionarlas, como mostró el apartado anterior.

Los 150 pares que siguen sin respaldo al cierre se reparten entre pocos activos: 84 en las dos estaciones con macOS, 43 en el servidor de integración continua, 8 en la pasarela VPN, 7 en el firewall, 2 en la wiki pública, 1 en el nodo del orquestador y 5 en los servidores Windows. La sección 5.2 los examina.

Los once activos sin pares corren PostgreSQL, Apache, Ubuntu, Debian, Zabbix y Windows 11. Que un activo no registre pares significa que ni el artefacto ni la NVD lo vincularon con ninguna vulnerabilidad de la campaña. La única excepción es ws-dev-03, con dos pares que la NVD vincula solo como plataforma.

El diagnóstico previo descrito en el Anexo A ya anticipaba esta desigualdad: solo seis de los veinte productos del inventario reciben de su propio fabricante el identificador de plataforma. Las cifras de cobertura de esta sección describen, por lo tanto, sobre todo lo ocurrido con productos de Microsoft.

5.1.5 Qué habrían aportado la CNA y CISA

La pregunta de cobertura contempla dos vías más, que el artefacto no consulta. La CNA es la organización que publica el registro de la vulnerabilidad, a menudo el propio fabricante, y puede

declarar en él los productos afectados. CISA es la agencia de ciberseguridad de los Estados Unidos, que agrega datos propios a los registros. Las dos se midieron por fuera del artefacto, sobre los registros ingeridos y al cierre de la campaña, según establece la sección 1.7. Se aplica el mismo criterio que en el resto de la sección: cuenta solo el producto declarado afectado.

Tabla 12

Vulnerabilidades y pares que habrían vinculado la CNA y CISA

Vía	Vulnerabilidades que vincula con el inventario	Pares que vincula	Pares que la NVD no vincula al cierre
CNA	690	5.368	14
CISA	0	0	0

Nota. Vulnerabilidades y pares vulnerabilidad-activo que cada vía habría vinculado con el inventario, medidos sobre los registros de las 14.456 vulnerabilidades ingeridas durante la campaña. La última columna cuenta los pares de cada vía que la NVD no declara afectados en la consulta del 3 de octubre de 2026. Fuente: registros del repositorio público de vulnerabilidades al cierre y consulta de cierre a la NVD.

Al cierre, la vía de la CNA agrega poco a la de la NVD. De sus 5.368 pares, 5.354 figuran también entre los que la NVD declara afectados, y 14 quedan fuera. Esos 14 pares corresponden a dos vulnerabilidades de Microsoft publicadas el 8 de septiembre. La NVD todavía no había terminado de analizar la primera al cierre, de modo que no declaraba ningún producto para ella. La segunda quedó fuera porque Microsoft agregó las versiones de Windows Server a su registro después de que el flujo la ingiriera, y la configuración que publicó la NVD no incluye esos servidores.

Frente al artefacto, en cambio, la vía de la CNA sí habría agregado cobertura. De sus 5.368 pares, el artefacto no detectó 2.121. De ellos, 2.112 son exactamente los pares de las cuatro estaciones con Windows 10 que se le escaparon, según mostró el apartado 5.1.3: la CNA declaraba lo que la inferencia no supo reconocer. Los nueve restantes corresponden a las dos vulnerabilidades del párrafo anterior. Cinco son los servidores Windows que Microsoft agregó cuando la vulnerabilidad ya había salido de la ventana del flujo, y cuatro son las estaciones con Windows 10 de la vulnerabilidad todavía en análisis. Como esta vía se midió solo al cierre, el trabajo no establece si su dato ya estaba en el registro cuando el flujo vio cada vulnerabilidad.

La vía de CISA no aportó ningún dato. De los 11.661 bloques que CISA agregó a los registros ingeridos, ninguno declara productos afectados. El cero confirma, sobre los datos de la campaña, que la política que la agencia anunció en diciembre de 2024, descrita en la sección 2.3, se sostuvo durante la ventana observada.

5.1.6 Veredicto sobre la primera hipótesis

La primera hipótesis sostiene que la combinación de vías alcanza una proporción sustantiva de correlaciones que la vía formal no alcanza por sí sola, y que esa proporción es mayor en el momento de la detección que al cierre. La tabla siguiente reúne las dos cifras que la contrastan, tomadas del apartado 5.1.2.

Tabla 13

Correlaciones sin respaldo formal de la NVD, al detectar y al cierre

Momento	Vulnerabilidades sin respaldo formal	Pares sin respaldo formal
Al detectar	878 de 1.018 (86,2 %)	3.274 de 3.848 (85,1 %)
Al cierre	104 de 1.018 (10,2 %)	150 de 3.848 (3,9 %)

Nota. Correlaciones del artefacto que no tenían respaldo formal de la NVD en cada momento, contando solo el producto declarado afectado. «Al detectar» comprende todas las corridas en que la vulnerabilidad estuvo dentro de la ventana del flujo; «al cierre» corresponde a la consulta del 3 de octubre de 2026. Fuente: apartado 5.1.2.

La evidencia sostiene la hipótesis. Al detectar, la vía formal no respaldaba el 86,2 % de las vulnerabilidades que el artefacto correlacionó; al cierre, solo el 10,2 %. Que la proporción bajara entre los dos momentos se seguía casi por construcción, porque el dato formal solo se suma con el tiempo; lo que la campaña aporta es su tamaño. Sin la vía de inferencia, el artefacto habría correlacionado durante la campaña menos de una de cada siete de estas vulnerabilidades.

La misma dependencia del dato formal se puede medir sobre el diseño original. Aplicado a la misma campaña, con sus identificadores corregidos y su ventana de tres días, habría detectado 87 de las 924 vulnerabilidades que la NVD terminó vinculando con el inventario (9,4 %) y 470 de sus 5.810 pares (8,1 %), frente a 914 y 3.698 del artefacto. En 24 de las 28 corridas no habría devuelto nada para ningún activo, sin registrar ningún error. El cálculo cruza la configuración visible en cada corrida con lo que la NVD devolvía el 5 de octubre de 2026 para cada identificador, de modo que el filtro de versión es el de esa fecha y no el de cada corrida.

El veredicto tiene tres límites. El primero es que mide alcance y no exactitud. Que la vía de inferencia establezca una correlación no implica que sea correcta, y la sección 5.2 mide con qué frecuencia no lo es.

El segundo es que la ventaja vale para el momento de la detección y no para el total. Medida por par, la combinación tal como se implementó dejó sin detectar los 2.112 pares de las cuatro estaciones con Windows 10, que la NVD terminó declarando afectados y que la CNA ya declaraba.

El tercero es que el efecto se concentra en cinco servidores de un único fabricante, que reúnen el 86,0 % de los pares sin respaldo al detectar. Su alcance más allá de este inventario se discute en el Capítulo 6 y no se infiere de estas cifras.

5.2 Precisión de la vía de inferencia: cuántas de sus correlaciones eran correctas y qué errores cometió

La sección 5.1 mostró que la vía de inferencia estableció la mayor parte de las correlaciones de la campaña. Esta sección mide cuántas de ellas eran correctas y qué clase de error cometió la vía en las que no lo eran. Al final examina también los errores de la vía formal y los pares que la inferencia no encontró.

Criterio de esta sección. Una correlación es correcta cuando cumple dos condiciones. La primera es que el registro de la vulnerabilidad o el aviso del fabricante declare afectado el producto del activo. La segunda es que la versión que registra el inventario caiga dentro del rango afectado. El criterio evalúa producto y versión, no exposición: no examina si el activo usa la función, corre sobre el sistema operativo o tiene la configuración que la falla requiere, porque el inventario no registra esos datos.

5.2.1 Cómo se eligieron y se revisaron los casos de la vía de inferencia

La vía de inferencia registró 3.424 pares en la base, incluidos 15 del período de estabilización. Para revisarlos, se agruparon en casos. Un caso reúne una vulnerabilidad y un producto del inventario, porque los activos que comparten producto reciben la misma respuesta. Los dos controladores de dominio, por ejemplo, forman un solo caso por cada vulnerabilidad. Los 3.424 pares forman 2.025 casos.

Los siete casos del firewall quedaron fuera del sorteo, porque antes de sortear ya se sabía que eran falsos positivos. Sortearlos habría mezclado casos de resultado conocido con casos por revisar. Se revisaron los siete y entran en la tasa con su tamaño real, 7 de 2.025 casos. El apartado 5.2.3 explica su error.

Los 2.018 casos restantes se sortearon en una muestra de 65, repartida por producto del inventario. Cada producto recibió al menos dos casos, o todos si tenía menos, y el resto se repartió en proporción a su tamaño. Sin ese reparto, la muestra habría quedado compuesta casi solo de casos de Windows Server, que reúnen 1.688 de los 2.018. Como el reparto no es proporcional, cada caso revisado se cuenta en la tasa tantas veces como casos de su producto representa: un caso de Windows Server 2022 representa unos cuarenta, y uno de Confluence, solo a sí mismo. El sorteo usó una semilla fija y quedó registrado antes de revisar el primer caso.

Tabla 14

Casos de la vía de inferencia y muestra revisada, por producto

Producto del inventario	Casos	Pares	Casos revisados
Windows Server 2022	599	1.198	15
Windows Server 2019	575	1.150	15
Windows Server 2016	514	514	13
macOS 13.0	225	450	7
Jenkins 2.401	53	53	3
GitLab 16.0.0	33	33	3
OpenVPN 2.5.4	8	8	2
Cisco IOS 15.4 (fuera del sorteo)	7	7	7
Elasticsearch 8.8.0	4	4	2
Exim 4.95	4	4	2
Confluence 8.2.0	2	2	2
Node.js 18.0.0	1	1	1
Total	2.025	3.424	72

Nota. Pares registrados por la vía de inferencia, agrupados en casos (vulnerabilidad y producto del inventario), y casos revisados por producto. Incluye los 15 pares del período de estabilización. Los siete casos del firewall no se sortearon: se revisaron todos, de modo que cada uno representa solo a sí mismo en la tasa. Las estaciones con Windows 10 no figuran, porque la inferencia no produjo ningún par sobre ellas (apartado 5.1.3). Fuente: tabla de telemetría y registro del sorteo del 4 de octubre de 2026.

Cada caso se contrastó con el registro de la vulnerabilidad tal como lo publicó la CNA y, cuando hacía falta, con el aviso de seguridad del fabricante. Para cada uno se anotó si el producto figuraba como afectado, si la versión del inventario caía dentro del rango y si el nombre coincidió completo o solo en parte. El juicio previo lo hizo el autor, asistido por un modelo de lenguaje: el modelo leyó cada registro y propuso una interpretación, y el autor la revisó y la aprobó o la corrigió caso por caso. Se lanzó un agente adicional para hacer una revisión independiente, sin acceso a los resultados del juicio previo. Juzgó los mismos 65 casos y coincidió en 61 con un veredicto firme; en otros tres, los dos juicios dejaron el caso sin decidir, y solo en uno discreparon. Con esas tres categorías, el acuerdo corregido por azar, medido con el kappa de Cohen, es de 0,94 (Cohen, 1960). En algunos casos el aviso no alcanzaba para decidir. Para esos casos se fijaron por escrito tres reglas de lectura, que se aplicaron a toda la muestra. La tabla siguiente las presenta junto con el caso que dio origen a cada una.

Tabla 15

Reglas de lectura de la revisión de la muestra

Situación	Cómo se juzgó	Caso de la muestra
El aviso lista solo las versiones que el fabricante todavía mantiene, y la del inventario no figura	Afectado, si la falla existe desde una versión anterior	Confluence 8.2.0: el aviso no la lista, pero la falla existe desde la 7.4.0 y la 8.2 nunca se corrigió. Node.js 18.0.0: el registro nombra solo las ramas con soporte y no excluye la 18
El inventario no registra qué actualizaciones tiene instaladas el equipo	Afectado, porque no hay dato que permita excluirlo	Los casos de Windows Server
La falla exige una condición del entorno que el inventario no registra: un sistema operativo o una opción de configuración	No se evalúa: se juzga por producto y versión	OpenVPN 2.5.4: la versión cae en el rango, pero la falla solo existe sobre Windows, y el inventario no registra el sistema del servidor. Exim 4.95: explotable solo con una opción de configuración que el inventario no registra

Nota. Reglas de lectura aplicadas a los 65 casos de la muestra de la vía de inferencia. La primera y la tercera fila resolvieron los cuatro casos en que la revisión propia y la independiente no coincidieron en un veredicto firme: Confluence y Node.js por la primera, y los dos casos de OpenVPN por la tercera. En los casos de OpenVPN, la decisión se aparta de la revisión independiente, que los dejó como dudosos y recomendaba contarlos como error. Se tomó el 11 de octubre, al aplicarles el mismo criterio que a Exim; hasta entonces se contaban como error. Contados así, la tasa sería del 21,8 % en el resto de los productos y del 3,6 % en el total. Fuente: registro de la revisión del 4 de octubre de 2026.

Las dos últimas reglas aceptan el par cuando el producto coincide, la versión no lo contradice y lo que falta es un dato del entorno que el inventario no registra. En Windows la versión no se puede comprobar, porque el inventario no registra el número de actualización instalado: el par se da por correcto porque no hay dato que permita descartarlo. Son limitaciones del inventario y no juicios sobre cada caso: la revisión no puede detectar un par que una actualización ya instalada, otro sistema operativo o una configuración distinta hayan dejado sin efecto.

Las tres reglas resuelven la duda en el mismo sentido: cuando ni el registro ni el aviso permiten establecer que el par es incorrecto, se lo cuenta como correcto. El sesgo es deliberado. En un entorno real, un flujo que descarta una correlación sin un dato que la excluya oculta un caso que debía llegar al analista, mientras que uno que la deja pasar la pone frente a quien puede descartarla. El sesgo alcanza solo a los casos dudosos: todo caso en que el registro o el aviso permitían establecer el error se contó como error. Por eso la tasa que sigue es un piso, y el apartado 5.2.2 mide cuánto sube si las dudas de la primera y la tercera regla se resuelven al revés. La segunda no admite ese cálculo, porque su duda no depende de cómo se lea el aviso, sino del dato que el inventario no registra.

Una tercera revisión, hecha a ciegas por un modelo distinto y sin las reglas de lectura de la Tabla 15, encontró los mismos cinco errores. Sus diferencias con el juicio final recaen solo en los casos dudosos que deciden esas reglas: juzgó error el de Node.js, dejó sin decidir uno de Confluence y los 43 de Windows Server, y coincidió en los dos de OpenVPN. Las dos revisiones de contraste las hicieron modelos, de modo que su independencia respecto del juicio del autor es de procedimiento y no de criterio.

5.2.2 Con qué frecuencia la vía de inferencia correlacionó un activo que no estaba afectado

La revisión no encontró errores de la vía de inferencia donde el nombre coincide exactamente con el del inventario y el rango del fabricante abarca toda la versión instalada, y la vía se equivocó con frecuencia en el resto. En Windows Server, que reúne cinco de cada seis casos, la revisión no encontró ningún error. En el resto de los productos, la vía falló en casi uno de cada cinco casos. Sobre el total, el error es bajo, del 3,2 %, pero esa cifra describe sobre todo lo ocurrido con Windows Server.

La diferencia tiene una explicación directa. En Windows Server, el nombre que publica el fabricante coincide exactamente con el del inventario en los 1.688 casos, aunque la regla solo exige que uno contenga al otro, de modo que la inferencia no tiene nada que decidir. Tampoco puede equivocarse por la versión del modo en que lo hizo con GitLab, donde la versión instalada era anterior a la que introdujo la falla: en Windows Server, el rango afectado que declara Microsoft empieza en la primera compilación de cada versión, de modo que ningún equipo instalado queda por debajo de él. En los demás productos, los nombres no siempre coinciden y la versión del inventario tiene que caer dentro de un rango que la vía no compara. Ahí es donde la inferencia trabaja de verdad, y ahí es donde se equivoca. El apartado siguiente examina esos errores uno por uno.

Tabla 16

Tasa de error de la vía de inferencia

Grupo	Casos revisados	Casos con error	Tasa por caso	Tasa por par
Windows Server	43	0	0,0 % (0,0 a 8,2)	0,0 % (0,0 a 8,2)
Resto de los productos	29	12	19,4 % (7,2 a 38,3)	11,6 % (2,8 a 29,0)
Total de la vía de inferencia	72	12	3,2 % (0,5 a 10,3)	1,9 % (0,1 a 8,3)

Nota. Tasa de error de la vía de inferencia, con su intervalo de confianza al 95 % entre paréntesis. Cada caso revisado se pondera por la cantidad de casos que representa (apartado 5.2.1). «Resto de los productos» incluye los siete casos del firewall, revisados todos. El intervalo es el exacto de Clopper-Pearson (Clopper & Pearson, 1934), ajustado al diseño estratificado de la muestra con el método de Korn y Graubard (1998). Un caso es una vulnerabilidad y un producto del inventario; un par, una vulnerabilidad y un activo. Fuente: revisión de la muestra del 4 de octubre de 2026 y registro del sorteo.

Las cifras salen de una muestra y no de la revisión de todos los casos, de modo que tienen un margen. El rango entre paréntesis indica entre qué valores puede estar la tasa real. En Windows Server, no haber encontrado ningún error en 43 casos no prueba que no haya ninguno: la tasa real podría llegar al 8,2 %. Además, en esos casos la revisión no puede comprobar si una actualización ya instalada corrige la falla, por la limitación del inventario que declara el apartado anterior. En el resto de los productos, la muestra es pequeña y el rango es amplio, del 7,2 % al 38,3 %. Aun en el extremo más favorable, ese grupo se equivoca en uno de cada catorce casos: el error fuera de Windows Server no es ocasional.

Medida por par, la tasa es más baja: 1,9 % sobre el total y 11,6 % fuera de Windows Server. Los errores recayeron sobre productos instalados en un solo activo, mientras que buena parte de los casos de Windows Server y de macOS abarca dos activos y cuenta doble en esta unidad.

Dos salvedades acompañan estas cifras. La separación entre Windows Server y el resto no estaba prevista en el diseño del sorteo: se decidió al revisar la muestra, al advertir que en Windows Server los nombres coinciden exactamente. Y la tasa del resto depende de pocos juicios: si uno de los dos errores de Jenkins se hubiera juzgado correcto, bajaría unos cinco puntos. En sentido contrario, la tasa es un piso, porque las reglas de lectura resolvieron las dudas a favor de la correlación (apartado 5.2.1). Si los cuatro casos que esas reglas dieron por correctos se hubieran contado como error —los dos de OpenVPN, que la revisión independiente recomendaba contar así, el de Node.js y uno de Confluence—, la tasa del resto subiría al 22,4 %, y la del total, al 3,7 %.

5.2.3 Qué clases de error cometió la vía de inferencia

Los doce errores de la revisión se reparten en tres clases, y todas tienen el mismo origen: la vía de inferencia compara nombres y nada más. No compara la versión ni sabe qué complementos tiene instalados un activo, y acepta como coincidencia que un nombre contenga al otro. Dos clases reúnen la mayor parte del error: la del complemento y la de la versión.

Tabla 17

Errores de la vía de inferencia por clase

Clase de error	Qué ocurrió	Producto	Casos con error en la revisión	Casos que representan
Complemento	La falla es de un complemento cuyo nombre contiene el del producto	Jenkins 2.401	2	35
Versión	La versión del inventario es anterior a la que introdujo la falla	GitLab 16.0.0, Confluence 8.2.0	3	23
Coincidencia parcial de nombre	La falla es de otro producto del mismo fabricante cuyo nombre contiene el del inventario	Cisco IOS 15.4	7	7
Total			12	65

Nota. Errores de la vía de inferencia por clase. «Casos que representan» es la suma de los pesos de los casos con error, redondeada: cada caso revisado cuenta por los casos de su producto que representa (apartado 5.2.1). Los siete casos del firewall se revisaron todos y cada uno representa solo a sí mismo. Fuente: revisión de la muestra del 4 de octubre de 2026, con la reclasificación del 11 de octubre, y registro del sorteo.

Complemento. Jenkins publica las fallas de sus complementos con el nombre del complemento, como «Jenkins LDAP Plugin» o «Jenkins Pipeline: Build Step Plugin». Como ese nombre contiene «Jenkins», la vía de inferencia da por afectado al servidor que corre Jenkins, aunque el inventario no registra qué complementos tiene instalados. Es la clase que más pesa: los dos errores representan unos 35 de los 53 casos de Jenkins. La sección 3.4 anticipó este mecanismo y lo atribuyó al criterio de correlación, no al modelado del inventario.

Versión. En los tres casos, el producto es el correcto pero la versión del inventario es anterior a la que introdujo la falla. GitLab 16.0.0, por ejemplo, quedó correlacionado con una falla que afecta a partir de la versión 18.2.7. La vía de inferencia no compara versiones, de modo que cualquier falla del producto alcanza al activo. El diseño anterior a la reestructuración sí respetaba los rangos de versión, según establece la sección 3.10, y habría evitado estos tres errores. La precisión de versión depende además del inventario. Sus versiones son antiguas: una versión antigua queda fuera de las fallas introducidas después de ella, pero dentro de casi cualquier rango del tipo «anterior a la versión X».

Coincidencia parcial de nombre. Las siete fallas son de Cisco IOS XR, un sistema distinto del Cisco IOS que corre el firewall. Como «IOS XR» contiene «IOS», la vía de inferencia las correlacionó con el firewall. Es la clase que menos casos representa.

5.2.4 Qué correlaciones no encontró la vía de inferencia

Los apartados anteriores midieron el error en una dirección: correlaciones que la vía de inferencia estableció y no debía. Este mide la dirección contraria, las correlaciones que debía establecer y no estableció. La referencia es lo que la NVD declara afectado en la consulta de cierre. La pregunta es qué habría encontrado la vía de inferencia por sí sola, sin la vía formal, con los nombres que el flujo leyó al ingerir cada vulnerabilidad.

Tabla 18

Pares afectados según la NVD que la vía de inferencia no encontró

Medida	Vulnerabilidades	Pares
Declaradas afectadas por la NVD al cierre	924	5.810
Que la vía de inferencia habría encontrado	913 (98,8 %)	3.542 (61,0 %)
Que la vía de inferencia no habría encontrado	11 (1,2 %)	2.268 (39,0 %)

Nota. Pares vulnerabilidad-activo que la NVD declara afectados en la consulta del 3 de octubre de 2026, y cuántos habría encontrado la regla de inferencia del artefacto aplicada sola, con los nombres de fabricante y producto que el flujo leyó en las corridas de la campaña. Una vulnerabilidad cuenta como encontrada si la vía la correlaciona con al menos uno de los activos que la NVD declara afectados. Fuente: consulta de cierre a la NVD e historial de ejecuciones del orquestador.

La pérdida se concentra en un solo producto. Los 2.268 pares no encontrados son de las cuatro estaciones con Windows 10, 567 en cada una. Sobre el resto del inventario, la vía de inferencia encontró todos los pares que la NVD declara afectados.

La causa no es un dato faltante. En los 2.268 pares, el registro que leyó el flujo ya nombraba el producto afectado: Microsoft lo publica como «Windows 10 Version 22H2». La falla está en la comparación. Normalizado, ese nombre queda «windows10version22h2», y el del inventario, «windows1022h2». Ninguno contiene al otro, porque la palabra «Version» está en el medio. Es el reverso de la clase de error de coincidencia parcial del apartado anterior. La misma regla acepta de más cuando un nombre agrega algo en un extremo, como «IOS XR» frente a «IOS», y rechaza cuando lo agrega en el medio. Esos nombres casi no cambian después de la publicación: reaplicada la regla el 2 de octubre sobre los nombres vigentes, los 3.610 pares que encontraba al ingerir se mantuvieron y solo se sumaron 5, todos de una misma vulnerabilidad.

Esta pérdida es la que la sección 5.1.3 mostró desde el lado del artefacto. De las 567 vulnerabilidades de Windows 10, la vía formal recuperó 39 en cada estación: las que ya tenían configuración publicada mientras estaban dentro de la ventana del flujo. Las 528 restantes no las encontró ninguna de las dos vías, y son los 2.112 pares que se le escaparon al artefacto. El punto ciego de la vía de inferencia fue, así, la única pérdida real de cobertura de la campaña.

5.2.5 Respuesta a la segunda pregunta

La segunda pregunta secundaria busca establecer con qué precisión la vía de inferencia vincula una vulnerabilidad con un activo cuando falta el identificador formal, y qué clase de error introduce. La tabla siguiente reúne las cifras que la responden.

Tabla 19

Resumen de la precisión de la vía de inferencia

Medida	Resultado	Apartado
Tasa de error por caso en Windows Server	0,0 % (0,0 a 8,2)	5.2.2
Tasa de error por caso en el resto de los productos	19,4 % (7,2 a 38,3)	5.2.2
Tasa de error por caso, total	3,2 % (0,5 a 10,3)	5.2.2
Clases de error	Complemento, versión y coincidencia parcial de nombre	5.2.3
Pares afectados que no habría encontrado	2.268 de 5.810 (39,0 %), todos de Windows 10	5.2.4

Nota. Resumen de los resultados de la sección 5.2. Un caso es una vulnerabilidad y un producto del inventario (apartado 5.2.1). Las tasas llevan su intervalo de confianza al 95 % entre paréntesis. Fuente: apartados 5.2.2 a 5.2.4.

La precisión de la vía de inferencia no alcanza para usarla sin que un analista verifique cada correlación, salvo en Windows Server, que reúne cinco de cada seis casos y donde, por las razones del apartado 5.2.2, no se encontró ningún error. En el resto de los productos, se equivocó en casi uno de cada cinco casos, por nombres que no coinciden o por versiones anteriores a la falla. Y en Windows 10, cuyo nombre difiere del registrado, no encontró ninguno de sus pares.

Los errores de las dos direcciones salen de una misma regla, que acepta como coincidencia que un nombre contenga al otro, y no mira la versión (apartados 5.2.3 y 5.2.4). La ceguera de versión no es propia de la inferencia: la vía formal la comparte, según muestra la revisión de esa vía en el Anexo E. Las otras clases de error sí lo son. De todos los errores, el que más pesó fue el que no encontró nada, el punto ciego de Windows 10.

La regla de comparación, tal como se implementó, no alcanza para evitar errores en ninguna de las dos direcciones. Además, sus fallas no se pueden anticipar desde la regla misma. Dependen de cómo nombra cada fabricante sus productos en los registros, y Jenkins y Windows 10 fallaron por razones opuestas: uno por un nombre que contiene al del inventario, el otro por un nombre que no lo contiene. Una vía de este tipo no se puede aplicar sobre un inventario sin relevar antes cómo nombran sus productos los fabricantes que lo componen. El Capítulo 7 presenta alternativas de comparación.

La respuesta tiene tres límites. El primero es que la muestra fuera de Windows Server es pequeña: la tasa de ese grupo descansa en 29 casos, y la separación entre los dos grupos se decidió al revisar la muestra. Esa tasa es, además, un piso: con las dudas de lectura resueltas en contra, llegaría al 22,4 % (apartado 5.2.2). El segundo es que, en Windows, la revisión no puede comprobar si una actualización ya instalada corrige la falla, porque el inventario no registra el número de actualización. El tercero es que el criterio evalúa producto y versión, no exposición, de modo que no establece si el activo usa la función afectada. El alcance de estas cifras más allá de este inventario se discute en el Capítulo 6.

5.3 Momento de la priorización: cuánto cambió el índice cuando maduró la información

Esta sección mide si el índice que el artefacto calculó al detectar cada vulnerabilidad representaba su riesgo, o si lo subestimaba por haberse calculado con información todavía incompleta. Para cada par vulnerabilidad-activo, contrasta el índice registrado en la detección con el que recalculó la reevaluación diferida el 1 de octubre de 2026, descrita en la sección 3.12. Las dos cifras corresponden al mismo par, observado en dos momentos.

Criterio de esta sección. El contraste abarca los 3.883 pares de la base: los 3.848 de la campaña y los 35 del período de estabilización, que la sección 3.3 admite en este análisis porque sus defectos no alcanzan al índice que el flujo calculó. La reevaluación aplica los mismos pesos y umbrales que el flujo diario. Por eso una diferencia entre los dos índices solo puede venir de un cambio en los datos de la vulnerabilidad: su severidad, su probabilidad de explotación o su presencia en el catálogo de vulnerabilidades explotadas. Al recalcular, las vulnerabilidades tenían entre 7 y 41 días desde su publicación, con una mediana de 23. Esta fecha difiere de la del cierre de la sección 5.1, que corresponde a la consulta a la NVD del 3 de octubre: aquella midió el respaldo de las correlaciones y no recalculó el índice.

5.3.1 Cuánto cambió el índice entre la detección y el cierre

Tabla 20

Cambio del índice entre la detección y el cierre

Medida	Pares	% sobre los contrastados
Pares contrastados	3.883	100,0
El índice sube al cierre	2.233	57,5
El índice baja al cierre	371	9,6
El índice no cambia	1.279	32,9
El índice sube más de 0,05	387	10,0
Cambian de prioridad	1	0,0
Se notifican al detectar (índice de 0,40 o más)	17	0,4
Se notificarían con los valores de cierre	17	0,4

Nota. Contraste entre el índice registrado al detectar y el recalculado por la reevaluación diferida del 1 de octubre de 2026, para los mismos pares. Un índice «no cambia» cuando la diferencia es menor que media unidad de la cuarta cifra decimal, que es la precisión con que la base lo guarda. Los umbrales de prioridad son los de la sección 3.6. Fuente: tabla de telemetría, columnas del índice al detectar y al cierre.

El índice subió en la mayoría de los pares, pero casi siempre en cantidades que no alteran nada. Subió en 2.233 de los 3.883 pares y bajó en 371. La mediana del cambio fue de una diezmilésima, y el cambio medio, de 0,0098. Solo 387 pares (10,0 %) subieron más de cinco centésimas.

El cambio vino de dos componentes, en proporciones muy distintas. La severidad cambió en 395 pares, todos ingeridos sin puntaje de severidad, que recibieron uno después. El flujo había contado esa ausencia como severidad cero. Esos pares explican casi todo el cambio medio: 0,0096 de 0,0098.

La probabilidad de explotación cambió en 3.488 pares, pero en promedio movió el índice dos diezmilésimas. La presencia en el catálogo de vulnerabilidades explotadas no cambió en ningún par. Los apartados 5.3.2 y 5.3.3 examinan cada componente.

Ninguna decisión de notificación cambió: con los valores de cierre se notificarían los mismos 17 pares que se notificaron al detectar. Un solo par cambió de prioridad, la vulnerabilidad CVE-2026-85706 sobre el servidor de repositorios, que pasó de alta a crítica. Su índice subió de 0,5529 a 0,7824, el cambio más grande de la campaña. Todo el aumento vino de la probabilidad de explotación, que pasó de 0,0116 a 0,9296.

Ese caso muestra que la información puede madurar en una magnitud que importa. La vulnerabilidad se detectó 38 horas después de su publicación, con una probabilidad de explotación de 0,0116. Casi veinte días después, al recalcular, FIRST le asignaba 0,9296. La correlación con el servidor es incorrecta, porque la versión instalada es anterior a las afectadas, pero eso no altera esta medición: la probabilidad de explotación es un atributo de la vulnerabilidad y no del activo. El apartado 5.3.3 examina el caso junto con el resto de los movimientos de ese componente.

5.3.2 Cuánto cambió la severidad

La severidad es un atributo de la vulnerabilidad y toma el mismo valor en todos los activos que esta alcanza. Este apartado da sus cifras por vulnerabilidad y también por par, porque el efecto sobre el índice se mide en cada par.

La severidad solo cambió en las vulnerabilidades que no tenían puntaje cuando el flujo las ingirió. Una vulnerabilidad puede publicarse sin ese puntaje: el registro aparece primero y la calificación se agrega después. El flujo registra esa ausencia como severidad cero, de modo que no distingue una vulnerabilidad todavía sin calificar de una inofensiva. Durante la campaña ingirió así 224 vulnerabilidades, que alcanzaban 395 pares. En las 224 el cero es ausencia y no un puntaje real: el historial del orquestador muestra que ninguno de esos registros traía puntaje en la corrida que lo ingirió. Al cierre, todas tenían puntaje.

Esas 224 vulnerabilidades no estaban dispersas. Provienen de tres publicaciones conjuntas, es decir, de tres ocasiones en que un fabricante publicó de una sola vez un conjunto de vulnerabilidades, como ocurre con sus actualizaciones de seguridad.

Tabla 21

Vulnerabilidades ingeridas sin severidad, por publicación conjunta

Publicación conjunta	Fecha	Horas entre la publicación y la ingesta	Vulnerabilidades publicadas	Sin severidad al ingerir	Pares sin severidad al ingerir
Jenkins	2 de septiembre	0,7	33	33	33
Apple	14 de septiembre	19,7	222	171	342
Jenkins	16 de septiembre	2,7	20	20	20
Total			275	224	395

Nota. Una publicación conjunta reúne las vulnerabilidades que un mismo fabricante publicó en el mismo minuto. Las horas se miden entre la publicación en la NVD y la ingesta del flujo. Una vulnerabilidad llegó sin severidad cuando la respuesta de la NVD en la corrida de su ingesta no traía ningún puntaje. Fuente: tabla de telemetría, historial de ejecuciones del orquestador y registros del repositorio público de vulnerabilidades.

Ninguno de esos registros traía el puntaje de quien lo publicó. Fuera de esas tres publicaciones, ninguna vulnerabilidad llegó sin severidad: los otros 66 pares que el flujo ingirió dentro de las 24 horas posteriores a la publicación, entre 1,9 y 23,7 horas después, tenían todos puntaje.

La severidad no se fue completando a medida que pasaba el tiempo. Cada registro la recibió de una vez, cuando alguien la cargó, y lo que decidió si faltaba al ingerir fue la publicación conjunta de la que formaba parte la vulnerabilidad, no las horas que tenía. Las dos publicaciones de Jenkins se ingirieron a menos de tres horas, y a ninguna de sus vulnerabilidades le había llegado todavía el puntaje. La de Apple se ingirió casi veinte horas después, y todavía faltaba en 171 de sus 222 vulnerabilidades. Otras vulnerabilidades, ingeridas con menos de dos horas, ya lo tenían.

El puntaje que faltaba lo cargó casi siempre CISA, no el NIST. En 215 de las 224 vulnerabilidades, el puntaje de cierre es igual al que CISA agregó al registro; en las 9 restantes lo cargó el NIST. La igualdad de valores indica el origen, aunque no lo prueba. Frente a la reforma del NIST, entonces, CISA lo suplió en la severidad, pero no en los identificadores de producto (CPE) que necesita la correlación: según la sección 5.1.5, no aportó ninguno.

En esos 395 pares el índice subió en promedio 0,0949. Por su severidad de cierre, 12 pares son de severidad baja, 246 media, 123 alta y 14 crítica, según la escala cualitativa de la versión 3 del sistema de puntaje. Ninguno cruzó el umbral de notificación: el índice más alto que alcanzaron fue 0,2341, también en los 14 de severidad crítica. El apartado 5.3.4 explica por qué este componente, con su peso, no alcanza por sí solo a cambiar una decisión.

5.3.3 Cuánto cambió la probabilidad de explotación

La probabilidad de explotación es un atributo de la vulnerabilidad y toma el mismo valor en todos los activos que esta alcanza. Por eso este apartado la mide por vulnerabilidad y no por par.

Tabla 22

Cambio de la probabilidad de explotación entre la detección y el cierre

Situación entre la detección y el cierre	Vulnerabilidades	%
Sin dato al detectar, con dato al cierre	61	5,9
Con dato en los dos momentos: sube	651	62,6
Con dato en los dos momentos: baja	223	21,4
Con dato en los dos momentos: no cambia	105	10,1
Total	1.040	100,0

Nota. Probabilidad de explotación registrada al detectar y recalculada por la reevaluación diferida del 1 de octubre de 2026, para las 1.040 vulnerabilidades distintas del contraste. Una vulnerabilidad no tenía dato al detectar cuando FIRST publicó su primera estimación después de la ingesta, según el criterio

de la sección 3.8; el flujo registró cero en esos casos. Las 61 cumplen ese criterio, y ninguna es una probabilidad real muy baja redondeada a cero. Fuente: tabla de telemetría, columnas de probabilidad de explotación al detectar y al cierre; series históricas de FIRST para los valores en cero.

La probabilidad de explotación maduró de dos maneras. En 61 vulnerabilidades el dato llegó: al detectar no existía y el flujo registró cero, y al cierre tenían un valor, con una mediana de 0,0036. Son las 53 de la campaña que identifica la sección 3.8, más ocho del período de estabilización. En las 979 restantes el dato existía y se revisó: subió en 651, bajó en 223 y no cambió en 105. Contando las dos maneras, la probabilidad subió en 712 de las 1.040 vulnerabilidades (68,5 %).

En las dos maneras el cambio fue chico. La mediana de todas pasó de 0,0029 al detectar a 0,0033 al cierre. Solo cuatro vulnerabilidades subieron más de una centésima, y solo una terminó en 0,04 o más. Ese valor tiene una referencia en FIRST: para quien hoy atiende solo las vulnerabilidades de severidad crítica, un esfuerzo equivalente en su escala corresponde aproximadamente al percentil 90, es decir, a una probabilidad de 0,04 o más (Forum of Incident Response and Security Teams, s. f.). FIRST no lo propone como umbral recomendado, sino como punto de partida.

Dos vulnerabilidades concentran los movimientos de algún tamaño. La primera es CVE-2026-85706, de GitLab, que pasó de 0,0116 a 0,9296 (apartado 5.3.1). La segunda es CVE-2026-85880, de Windows, que alcanza nueve activos del inventario y pasó de 0,0057 a 0,0362.

Las dos son además las únicas de la campaña que figuran en el catálogo de vulnerabilidades explotadas de CISA, y en las dos el catálogo se adelantó a la probabilidad. La de GitLab ingresó al catálogo el 11 de septiembre, un día antes de su publicación en la NVD; la de Windows, el 8 de septiembre, el mismo día en que se publicó. Al detectarlas, el flujo ya registraba la explotación confirmada, mientras que la probabilidad de explotación seguía cerca de cero. Tres semanas después, la de Windows todavía no llegaba a 0,04.

Dos casos no alcanzan para establecer un patrón. Son compatibles con que el catálogo registre la explotación antes que la estimación de FIRST, pero no lo demuestran. Su estabilidad debe leerse con la misma cautela: ninguna otra vulnerabilidad de la campaña ingresó al catálogo durante la ventana, de modo que el componente no cambió en ningún par porque no hubo nada que lo hiciera cambiar.

5.3.4 Qué componentes deciden una notificación

Este apartado explica por qué la maduración de los datos no cambió ninguna decisión. Para eso examina qué componentes del índice decidieron las 17 notificaciones de la campaña, y qué combinación de componentes necesita un par para llegar al umbral de 0,40.

Criterio de este apartado. Un componente es necesario en una notificación cuando, al quitar su aporte, el índice queda por debajo de 0,40. Una notificación puede tener más de un componente necesario.

Tabla 23

Componentes necesarios en las notificaciones emitidas

Componente	Peso	Notificaciones en que fue necesario
Severidad	0,15	12
Probabilidad de explotación	0,25	0
Explotación confirmada	0,30	10
Criticidad del activo	0,20	7
Exposición a Internet	0,10	7

Nota. Componentes necesarios en los 17 pares notificados. Como una notificación puede tener más de un componente necesario, la columna no suma 17. Los pesos son los de la sección 3.6. El índice se reconstruyó desde los componentes guardados al detectar, y coincide con el guardado en los 17 pares. Fuente: tabla de telemetría e inventario de activos.

En promedio, el índice lo forman dos componentes. Sobre los 3.883 pares del contraste, el índice medio fue 0,2018, y el 98,8 % de ese valor lo aportaron la criticidad del activo (49,8 %) y la severidad (49,0 %). La probabilidad de explotación aportó el 0,5 %, la explotación confirmada el 0,4 % y la exposición el 0,3 %. Lo que más pesa en el promedio, sin embargo, no es lo que decide las notificaciones.

La probabilidad de explotación no decidió ninguna. No fue necesaria en ninguna de las 17 notificaciones, y su mayor aporte en un par notificado fue 0,0029. Tampoco podía decidir: el valor más alto que registró la campaña al detectar fue 0,0169, que con su peso aporta 0,004 al índice. El peso del componente no es bajo, 0,25, el segundo más alto del índice. Lo que anula su aporte es que se suma de forma lineal sobre una variable cuyos valores habituales son milésimas: incluso 0,04, el valor de referencia de FIRST (apartado 5.3.3), aportaría 0,01. El Capítulo 6 discute qué implica esto para el diseño del índice, y el Capítulo 7 propone una alternativa.

La explotación confirmada, en cambio, decidió la mayoría. Fue necesaria en 10 de las 17 notificaciones: la de GitLab y la de Windows sobre nueve activos. Su peso, 0,30, deja al par a una décima del umbral, y casi cualquier activo completa esa décima. En 22 de los 30 activos del inventario, una vulnerabilidad con la explotación confirmada notifica sea cual sea su severidad. En los ocho restantes, de criticidad baja y sin exposición, le basta una severidad de 3,4.

Las otras siete notificaciones no tenían la explotación confirmada, y son todas del firewall perimetral. En ellas fueron necesarias a la vez la severidad, la criticidad y la exposición. La tabla siguiente muestra por qué solo ese activo pudo notificar de ese modo. Cada activo aporta al índice una parte fija, que sale de su criticidad y de su exposición. Sin explotación confirmada, y con una probabilidad de explotación que no aporta, lo que falta para llegar a 0,40 solo puede ponerlo la severidad, que aporta como máximo 0,15.

Tabla 24

Distancia al umbral de los activos sin explotación confirmada ni probabilidad de explotación

Tipo de activo	Activos	Aporte del activo al índice	Falta para llegar a 0,40	Severidad que lo cubre
Criticidad crítica, expuesto a Internet	1	0,30	0,10	6,7 o más
Criticidad alta, expuesto a Internet	2	0,25	0,15	Solo 10,0
Los demás	27	Entre 0,05 y 0,20	Entre 0,20 y 0,35	Ninguna

Nota. Situación de cada activo sin explotación confirmada y con probabilidad de explotación nula. El aporte del activo es la suma de sus componentes de criticidad y de exposición. La última columna indica qué severidad, en la escala de 0 a 10, cubre lo que falta. En los 27 activos restantes lo que falta supera 0,15, el aporte máximo de la severidad, de modo que ninguna severidad alcanza. Fuente: inventario de activos y pesos de la sección 3.6.

En el firewall basta una severidad de 6,7. En los dos servidores web expuestos hace falta la máxima, 10,0. En los otros 27 activos ninguna severidad alcanza, y por eso los 14 pares de severidad crítica del apartado 5.3.2 no cruzaron el umbral.

En este inventario y con estos pesos, entonces, la explotación confirmada basta casi siempre para notificar, y la probabilidad de explotación no pesa. Sin explotación confirmada, una notificación exige tres condiciones a la vez. El activo tiene que estar expuesto a Internet: ningún activo sin exposición puede notificar de otro modo. Su criticidad tiene que ser alta o crítica. Y la severidad tiene que ser elevada: al menos 6,7 en el activo de criticidad crítica, el extremo superior de la banda media, y 10,0 en los de criticidad alta.

5.3.5 Qué habría cambiado un disparador por probabilidad de explotación

Este apartado prueba una regla alternativa sobre los datos ya guardados: que toda vulnerabilidad con una probabilidad de explotación de 0,04 o más se notifique por sí sola, además de las que notifica el índice. El 0,04 es el valor de referencia de FIRST presentado en el apartado 5.3.3. La prueba no requiere datos nuevos.

Criterio de este apartado. La regla se aplica sobre tres registros de la base: el valor guardado al detectar, el valor de cierre y la serie diaria de FIRST que la base conserva para las 1.040 vulnerabilidades. La serie permite comprobar si alguna superó 0,04 en un día intermedio y después volvió a bajar.

Tabla 25

Efecto de un disparador por probabilidad de explotación de 0,04

Momento	Vulnerabilidades con 0,04 o más	Pares que notificaría la regla	De ellos, sin notificar por el índice
Al detectar	0	0	0
Al cierre	1	1	0
En algún día de la serie diaria	1	1	0

Nota. Resultado de aplicar la regla «probabilidad de explotación de 0,04 o más notifica» a los 3.883 pares del contraste, que corresponden a 1.040 vulnerabilidades. La serie diaria cubre del 21 de agosto al 1 de octubre de 2026. Fuente: tabla de telemetría y serie diaria de probabilidad de explotación de la base.

La regla no habría cambiado ninguna notificación. Al detectar, ninguna vulnerabilidad llegaba a 0,04. Durante toda la ventana solo una la superó: la de GitLab, que pasó de 0,0116 el día de su detección a 0,111 al día siguiente, y se mantuvo por encima hasta el cierre. Ese par ya estaba notificado por la explotación confirmada.

El resultado no alcanza para juzgar la regla, por dos razones. La campaña casi no produjo probabilidades altas, de modo que la prueba no tuvo ocasión de mostrar qué agrega el disparador. Y en el único caso en que la probabilidad superó 0,04, la explotación ya estaba confirmada desde antes (apartado 5.3.3). Eso sugiere que, en esta campaña, la explotación confirmada bastó para cubrir lo que el disparador habría señalado, pero no lo prueba: el aporte propio de la probabilidad de explotación está en las vulnerabilidades que todavía no se explotan, y la campaña no registró ninguna con probabilidad alta.

5.3.6 Veredicto sobre la segunda hipótesis

La segunda hipótesis sostiene que el índice calculado en el momento de la ingesta subestima sistemáticamente el riesgo de una vulnerabilidad, y que la magnitud de esa subestimación depende del tiempo transcurrido desde su publicación. Como el índice no estima riesgo (sección 3.6), la subestimación se contrasta sobre su valor: el índice calculado al detectar frente al recalculado con información madura. La tabla siguiente reúne las cifras que la contrastan.

Tabla 26

Resumen del momento de la priorización

Medida	Resultado	Apartado
Pares cuyo índice sube al cierre	2.233 de 3.883 (57,5 %)	5.3.1
Cambio mediano del índice	0,0001	5.3.1
Pares cuyo índice sube más de 0,05	387 (10,0 %): 386 por severidad ausente al ingerir y 1 por probabilidad de explotación	5.3.1 y 5.3.2
Notificaciones que cambian	0 de 17	5.3.1
Pares que cambian de prioridad	1, de alta a crítica	5.3.1
Qué determinó la falta de severidad al ingerir	La publicación conjunta de la que formaba parte la vulnerabilidad, no las horas transcurridas	5.3.2

Nota. Contraste entre el índice registrado al detectar y el recalculado por la reevaluación diferida del 1 de octubre de 2026, sobre los 3.883 pares del contraste. Fuente: apartados 5.3.1 y 5.3.2.

La evidencia no sostiene la hipótesis tal como está formulada. El índice calculado al detectar sí quedó por debajo del de cierre en la mayoría de los pares, pero casi siempre por diezmilésimas, y ninguna notificación cambió. La subestimación apreciable se concentró en el 10,0 % de los pares, y salvo en un caso no vino de una maduración gradual: vino de un dato que faltaba al ingerir,

la severidad, que el flujo registró como cero. Tampoco dependió del tiempo transcurrido. Que la severidad faltara o no lo decidió la publicación conjunta de la que formaba parte la vulnerabilidad: hubo vulnerabilidades ingeridas a menos de dos horas que ya la tenían, y otras ingeridas a casi veinte horas a las que todavía les faltaba.

El veredicto tiene tres límites. El primero es que la subestimación medida depende en parte del diseño del flujo. Como el flujo no distingue una severidad ausente de una severidad cero, convierte la falta de un dato en un índice bajo. Un flujo que marcara esos pares como pendientes de calificación no habría registrado esa subestimación, pero tampoco habría podido priorizarlos.

El segundo es la ventana del contraste. El índice se recalculó cuando las vulnerabilidades tenían entre 7 y 41 días, con una mediana de 23. Lo que maduró después, como un ingreso tardío al catálogo de vulnerabilidades explotadas, queda fuera de estas cifras.

El tercero es el alcance del caso. La conclusión sobre el tiempo descansa en tres publicaciones conjuntas de dos fabricantes, y la probabilidad de explotación no podía mover el índice por la forma en que este la suma (apartado 5.3.4). Su alcance más allá de este inventario y de este índice se discute en el Capítulo 6.

5.4 Ubicación del cuello de botella: qué tramo determinó el momento de la detección

Esta sección mide qué limita el tiempo que pasa entre la publicación de una vulnerabilidad y su detección. Ese tiempo se descompone en tres tramos, que la sección 3.7 permite medir por separado: lo que tarda el artefacto en procesar una corrida, el tiempo entre una corrida y la siguiente, y lo que tarda la NVD en publicar la configuración que necesita la vía formal. La tercera hipótesis sostiene que el procesamiento es el menor de los tres, y que el tramo que gobierna la detección depende de la vía.

Criterio de esta sección. Cada tramo se mide en su propia unidad: el procesamiento, por corrida; el tiempo entre corridas, entre corridas efectivas consecutivas; y la demora de la NVD, por vulnerabilidad. El universo es el de la campaña: 27 corridas efectivas y 1.018 vulnerabilidades correlacionadas. Por las dos limitaciones del instrumento que declara la sección 1.8, los tramos se comparan en órdenes de magnitud y no por sus valores puntuales. Para la demora de la NVD, el apartado 5.4.3 corrige ambas con el historial de cambios que publica la propia fuente.

5.4.1 Cuánto tarda el artefacto en procesar una corrida

El tiempo de procesamiento va desde la marca de ingesta, que el flujo estampa al comenzar la correlación, hasta el cierre del procesamiento de cada par, según describe la sección 3.7. Deja fuera la descarga desde la NVD, que lleva decenas de segundos por corrida. Se mide solo en las corridas posteriores al 9 de septiembre de 2026, porque el control de ritmo incorporado ese día alarga el intervalo y vuelve incomparables las corridas anteriores. Quedan fuera también las siete filas de la corrida reparada a mano el 3 de septiembre (sección 3.8). Solo las corridas que registran pares nuevos dejan la marca de cierre: de las diecisiete posteriores al control, lo hicieron nueve.

Tabla 27

Tiempo de procesamiento por corrida

Corrida	Pares correlacionados en la corrida	Pares nuevos	Segundos de procesamiento
9 de septiembre	3.203	3.195	471,9
10 de septiembre	3.297	102	523,8
11 de septiembre	16	2	2,6
13 de septiembre	2	2	3,4
15 de septiembre	444	444	89,9
16 de septiembre	481	37	77,9
17 de septiembre	39	2	5,6
20 de septiembre	4	4	1,2
24 de septiembre	7	7	1,6

Nota. Tiempo entre la marca de ingesta y el cierre del procesamiento, en mediana por corrida. Se da una cifra por corrida y no por par porque el flujo cierra juntos todos los pares de una corrida: dentro de cada una, difieren en menos de dos segundos. Los pares correlacionados son todos los que la corrida vinculó con el inventario, incluidos los que ya había registrado una corrida anterior; los nuevos son los que la corrida escribió por primera vez. La duración depende de los correlacionados porque el flujo consulta la probabilidad de explotación de cada uno en consultas sucesivas que espacia el control de ritmo, antes de verificar cuáles son nuevos. Por eso la corrida del 10 de septiembre, con 102 pares nuevos, tardó más que la del 9: las dos correlacionaron más de tres mil pares, porque sus ventanas incluían el 8 de septiembre, el día de mayor publicación del mes (sección 3.7). Corridas posteriores a la incorporación del control de ritmo, el 9 de septiembre de 2026, que registraron pares nuevos. Fuente: tabla de telemetría y tabla de auditoría.

El procesamiento tardó entre poco más de un segundo y casi nueve minutos por corrida, según la cantidad de pares que correlacionó. En las corridas de cien pares o más, cada par correlacionado sumó una mediana de 0,16 segundos, entre 0,15 y 0,20. En las más chicas la cifra por par es mayor, porque pesa un costo fijo de la corrida que no depende de cuántos pares procese. El intervalo incluye la espera del control de ritmo. Mide, por lo tanto, lo que tarda el artefacto tal como está construido, y no solo el cómputo.

5.4.2 Cada cuánto corre el flujo

El flujo está programado para dispararse una vez por día, a las 14:00 locales. Este apartado mide cuánto tiempo pasó efectivamente entre una corrida efectiva y la siguiente.

Tabla 28

Tiempo entre corridas efectivas consecutivas

Tiempo entre dos corridas efectivas consecutivas	Brechas	Horas
Todas	26	Mediana 24,0; entre 15,6 y 48,0
Entre 23 y 25 horas	17	23,1 a 24,8
Menos de 23 horas	4	15,6 a 22,7
Más de 26 horas	5	26,2 a 48,0

Nota. Horas entre las marcas de dos corridas efectivas consecutivas de la tabla de auditoría. Las 27 corridas efectivas de la campaña dejan 26 brechas. Una corrida efectiva es la primera de cada día, según el criterio de la sección 3.8. Ninguna brecha quedó entre 25 y 26 horas. Fuente: tabla de auditoría.

El flujo corrió en mediana cada 24 horas. Las brechas que se apartan de ese valor vienen de corridas que no se ejecutaron a las 14:00: las suplidas a mano (sección 3.8) y la repetición del 9 de septiembre (sección 3.12). Una corrida fuera de horario alarga la brecha anterior y acorta la siguiente, porque la corrida siguiente vuelve a dispararse a las 14:00. La brecha de 48 horas corresponde al 12 de septiembre, el único día sin corrida. Desde el 13 de septiembre hasta el cierre, las trece brechas quedaron entre 23,6 y 24,4 horas.

Para la detección, esto significa que una vulnerabilidad espera hasta la corrida siguiente a su publicación: hasta un día, y hasta dos en el caso del 12 de septiembre. Ese día sin corrida no hizo perder ninguna vulnerabilidad, porque la ventana de tres días de la corrida del 13 cubrió lo publicado el 12.

5.4.3 Cuánto tarda la NVD en publicar la configuración

La vía formal solo puede correlacionar una vulnerabilidad cuando la NVD ya publicó su configuración, es decir, la lista de productos afectados (sección 3.10). Este apartado mide cuánto tardó en llegar esa configuración desde la publicación de cada una de las 1.018 vulnerabilidades correlacionadas.

Criterio de este apartado. Se toma como momento de llegada el primero en que la NVD publicó una configuración para la vulnerabilidad, aunque esa configuración no incluya ningún producto del inventario: lo que se mide es cuándo la NVD analizó la vulnerabilidad, no si la vinculó con un activo. La fecha sale del historial de cambios que la NVD publica para cada vulnerabilidad, consultado el 13 de octubre de 2026: es la del evento de análisis inicial en que el NIST agregó la configuración. A diferencia de la fecha de última modificación que señala la sección 1.8, registra ese cambio y no cualquier otro. Dos registros más ubican cada llegada respecto de la ventana del flujo: lo que la NVD devolvió en cada corrida, que conserva el historial del orquestador, y la consulta a la NVD del 3 de octubre de 2026. La ventana abarca tres días de calendario en tiempo universal, y el flujo corre a las 17:00 de ese huso, las 14:00 locales (sección 3.7). Una vulnerabilidad publicada antes de esa hora entra en tres corridas y sale de la ventana entre 48 y 65 horas después de su publicación; una publicada más tarde entra en dos y sale entre 41 y 48 horas después. En las 788 vulnerabilidades que salieron de la ventana sin configuración, la última corrida que las vio fue, en la mediana, 47 horas después de su publicación.

Tabla 29

Momento de llegada de la configuración de la NVD

Cuándo llegó la configuración	Vulnerabilidades	%
Ya estaba en la primera corrida que la ingirió	47	4,6
Llegó mientras estaba en la ventana	134	13,2
Llegó después de salir de la ventana	788	77,4
No había llegado el 3 de octubre	49	4,8
Total	1.018	100,0

Nota. Vulnerabilidades correlacionadas durante la campaña, según el momento en que la NVD publicó su configuración. Las 181 de las dos primeras filas son las que tenían respaldo formal al detectar según la sección 5.1.2. Al cierre, esa sección cuenta 63 sin respaldo y no 49, porque en otras 14 la configuración no nombra ningún producto del inventario. Fuente: historial de ejecuciones del orquestador, historial de cambios de la NVD y consulta a la NVD del 3 de octubre de 2026.

Tabla 30

Configuración publicada según los días transcurridos desde la publicación

Días desde la publicación	Vulnerabilidades con configuración	% de las 1.018
3	302	29,7
5	391	38,4
7	459	45,1
10	630	61,9
14	749	73,6
21	932	91,6

Nota. Vulnerabilidades correlacionadas que tenían configuración publicada a los días indicados desde su publicación. Incluye las 47 que ya la tenían en la primera corrida; las 49 que no la tenían el 3 de octubre no cuentan en ningún plazo. Fuente: historial de cambios de la NVD e historial de ejecuciones del orquestador.

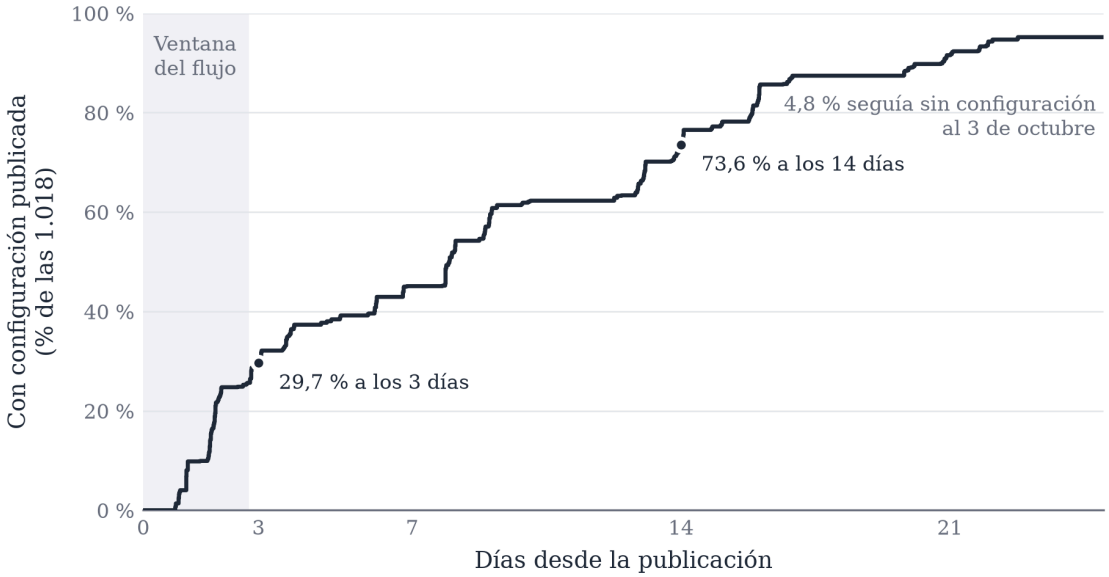


Figura 3. Proporción de las 1.018 vulnerabilidades correlacionadas que tenía configuración publicada en la NVD, según los días transcurridos desde su publicación. La franja gris marca el tiempo máximo que una vulnerabilidad permanece en la ventana del flujo, 65 horas desde su publicación. Según la hora en que se publicó, cada una sale de la ventana entre las 41 y las 65 horas (apartado 5.4.3). Por eso la curva supera, dentro de la franja, al 17,8 % que recibió la configuración mientras el flujo la miraba (Tabla 29). Las 47 que ya tenían configuración en la primera corrida se cuentan en el momento de esa corrida; las 49 que no la tenían el 3 de octubre no suman en ningún plazo. Fuente: historial de cambios de la NVD e historial de ejecuciones del orquestador.

Para la mayoría de las vulnerabilidades, la configuración no llegó mientras el flujo las miraba. Solo 47 la tenían en la primera corrida, y a otras 134 les llegó en las corridas siguientes. A 788 les llegó después de salir de la ventana, entre 1,8 y 22,8 días después, con una mediana de 8,9, y 49 seguían sin ella el 3 de octubre, entre 17 y 32 días después de su publicación. Consultado de nuevo el historial el 2 de noviembre, ninguna de las 49 la había recibido. Las 11 correlacionadas que se publicaron después de la última de ellas recibieron la configuración el 24 o el 28 de septiembre.

Esas fechas concuerdan con lo que registró el flujo. En las 922 vulnerabilidades que la recibieron después de la primera corrida, la fecha del historial de la NVD cae entre la última corrida que vio la vulnerabilidad sin configuración y la primera que la vio con ella, o la consulta del 3 de octubre.

La llegada fue gradual. A los tres días de publicadas, el 29,7 % de las vulnerabilidades tenía configuración; a la semana, el 45,1 %; a las dos semanas, el 73,6 %; y a las tres semanas, el 91,6 %.

El sesgo de la ventana que anuncia la sección 1.8 tiene, entonces, un tamaño medible. Contada solo sobre las llegadas que el flujo alcanzó a ver, la demora de la NVD tiene una mediana de 1,7 días. Contada sobre las 922 que la recibieron después de la primera corrida, la mediana es de 8,0 días, casi cinco veces más. El estimador de Kaplan-Meier (Kaplan & Meier, 1958) sobre las 1.018, con cierre en la consulta del 3 de octubre y las 49 sin configuración como observaciones censuradas, da la misma mediana, con cuartiles de 2,6 y 14,1 días, y lleva la proporción a las tres semanas del 91,6 % al

92,1 %. En órdenes de magnitud, la demora se mide en días, y para el 26,4 % de las vulnerabilidades supera las dos semanas. El reparto es compatible con la política que el NIST anunció en abril de 2026 (sección 1.1), aunque estos datos no permiten saber cuáles de las vulnerabilidades pertenecen al subconjunto que ese organismo prioriza.

5.4.4 Qué tramo determinó el momento de la detección en cada vía

Este apartado reúne los tres tramos anteriores para establecer cuál fijó el momento de cada detección. La tercera hipótesis responde por separado para cada vía, porque cada una depende de un dato distinto: la inferencia usa el fabricante y el producto que el registro trae desde su publicación, y la vía formal necesita la configuración que la NVD agrega después. El procesamiento no decide en ninguna de las dos: dura como máximo nueve minutos (apartado 5.4.1) y termina dentro de la misma corrida, de modo que no cambia en qué corrida se detecta una vulnerabilidad. Para cada vulnerabilidad correlacionada, el apartado establece si el artefacto la detectó en la primera corrida posterior a su publicación o en una posterior, y cuántas horas pasaron. Si la detectó en la primera, la demora la fijó la cadencia del flujo. Si la detectó en una posterior, la fijó la espera de la configuración de la NVD.

Criterio de este apartado. La detección de una vía es la primera corrida que registró un par de la vulnerabilidad por esa vía. Ocho vulnerabilidades aparecen en las dos vías: la inferencia las vinculó con algunos activos del inventario y la vía formal, con otros. Por eso la tabla suma 1.026 vulnerabilidades y no las 1.018 correlacionadas.

Tabla 31

Horas entre la publicación y la detección, por vía

Vía	Corrida en que se detectó	Vulnerabilidades	Horas desde la publicación
Inferencia	Primera posterior a la publicación	935	0,7 a 37,7
Inferencia	Una posterior	0	—
Formal	Primera posterior a la publicación	47	20,0 a 27,0
Formal	Una posterior	44	39,7 a 63,7

Nota. Horas entre la publicación en la NVD y la marca de ingesta de la corrida que detectó la vulnerabilidad por cada vía. Una corrida posterior es cualquier corrida efectiva distinta de la primera que siguió a la publicación. De las 44 detectadas por la vía formal en una corrida posterior, 43 esperaron una corrida y 1 esperó dos. Fuente: tabla de telemetría y tabla de auditoría.

La vía de inferencia nunca esperó a la NVD. Detectó sus 935 vulnerabilidades en la primera corrida posterior a la publicación. Su demora la impuso la cadencia: entre menos de una hora y 37,7 horas, según cuánto faltara para la corrida siguiente en el momento de la publicación.

La vía formal sí esperó. Cuarenta y siete vulnerabilidades ya tenían la configuración en la primera corrida y se detectaron en ella, y ninguna de ellas se había publicado menos de 20 horas antes. Las otras 44 se detectaron en una corrida posterior, entre 39,7 y 63,7 horas después de su publicación: el flujo las había ingerido sin configuración y las vinculó cuando la NVD la agregó. En 8 de ellas la

inferencia ya había detectado la vulnerabilidad en otros activos. En las 36 restantes, la espera de la configuración retrasó la única detección.

Lo que la vía formal no alcanzó pesa más que lo que detectó tarde. Solo podía actuar sobre las 181 vulnerabilidades cuya configuración llegó dentro de la ventana (apartado 5.4.3). De ellas, detectó 91, y las otras 90 ya las había detectado la inferencia, que la vía formal confirmó después. Sobre las 837 restantes no podía actuar, porque la demora de la NVD superó el tiempo que el flujo las miraba. En la vía formal, la NVD no fija solo cuándo se detecta una vulnerabilidad, sino también si se detecta.

5.4.5 Veredicto sobre la tercera hipótesis

La tercera hipótesis sostiene que el procesamiento del artefacto no limita el tiempo de detección, porque es menor en órdenes de magnitud que los otros dos tramos. Sostiene además que la demora con que la NVD publica la configuración gobierna la vía formal, y que la cadencia del flujo gobierna la vía de inferencia. La tabla siguiente reúne las cifras que la contrastan.

Tabla 32

Resumen de la ubicación del cuello de botella

Medida	Resultado	Apartado
Procesamiento de una corrida	Segundos a minutos: de 1,2 segundos a 8,7 minutos	5.4.1
Tiempo entre corridas	Un día: mediana de 24,0 horas, entre 15,6 y 48,0	5.4.2
Demora de la NVD en publicar la configuración	Días: mediana de 8,0; más de dos semanas en el 26,4 %	5.4.3
Detección por la vía de inferencia	935 de 935 en la primera corrida posterior a la publicación	5.4.4
Detección por la vía formal	47 en la primera corrida y 44 en una posterior; sin alcance sobre 837 de las 1.018	5.4.4

Nota. Resumen de los tres tramos de la latencia de detección y del momento de la detección en cada vía, sobre la campaña de recolección. Fuente: apartados 5.4.1 a 5.4.4.

La evidencia sostiene la hipótesis. El procesamiento fue el tramo más corto por amplio margen. En el peor caso, de casi nueve minutos, fue más de cien veces menor que un día de cadencia, y en la corrida típica, de unos segundos, la diferencia supera las diez mil veces. Ninguna detección cambió de corrida por el procesamiento. La vía de inferencia detectó todas sus vulnerabilidades en la primera corrida posterior a la publicación, de modo que su demora la fijó la cadencia. La vía formal dependió de la NVD: detectó tarde las vulnerabilidades cuya configuración llegó durante la ventana y no alcanzó las demás.

En la vía formal, el resultado va más allá de lo que la hipótesis anticipaba. La hipótesis planteaba la demora de la NVD como un factor que retrasa la detección. Con una ventana de tres días, esa demora la impidió en el 82,2 % de las vulnerabilidades correlacionadas, porque la configuración no llegó mientras el flujo las miraba. Es la distinción que plantea la sección 1.1: un dato demorado se resuelve esperando, y uno que llega fuera del alcance del sistema obliga a buscarlo por otra

vía. En esta campaña, esa otra vía fue la inferencia. Una ventana más larga habría alcanzado más configuraciones: a los siete días la tenía el 45,1 % y a los catorce, el 73,6 % (apartado 5.4.3). El Capítulo 7 examina esa alternativa y su costo.

El veredicto tiene tres límites. El primero es que la cadencia es una decisión de diseño y no una propiedad del problema. Que gobierne la vía de inferencia describe a este artefacto, que corre una vez por día. Una cadencia más corta reduciría esa demora hasta donde lo permitan los límites de las fuentes que describe la sección 3.9.

El segundo es el universo de la demora de la NVD. Se midió sobre las 1.018 vulnerabilidades que el artefacto correlacionó y no sobre todo lo que la NVD publicó.

El tercero es el alcance del caso. La campaña duró cuatro semanas, y los datos no permiten saber cuáles de estas vulnerabilidades pertenecen al subconjunto que el NIST prioriza. Su alcance más allá de este período se discute en el Capítulo 6.

5.5 Fallas silenciosas: cómo se distinguió un resultado nulo legítimo de una falla

Las secciones anteriores midieron lo que el artefacto registró. Esta examina si se podía confiar en lo que no registró. En esta arquitectura, varios defectos se manifestaron como ausencia de datos y no como errores, según plantea la sección 1.3. Una corrida que pierde registros o correlaciones puede verse igual que un día sin novedades. Sobre las 28 corridas de la campaña, un mecanismo distingue los dos casos cuando contrasta el resultado del flujo con un dato que el propio nodo no produce.

El testigo de truncamiento no se activó en ninguna corrida de la campaña, según consigna la sección 3.10. Su punto ciego, descrito en la sección 3.7, se presentó una sola vez y no afecta a este análisis.

La fila de auditoría se escribe en toda corrida, aunque no haya correlaciones, porque la rama que la compone registra ceros cuando no recibe resultados de la correlación (sección 4.5). Sobre esa fila se aplicó un control: comparar los correlacionados que declara con los pares que la tabla de telemetría guardó en la misma corrida. Un cero acompañado de pares guardados es una fila falsa. Un cero sin pares puede ser legítimo. El control no lo ejecuta el artefacto: se aplica después, sobre las dos tablas, y es posible porque la fila existe en toda corrida.

De las 28 filas, una sola se contradice con la base. La del 3 de septiembre declara cero correlacionados sobre 1.159 vulnerabilidades ingeridas, y esa corrida guardó 7 pares. Es la corrida interrumpida por la caducidad de la credencial de correo y completada a mano (sección 3.8). Al ejecutar los nodos uno por uno, la rama de auditoría no recibió la salida de la correlación y registró ceros. La misma tolerancia que garantiza una fila en toda corrida produjo el cero falso. Por eso las cifras por corrida de ese día salen de la tabla de telemetría.

Quedan las siete corridas que no correlacionaron nada ni guardaron pares. En ellas, un nodo de correlación que hubiera dejado de funcionar habría producido la misma fila de auditoría que un día sin vulnerabilidades de los productos del inventario. Para distinguir los dos casos se usó una fuente que no depende del artefacto: la consulta de cierre a la NVD del apartado 5.1.3. Si el nodo hubiera

fallado en alguno de esos días, la NVD mostraría vulnerabilidades ingeridas ese día que afectaban a algún activo y que el artefacto nunca detectó o detectó recién en una corrida posterior. No apareció ninguna. Hay cinco casos que solo lo parecen: vulnerabilidades de Langflow, un producto que no figura en el inventario, que llegaron sin configuración y que la NVD vinculó después a las estaciones macOS solo como plataforma. Ninguna vía podía detectarlas. Dentro de lo que la NVD había analizado al 3 de octubre, los siete ceros fueron correctos.

En respuesta a la quinta pregunta, el artefacto aportó dos mecanismos: el testigo de truncamiento, que no registró pérdidas, y la fila de auditoría, cuyo contraste con la base encontró el único registro falso de la campaña, producido por la caducidad de la credencial de correo el 3 de septiembre. Ninguno de los dos alcanza a un cero sin pares: para esos casos hizo falta una fuente externa.

5.6 Notificaciones emitidas: qué hizo el tramo final del flujo con los pares que recibió

Esta sección evalúa el último tramo del flujo, el triaje y el envío del correo, separado de lo que le llega. El tramo recibe cada par con su índice ya calculado y tiene una sola tarea: enviar un correo si el índice alcanza 0,40 y no enviarlo si no lo alcanza (sección 3.11). Se lo juzga por esa tarea. Si la correlación era correcta, lo mide la sección 5.2.

De los 3.883 pares de la base, 17 alcanzaron el umbral, y los 17 generaron su correo. El flujo marca un par como notificado recién después de que el servicio de correo acepta el mensaje, y en ese momento guarda el identificador que el servicio le asigna. Los 17 pares tienen ese identificador, y ningún par que alcanzó el umbral quedó sin él. Adicionalmente, ningún par por debajo del umbral generó correo. El identificador prueba que el servicio aceptó el envío, no que el analista haya leído el mensaje.

Los correos salieron en tres de las 28 corridas. Siete corresponden a la del 3 de septiembre, interrumpida por la caducidad de la credencial de correo (sección 3.8). Fue la única falla del tramo en la campaña, y no perdió ningún correo: los siete salieron casi media hora después, al completarse la corrida a mano. Los nueve siguientes salieron el 9 de septiembre, y el último, el 13. Las otras 25 corridas no enviaron ninguno.

El tramo envía lo que recibe y no puede juzgar si la correlación era correcta. Por eso los errores de las etapas anteriores llegaron al analista: siete de los 17 correos correspondían a las correlaciones falsas del firewall (apartado 5.2.3), y uno a la de GitLab, cuya versión inventariada es anterior a la afectada. Los nueve de Windows no pueden confirmarse, porque el inventario no registra el número de actualización del sistema.

Ningún par quedó cerca del umbral. El notificado de índice más bajo tuvo 0,4235, y el no notificado de índice más alto, 0,3319. Cualquier umbral entre esos dos valores habría producido las mismas 17 notificaciones. El reparto de los correos lo fijó el mecanismo de notificación: nueve de los 17 llevaron una misma vulnerabilidad, porque el flujo notifica por par y no por vulnerabilidad (sección 3.11).

Tampoco cambian las notificaciones con otra regla de cálculo. El apartado 5.3.5 lo mostró para un disparador por probabilidad de explotación, y lo mismo ocurre con el escenario de la sección 3.6, que duplica el peso de la exposición a Internet. Con los valores al detectar y con los del cierre, notifica los mismos 17 pares. Como la exposición vale cero o uno, en ella el peso es lo único que puede mover el índice, y alcanza a pocos pares: solo 21 de los 3.883 caen sobre activos expuestos. El que más se acerca al umbral sube de 0,3319 a 0,3975 y no lo alcanza.

Capítulo 6: Conclusiones

Este capítulo responde la pregunta principal de la sección 1.3, revisa el cumplimiento de los objetivos específicos y delimita qué conclusiones sostiene la evidencia reunida. Las respuestas a las preguntas secundarias no se repiten. Los veredictos de las tres hipótesis están en los apartados 5.1.6, 5.3.6 y 5.4.5, y las respuestas descriptivas en los apartados 5.2.5 y 5.5.

6.1 Respuesta a la pregunta principal

La pregunta principal tiene tres partes: qué efectos tuvo la reforma del enriquecimiento de la NVD sobre la arquitectura, en qué medida el rediseño recuperó la capacidad de detección y con qué consecuencias para la priorización. Esta sección las responde en ese orden.

El flujo rediseñado pasó a ingerir lo publicado en una ventana de tres días, y con ese diseño la demora de la NVD no retrasó el dato de correlación, sino que lo dejó fuera de su alcance. La NVD publicó la configuración de las vulnerabilidades correlacionadas con una mediana de ocho días, y el flujo deja de revisar cada vulnerabilidad entre 41 y 65 horas después de publicada, según la hora en que se publicó (apartado 5.4.3). En el 82,2 % de ellas, la configuración no llegó mientras el flujo la miraba (apartado 5.4.4). Es la distinción que plantea la sección 1.1: un dato demorado se resuelve esperando, y uno fuera de alcance obliga a buscarlo por otra vía. La demora en sí no es atribuible solo a la reforma: el retraso de la NVD está documentado desde febrero de 2024 (sección 2.1), y una sola campaña no permite separar las dos causas. Con el dato del NIST como única vía, y contando solo los productos que la NVD marca como vulnerables, el artefacto habría correlacionado al detectar menos de una de cada siete vulnerabilidades (apartado 5.1.6).

El rediseño recuperó casi por completo la detección por vulnerabilidad, y la recuperó sin demora. De las 924 vulnerabilidades que la NVD terminó declarando que afectaban al inventario, el artefacto detectó 914 (apartado 5.1.3), y la vía de inferencia detectó todas las suyas en la primera corrida posterior a la publicación (apartado 5.4.4). Por par, la recuperación fue menor: el artefacto detectó casi dos de cada tres, y los 2.112 pares que perdió recaen todos sobre las cuatro estaciones con Windows 10. Esa pérdida exigió tres condiciones a la vez. Microsoft, como CNA de sus propios productos, declara en el registro de cada vulnerabilidad los productos afectados, pero la respuesta de la NVD no incluye ese dato; la vía de inferencia no reconoció el nombre con que Microsoft designa esas versiones; y el NIST agregó su identificador cuando el flujo ya no consultaba esas vulnerabilidades.

La recuperación tuvo un costo en precisión, y lo fijó la regla con que la vía de inferencia compara nombres. En Windows Server la revisión no encontró errores; en el resto de los productos, la vía se equivocó en casi uno de cada cinco casos (apartado 5.2.2). Tres de esos errores salen de que el rediseño perdió la comparación de versiones, que antes hacía el servidor de la NVD (sección 3.10). Esos errores llegaron al analista: ocho de las 17 notificaciones de la campaña correspondían a correlaciones falsas, siete del firewall y una del servidor de repositorios (sección 5.6). Por eso, cuánto recuperó el rediseño no depende solo de cómo está construido el flujo, sino también de qué

fabricantes componen el inventario y de cómo nombran sus productos. El mismo flujo, aplicado a otro inventario, habría recuperado otra proporción.

Para la priorización, la consecuencia fue menor de lo que anticipaba la segunda hipótesis. El índice calculado al detectar casi no difirió del recalculado con información madura, y ninguna notificación cambió (apartado 5.3.1). La subestimación apreciable vino de un dato ausente y no de uno inmaduro: la severidad, que el flujo registró como cero sin distinguir la falta de un puntaje de un puntaje de cero (apartado 5.3.2). Ese dato, además, no quedó sin respuesta, y eso muestra que la reforma no dejó un vacío uniforme. De los dos datos que el NIST dejó de garantizar, la severidad y el identificador de producto, otra fuente pública cubrió uno y no el otro. CISA completó la severidad en 215 de las 224 vulnerabilidades que llegaron sin ella, pero no aportó ningún identificador de producto (apartados 5.3.2 y 5.1.5). El dato que quedó sin reemplazo es justamente el que la correlación necesita, y por eso el artefacto tuvo que inferirlo.

Las notificaciones las decidió la información que ya estaba al detectar. La explotación confirmada, tomada del catálogo de CISA, fue necesaria en 10 de las 17, y la probabilidad de explotación en ninguna (apartado 5.3.4). La probabilidad no podía decidir, por dos causas. El índice la suma de forma lineal sobre valores que en esta campaña fueron casi siempre milésimas (apartado 5.3.4). Y al detectar el dato todavía no existía en 61 vulnerabilidades, o apenas empezaba a moverse (apartado 5.3.3). Para esta arquitectura, el catálogo pesó más que la probabilidad. Los dos no compiten como predictores: el catálogo registra una explotación ocurrida y la probabilidad estima una futura. Solo la segunda puede adelantarse a la explotación, y en esta campaña no tuvo ocasión de hacerlo (apartado 5.3.5).

Que el índice casi no se moviera tuvo una consecuencia más. El flujo notifica un par solo la primera vez que lo ve, de modo que un aumento posterior del riesgo no genera aviso (sección 1.7). En esta campaña ese límite no tuvo costo: el único par que cambió de prioridad ya estaba notificado, y ningún otro alcanzó el umbral con los valores de cierre (apartado 5.3.1). Esa ausencia de costo depende de un índice que la probabilidad de explotación no puede mover, y dejaría de valer en uno que sí reaccionara a ella.

El resto del artefacto no fue lo que limitó la detección, y tres resultados del Capítulo 5 lo muestran. El procesamiento de una corrida tardó entre segundos y minutos, frente a un día entre corridas, y no retrasó ninguna detección (apartado 5.4.5). El tramo de notificación envió un correo por cada par que alcanzó el umbral, y ninguno más (sección 5.6). Y los controles de integridad encontraron un solo error en toda la campaña, un conteo equivocado en el registro de auditoría de una corrida, que no afectó a los datos recolectados (sección 5.5). Lo que limitó al artefacto fue, entonces, lo que recibió de la fuente, la ventana durante la que lo consultó y la regla con que lo comparó con el inventario.

6.2 Cumplimiento de los objetivos específicos

Los objetivos de construcción se cumplieron, salvo una parte del tercero. La base de datos relacional modela las vulnerabilidades, los activos y la correlación entre ellos (sección 4.2 y Anexo C). El flujo

ingirió durante la campaña la totalidad de lo publicado en cada ventana, 14.456 vulnerabilidades distintas en 28 corridas, y resolvió su correlación localmente por las dos vías (secciones 4.4 y 5.1). El índice incorpora la probabilidad de explotación de FIRST, pero la priorización basada en ella, que el objetivo también enunciaba, no se logró: ese componente no decidió ninguna notificación, por las causas expuestas en la sección 6.1. El mecanismo de notificación envió los 17 correos que correspondían y registró en la base el identificador que el servicio de correo asignó a cada uno (sección 5.6).

Los objetivos de medición también se cumplieron. La reevaluación diferida recalculó el índice el 1 de octubre de 2026 sin alterar el valor registrado al detectar, y su contraste es el que mide la sección 5.3. Se trata de un instrumento de medición y no de un componente del producto: el flujo diario no la ejecuta ni toma decisiones a partir de ella. La cobertura de cada vía se midió al detectar y al cierre (sección 5.1). La precisión de la vía de inferencia se validó sobre una muestra de 65 casos revisada contra los registros de los fabricantes, y la vía formal, con la revisión completa de sus 101 vulnerabilidades: 60 contra el aviso del fabricante y 41 que coinciden con el activo solo como plataforma (sección 5.2 y Anexo E). Los tres tramos de la latencia se compararon en la sección 5.4.

El último objetivo, documentar los efectos de la reforma, los cambios de diseño y los modos de falla, se cumplió a lo largo del documento. La sección 1.1 y la fase 4 de la sección 3.12 describen la reestructuración que exigió la reforma; el Capítulo 4, el artefacto que resultó; la sección 5.5, los mecanismos que detectaron las fallas silenciosas; y la sección 6.1, el efecto de la reforma medido sobre la campaña.

6.3 Alcance de las conclusiones

Este trabajo es un estudio de caso, y sus conclusiones no se extienden a otros inventarios por inferencia estadística. Se extienden por el mecanismo: una conclusión vale fuera del caso en la medida en que el mecanismo que la produjo se encuentre en otra arquitectura, con independencia de las cifras. Con ese criterio, la evidencia reunida sostiene tres conclusiones y no alcanza para otras tres.

La primera conclusión que se sostiene es que un flujo que consulta por fecha de publicación convierte la demora de la fuente en un problema de alcance. Su mecanismo es la relación entre la demora de la NVD y la ventana durante la cual el flujo revisa cada vulnerabilidad, y alcanza a toda arquitectura que consulte la fuente por fecha de publicación con una ventana más corta que esa demora. La cifra exacta, el 82,2 %, sí es propia del caso, y no se atribuye solo a la reforma: la demora de la NVD es anterior a ella (sección 2.1). La campaña duró cuatro semanas, y los datos no permiten saber cuáles de las vulnerabilidades observadas pertenecen al subconjunto que el NIST se comprometió a enriquecer (apartado 5.4.5).

La segunda es que la probabilidad de explotación no puede mover un índice que la suma de forma lineal con su escala original. En el índice de este trabajo es un defecto de diseño, que la medición puso en evidencia. Esta conclusión no depende del inventario: depende de la forma del índice y de

la distribución de la probabilidad, que FIRST publica para todas las vulnerabilidades y no solo para las de este caso (apartado 5.3.3). Vale para cualquier índice construido del mismo modo.

La tercera es que la precisión de una vía de inferencia por nombre depende de cómo nombran sus productos los fabricantes del inventario y de cómo declaran los rangos de versión afectados. Lo que se extiende es el mecanismo, y no la tasa. La tasa total, del 3,2 %, refleja que cinco de cada seis casos de la muestra eran de Windows Server, donde el nombre coincide exactamente y el rango del fabricante abarca toda la versión instalada (apartado 5.2.2). El efecto de la reforma se concentró además en cinco servidores de un único fabricante, que reunieron el 86,0 % de los pares sin respaldo al detectar (apartado 5.1.4). Un inventario compuesto por otros fabricantes obtendría otras cifras de cobertura y de precisión, aun con el mismo flujo, según anticipa la sección 3.3.

La evidencia no alcanza, en cambio, para juzgar el canal de alertas como herramienta de triaje. Diecisiete notificaciones, ocho de ellas falsas y nueve de Windows que no pueden confirmarse, permiten describir qué hizo el canal en esta campaña, pero no estimar su tasa de error ni la utilidad del umbral. Tampoco alcanza para concluir que la probabilidad de explotación carezca de valor como anticipo. La campaña casi no registró probabilidades altas, y la prueba del disparador no tuvo ocasión de mostrar qué agregaría (apartado 5.3.5). Ni alcanza para afirmar que la madurez del dato carezca de consecuencias en general. La conclusión sobre el tiempo descansa en tres publicaciones conjuntas de dos fabricantes (apartado 5.3.6). Lo que de ella se extiende es un punto de diseño: un flujo que registra la falta de un dato como un cero convierte esa falta en un riesgo bajo.

Dos condiciones del caso limitan todas las conclusiones. La primera es que el trabajo no observó el sistema bajo el régimen anterior de enriquecimiento, de modo que la comparación con ese régimen es una inferencia a partir de la lógica del diseño, según declara la sección 1.7. La segunda es la granularidad del inventario. El inventario no registra el número de actualización de Windows, los complementos instalados, la configuración de los servicios ni el sistema operativo bajo el software de aplicación. Sin esos datos, una parte de las correlaciones no puede confirmarse ni descartarse. El límite de la correlación no está solo en la regla que compara los nombres, sino también en lo que el inventario registra de cada activo.

Esas conclusiones acotan la transferencia que plantea la sección 1.4. El criterio de emplear herramientas abiertas y fuentes públicas se sostiene: el artefacto operó la campaña completa con herramientas sin costo de licencia y fuentes de acceso público. Pero un flujo como este no se transfiere listo para usar a un inventario distinto. Antes de desplegarlo, hay que relevar cómo nombran sus productos los fabricantes que componen ese inventario y declarar dónde no va a alcanzar la cobertura. El Capítulo 7 desarrolla esas condiciones.

Capítulo 7: Recomendaciones

Este capítulo reúne las recomendaciones que se desprenden de los resultados. Ninguna se implementó ni se midió. El artefacto permaneció congelado durante la campaña, y cualquier cambio posterior produciría un sistema distinto del que se evaluó. Cada recomendación parte de una falla documentada en el Capítulo 5, describe el cambio y declara qué resolvería y qué no. La sección 7.1 reúne las correcciones al flujo diario; la 7.2, los datos que el inventario debería registrar; la 7.3, los cambios en la priorización y la notificación; y la 7.4, las líneas de trabajo que exceden una corrección.

7.1 Correcciones propuestas al flujo

La única pérdida real de cobertura de la campaña, la de las cuatro estaciones con Windows 10, exigió tres condiciones a la vez (apartado 5.2.4). La respuesta de la NVD no traía el identificador que Microsoft declara en el registro. La regla de inferencia no reconoció el nombre con que Microsoft publica el producto. Y la configuración del NIST llegó cuando el flujo ya no consultaba esas vulnerabilidades. Bastaba con que faltara una de las tres para que la pérdida se evitara o se recuperara después. Los apartados 7.1.1, 7.1.2 y 7.1.4 corresponden a esas tres condiciones. El 7.1.3 trata la versión y la plataforma, que afectan a la precisión de las dos vías, y el 7.1.5, el tratamiento de los pares ya registrados.

7.1.1 Leer el identificador que declara la CNA

La primera recomendación es leer el identificador formal que declara la CNA, la organización que publica cada vulnerabilidad. Ese dato figura en un bloque propio del registro de origen, que la respuesta de la NVD no incluye (sección 3.10). Es la vía que el apartado 5.1.5 midió por fuera del artefacto, y la que declaraba los 2.112 pares de Windows 10 que el artefacto no detectó. El repositorio público del programa CVE publica cada hora un paquete con los registros nuevos y modificados desde el comienzo del día (CVE Program, s. f.). Bastaría con descargarlo una vez por corrida, junto con la consulta a la NVD.

En el flujo, esa lectura sería un paso intermedio entre las dos vías actuales. Primero se compara la configuración del NIST, como hoy. Si no coincide, se comparan los identificadores de la CNA con la misma regla. Solo si ninguno coincide se recurre a los nombres por inferencia. La inferencia quedaría reservada para las vulnerabilidades sin dato formal de ninguna fuente, y cada correlación registraría de qué paso salió. El cambio tiene tres límites. No ayuda donde la CNA no declara identificadores, como ocurre con buena parte de los fabricantes del inventario (Anexo A). Como aplica la regla de la vía formal, hereda su ceguera de versión, que trata el apartado 7.1.3. Y como la vía de la CNA se midió solo al cierre, el trabajo no establece si habría detectado esos pares al primer contacto o recién cuando la CNA completó su registro (apartado 5.1.5). En el segundo caso, la consulta por modificación del apartado 7.1.4 los habría recuperado tarde, como al dato del NIST.

7.1.2 Comparar los nombres sin depender de su forma

La segunda recomendación es cambiar la regla de comparación de la vía de inferencia. Ninguna regla basada solo en cadenas corrige los dos sentidos del error. Comparar por palabras, exigiendo que cada palabra del nombre del inventario figure en el del fabricante, reconoce «Windows 10 Version 22H2» como el Windows 10 22H2 del inventario. Pero sigue aceptando «Cisco IOS XR» por «Cisco IOS» y los complementos de Jenkins por Jenkins, porque también en esos casos están todas las palabras del inventario. Exigir que los dos nombres tengan exactamente las mismas palabras elimina esos errores y vuelve a perder Windows 10.

Se recomiendan dos alternativas que no dependen de la forma del nombre. La primera es una tabla de equivalencias que asocie cada producto del inventario con los nombres bajo los que su fabricante lo publica, o con su identificador en el diccionario de productos de la NVD. Es el relevamiento previo que la sección 6.3 plantea como condición para trasladar el flujo, y que la sección 7.2 retoma. Su costo es que se mantiene a mano: un nombre nuevo de un fabricante no se reconoce hasta que alguien lo agrega. La segunda es someter cada correlación por inferencia a un modelo de lenguaje, que lea la descripción de la falla y el registro del activo y señale las dudosas. No reemplaza al analista. Además, agrega un componente cuya respuesta no es determinista, en tensión con la reproducibilidad que plantea la sección 2.7. Serviría como filtro previo a la revisión humana, no como criterio de correlación.

7.1.3 Comparar la versión y leer solo los productos vulnerables

Ninguna de las alternativas anteriores resuelve la versión. Los tres errores de versión de la inferencia (apartado 5.2.3) y la misma ceguera en la vía formal (Anexo E) piden comparar la versión del inventario contra los rangos que declara el registro. La comparación depende de cómo venga expresado el rango. Cuando viene en campos estructurados, con su límite inferior y su límite superior, alcanza con una comparación directa. Así lo expresan la configuración del NIST y, cuando la CNA lo completa, el bloque de versiones de su registro. El diseño anterior a la reestructuración ya respetaba los rangos del NIST (sección 3.10). Cuando el rango figura solo en la descripción de la falla, con las convenciones propias de cada fabricante (sección 1.7), la lectura podría quedar a cargo de un modelo de lenguaje, con los recaudos que plantea el apartado 7.1.2. En los dos casos, la correlación cuya versión no pueda establecerse se marcaría como de versión no verificada, en lugar de darse por buena. Es lo que ocurriría siempre que falte el dato del lado del inventario, como el número de actualización de Windows, que la sección 7.2 retoma.

La regla formal admite además un cambio más simple: leer solo los productos que la configuración marca como vulnerables. Hoy la regla toma todos los identificadores de la configuración, incluidos los que el NIST declara solo como plataforma de ejecución. Así correlacionó 82 pares de programas que corren sobre macOS con las dos estaciones que usan ese sistema (apartado 5.1.2). El cambio es una condición en un nodo del flujo. Elimina esos pares sin perder detecciones, porque en ninguno de ellos el activo era el producto afectado.

7.1.4 Consultar por fecha de modificación

La tercera condición es de tiempo. El flujo consulta por fecha de publicación con una ventana de tres días, y la configuración no llegó dentro de ella en el 82,2 % de las vulnerabilidades correlacionadas (apartado 5.4.5). La alternativa que ese apartado deja planteada es alargar la ventana: a los catorce días tenía configuración el 73,6 %. Su costo es que cada vulnerabilidad pasa por catorce corridas en lugar de dos o tres, y aun así queda afuera más de una de cada cuatro.

La recomendación es cambiar el criterio de la consulta y no su extensión: que cada corrida pida a la NVD los registros modificados desde la corrida anterior, en lugar de los publicados en los últimos tres días. Publicar un registro es su primera modificación, de modo que la consulta trae las vulnerabilidades nuevas y, además, las anteriores que cambiaron, entre ellas las que reciben su configuración. El monitoreo sigue siendo diario y cubre un solo día. Las 528 vulnerabilidades de Windows 10 que se perdieron terminaron con configuración formal (apartado 5.1.3), de modo que esa consulta las habría recuperado tarde, pero las habría recuperado. El volumen se mantiene en el orden de la campaña. En los dos días consultados el 15 de octubre de 2026, el 13 y el 14, la NVD registró 2.766 y 3.357 modificaciones, frente a un máximo de 2.804 registros por corrida durante la recolección (sección 3.10). La mayor parte son registros que cambiaron por otros motivos y que no correlacionan con el inventario.

7.1.5 Recalcular y volver a decidir sobre los pares ya registrados

Hoy el flujo consulta la probabilidad de explotación y calcula el índice de cada par correlacionado antes de verificar si ya lo había registrado, y esas consultas fijan el tiempo de procesamiento (apartado 5.4.1). Cuando el par ya existía, ese cálculo se descarta. La rama que lo recibe, la de promoción, anota si cambió la vía de correlación y termina, sin guardar el índice nuevo ni volver a decidir si corresponde notificar. El flujo paga el costo del recálculo y no lo usa. Además, consulta a FIRST una vez por par, aunque su interfaz admite varias vulnerabilidades por petición; agruparlas por vulnerabilidad habría reducido esa espera y el volumen que motivó el rechazo del 9 de septiembre.

La recomendación es invertir el orden y darle destino al recálculo. El flujo verificaría primero si el par existe, y en los dos casos calcularía el índice con los datos recibidos y lo guardaría. Un par nuevo sigue el camino actual. Uno ya registrado pasa por el mismo triaje, con una sola condición agregada: se notifica si cruza el umbral y no se había notificado antes, para que un registro que cambia por cualquier motivo no repita el aviso. En la campaña no habría alterado ninguna decisión: con los valores de cierre se notificarían los mismos 17 pares (apartado 5.3.1). El caso que justifica el cambio es el de una vulnerabilidad que ingresa al catálogo después de detectada, que el diseño actual nunca avisaría. En la campaña no ocurrió: las dos vulnerabilidades del catálogo ya figuraban en él al detectarse (apartado 5.3.3). La probabilidad de explotación queda fuera de este mecanismo, porque FIRST la actualiza a diario sin que cambie el registro de la NVD; la sección 7.3 trata esa escalada.

7.2 Inventario y modelo de datos

La sección 6.3 concluye que una parte de las correlaciones no puede confirmarse ni descartarse, porque el inventario no registra lo que haría falta para juzgarlas. El diseño de un modelo de inventario completo excede el alcance de este trabajo. El apartado 7.2.1 identifica qué datos faltaron, el 7.2.2 trata el relevamiento de nombres que debería preceder al despliegue y el 7.2.3 propone dos correcciones del modelo de datos de la base.

7.2.1 Datos que el inventario no registró

El inventario anota cada activo con su producto principal y la versión declarada. En la campaña faltaron tres clases de datos.

La primera son los componentes del activo. El inventario no declara el núcleo de Linux bajo cada distribución (sección 3.4). No sabe qué complementos de Jenkins tiene instalados el servidor, y sus fallas se correlacionaron igual (apartado 5.2.3). Tampoco registra el sistema operativo sobre el que corre OpenVPN, del que dependían dos de sus fallas (apartado 5.2.1).

La segunda es la configuración. La falla de Exim de la muestra exige una opción que el inventario no registra (apartado 5.2.1). Varias fallas de Windows Server dependen de roles que los activos no declaran (Anexo E).

La tercera es la versión exacta de Windows. El inventario registra la edición del sistema y no la actualización instalada, y por eso las nueve notificaciones de Windows no pueden confirmarse ni descartarse (sección 5.6).

Registrar los componentes y la configuración supone rediseñar el inventario. En un parque real, ese dato lo provee una herramienta de inventario automático, integración que retoma la sección 7.4. La versión de Windows, en cambio, es un solo dato por activo, y la recomendación es registrarlo: la compilación completa de cada sistema, incluido el número que avanza con cada actualización mensual. Microsoft declara en su registro la compilación a partir de la cual cada falla está corregida, de modo que con ese dato la comparación directa del apartado 7.1.3 alcanzaría también a los activos Windows. El dato cambia con cada ciclo de parches, y mantenerlo al día también correspondería a esa herramienta.

7.2.2 Relevar los nombres de cada fabricante antes de desplegar

La recomendación es relevar, antes de desplegar el flujo, cómo nombra cada fabricante los productos del inventario. Es la condición que la sección 6.3 plantea para llevarlo a otro inventario, y el insumo de la tabla de equivalencias del apartado 7.1.2. Para cada producto, el relevamiento reúne los nombres con que su fabricante lo publica y separa los que lo designan de los que designan otra cosa aunque lo contengan, como «Cisco IOS XR» frente al Cisco IOS del firewall. El diagnóstico del Anexo A hizo un ejercicio parecido sobre los identificadores formales, pero no sobre los nombres en texto que lee la inferencia, y por eso no anticipó los casos de Windows 10 y de Jenkins. El relevamiento tiene un límite: solo encuentra los nombres que ya aparecieron en los registros. Un producto sin vulnerabilidades en el período relevado no deja nombres que clasificar.

7.2.3 Corregir dos campos de la base

La sección 1.7 declara dos límites del modelo de datos que conviene corregir en una versión posterior. El primero es de nomenclatura: el valor «informativa» designa a la vez una categoría de prioridad y un estado del hallazgo. No afectó a ningún resultado, porque las dos columnas son independientes. La corrección es renombrar el valor del estado, por ejemplo como «sin notificar», de modo que cada palabra designe una sola cosa en la base y en la interfaz.

El segundo es que el flujo no guarda qué organización publicó el puntaje de severidad. La respuesta de la NVD informa ese origen junto a cada puntaje, pero el flujo guarda el primer puntaje que recibe y descarta su origen. Por eso el apartado 5.3.2 tuvo que deducirlo por coincidencia de valores: el puntaje de cierre coincidía con el de CISA en 215 de 224 vulnerabilidades, una igualdad que indica el origen pero no lo prueba. La corrección es guardar el origen en una columna propia. Junto con la consulta por modificación del apartado 7.1.4, quedaría registrado quién cargó cada puntaje y en qué corrida llegó. Después de la reforma, ese dato ya no puede suponerse: la severidad puede llegar del NIST, de CISA o de ninguno de los dos.

7.3 Priorización y notificación

La probabilidad de explotación no decidió ninguna notificación de la campaña, y el flujo registró como cero los datos que todavía no existían al detectar (apartados 5.3.2 a 5.3.4). Además, el flujo envía un correo por par (sección 3.11). El apartado 7.3.1 propone un disparador propio para la probabilidad de explotación; el 7.3.2, cómo detectar su aumento después de la detección; el 7.3.3, cómo marcar un índice calculado con datos faltantes; y el 7.3.4, un aviso por vulnerabilidad.

7.3.1 Notificar por probabilidad de explotación con una categoría propia

La recomendación es que una probabilidad de explotación de 0,04 o más notifique por sí sola, con una categoría de prioridad propia, y que el componente salga del índice. Dentro del índice no puede decidir, por la escala en que se suma (apartado 5.3.4). Con el disparador, su peso en la suma se vuelve redundante.

El índice conservaría los otros cuatro pesos y el umbral de 0,40. Quitar el componente no habría cambiado ninguna notificación de la campaña: el menor índice notificado fue 0,4235, y el mayor aporte de la probabilidad en un par notificado, 0,0029 (apartado 5.3.4 y sección 5.6). Lo que no se recomienda es repartir su peso de 0,25 entre los demás componentes. Un reparto proporcional, por ejemplo, haría que el firewall notificara cualquier vulnerabilidad aunque su severidad fuera cero, porque su criticidad y su exposición sumarían por sí solas 0,40. Cualquier reparto define un índice nuevo que habría que calibrar, y la sección 7.4 trata ese rediseño.

La categoría propia responde a lo que el dato significa. La explotación confirmada registra un ataque ocurrido, y la probabilidad estima uno futuro (sección 6.1). Un aviso por probabilidad alta no es necesariamente tan urgente como uno de prioridad crítica, y el analista tiene que poder distinguirlos desde el asunto del correo. Si el par ya cruzó el umbral del índice, el disparador no agrega un segundo aviso.

El valor de 0,04 es el que FIRST presenta como punto de partida, equivalente aproximado al percentil 90 de su escala, y no como umbral recomendado (Forum of Incident Response and Security Teams, s. f.). La regla no pudo juzgarse en la campaña. No habría cambiado ninguna notificación, porque la única vulnerabilidad que superó 0,04, la de GitLab, ya estaba notificada por la explotación confirmada (apartado 5.3.5). Fijar el valor exige observarlo en un período con probabilidades más altas. Un umbral sobre el percentil se descarta: el percentil mide la posición de una vulnerabilidad frente a las demás, y puede cambiar sin que cambie su probabilidad.

7.3.2 Detectar el aumento de la probabilidad después de la detección

La recomendación es que el flujo revise cada día la probabilidad de explotación de los pares que registró y no notificó. Al detectar, la probabilidad casi nunca tiene todavía un valor que importe: la más alta de la campaña en ese momento fue 0,0169 (apartado 5.3.4), y la de GitLab superó 0,04 recién al día siguiente (apartado 5.3.5). Un disparador que solo mirara el valor de la detección casi nunca se activaría. La consulta por modificación y el recálculo de los apartados 7.1.4 y 7.1.5 tampoco alcanzan, porque FIRST recalcula la probabilidad a diario sin que la NVD modifique el registro.

La revisión se integraría al flujo como una rama que parte del mismo disparador diario. Primero descarga el archivo en que FIRST publica cada día la probabilidad de todas las vulnerabilidades que puntúa (Forum of Incident Response and Security Teams, 2026b). Después consulta en la base los pares registrados sin notificar y los cruza con el archivo. Los que alcanzan 0,04 pasan al tramo de notificación que ya existe, que envía el correo con la categoría del apartado 7.3.1 y marca el par como notificado, para que no vuelva a avisar. Si el cruce no devuelve ningún par, la rama termina ahí.

El costo es una descarga por corrida y una comparación dentro del flujo, sin consultas adicionales a FIRST. En la campaña, el cruce no habría devuelto ningún par: la única vulnerabilidad que superó 0,04 ya estaba notificada por la explotación confirmada (apartado 5.3.5). El valor de la rama está en el caso para el que existe el disparador, el de una vulnerabilidad que todavía no se explota.

7.3.3 Marcar el índice calculado con datos ausentes

La recomendación es que el flujo registre cuándo falta un dato, en lugar de confundir la falta con un cero. Hoy registra como severidad cero la de una vulnerabilidad todavía sin calificar, y así ingirió 224 vulnerabilidades en 395 pares (apartado 5.3.2). Hizo lo mismo con la probabilidad de explotación de las 61 vulnerabilidades que FIRST todavía no había estimado (apartado 5.3.3). Es el punto de diseño que plantea la sección 6.3.

El cambio no requiere columnas nuevas. Las columnas de severidad y de probabilidad de explotación ya admiten un valor vacío (Anexo C), y alcanza con guardar ahí la falta en lugar de un cero. El índice se seguiría calculando como hoy: al hacer la cuenta, el flujo toma como cero el componente vacío, pero no guarda ese cero en la columna. El valor vacío en la columna basta para saber que el índice es un mínimo y no un valor definitivo. Cuando llega la severidad, la consulta por modificación del apartado 7.1.4 trae el registro, y el recálculo del 7.1.5 completa la columna y actualiza el índice; la probabilidad la trae el archivo diario del apartado 7.3.2. En la campaña habría bastado: las 224

vulnerabilidades recibieron su puntaje después, y ninguno de sus pares cruzó el umbral, porque el índice más alto que alcanzaron fue 0,2341 (apartado 5.3.2).

7.3.4 Enviar un aviso por vulnerabilidad

La recomendación es enviar un solo correo por vulnerabilidad, con la lista de los activos que alcanza. Hoy el flujo envía uno por par (sección 3.11). El 9 de septiembre, la vulnerabilidad CVE-2026-85880 de Windows produjo nueve correos, uno por activo (sección 5.6). Agrupados por vulnerabilidad, los 17 correos de la campaña habrían sido nueve.

La decisión se seguiría tomando par por par, porque el índice depende de la criticidad y la exposición de cada activo, y una misma vulnerabilidad puede notificar en unos y no en otros. El correo reuniría los pares de esa vulnerabilidad que cruzaron el umbral en la corrida. El cuerpo ya presenta los datos del par en una tabla (sección 3.11), de modo que alcanza con una fila por activo, ordenadas por índice, y con la prioridad más alta del grupo en el asunto. En un inventario de mayor escala, el cambio evita la avalancha de mensajes que anticipa la sección 3.11.

7.4 Líneas de trabajo futuro

Esta sección reúne las líneas de trabajo que van más allá de las secciones anteriores. Las recomendaciones de las secciones 7.1 a 7.3 modifican el flujo dentro de su diseño actual; las que siguen exigen probar un diseño alternativo, integrar una herramienta externa o volver a medir. Una queda fuera aun de ellas. La sección 1.7 excluye la remediación activa, y el trabajo no reunió evidencia para recomendarla. Instalar parches de forma automática supone que la correlación es correcta, y ocho de las 17 notificaciones de la campaña correspondían a correlaciones falsas (sección 5.6). Antes de automatizar la respuesta, la correlación que la dispararía tiene que ser confiable.

7.4.1 Probar un árbol de decisión como alternativa al índice

La recomendación es probar un árbol de decisión como alternativa al índice. El apartado 7.3.1 saca la probabilidad de explotación del índice sin repartir su peso, porque cualquier reparto cambia qué pares notifican. Un árbol como el del modelo SSVC es otra manera de resolver la prioridad: combina valores discretos en lugar de sumar puntajes (Spring et al., 2021), y en él se inspira la tabla de plazos de la directiva 26-04 de CISA (sección 2.4). La prueba consiste en aplicar los dos sobre el mismo inventario y comparar qué pares notifica cada uno.

El insumo de explotación ya está disponible. Junto a la pertenencia al catálogo de CISA, que el índice usa con dos valores, la base guarda el punto de decisión de tres niveles que CISA publica bajo ese modelo: sin evidencia, prueba de concepto pública y explotación activa (Anexo C). Medir qué cambiaría con los tres niveles no requiere modificar el flujo, porque el dato se guardó durante la campaña, y es el primer paso de la prueba. La severidad entraría como impacto técnico, que la directiva describe como análogo al puntaje CVSS (sección 2.4). Para ese puntaje, el flujo ya lee la versión 4.0 cuando el registro no trae la 3.x (sección 3.5). La comparación completa requiere una campaña propia (apartado 7.4.4).

7.4.2 Integrar una herramienta de inventario automático

La recomendación es que el inventario lo provea una herramienta que releve los activos de forma automática. Es la integración que anticipa el apartado 7.2.1: los componentes de cada activo, su configuración y la compilación exacta de Windows cambian con cada instalación y cada ciclo de parches, y mantenerlos a mano no es viable fuera de un entorno simulado. La integración cambia la fuente del inventario y no el flujo, que seguiría leyendo la misma tabla de activos.

Dos condiciones la acotan. La herramienta tiene que registrar los productos con el nombre o el identificador con que los publican sus fabricantes; si no, el relevamiento del apartado 7.2.2 sigue siendo necesario. Y un inventario que cambia entre corridas obliga a decidir qué ocurre con los pares de un activo que se actualizó o se retiró, una cuestión que el inventario fijo de la campaña no planteó.

7.4.3 Observar la exposición en lugar de declararla

La recomendación es obtener la exposición a Internet de cada activo de una fuente de observación externa, en lugar de declararla en el inventario. En la campaña fue un atributo fijo, cargado a mano (sección 1.7), y es el peso del índice con menos respaldo en la literatura revisada (sección 3.6). Pesa, además, en las decisiones: sin explotación confirmada, ningún activo sin exposición puede notificar (apartado 5.3.4). Un servicio que indexa los equipos visibles desde Internet, como Shodan (Shodan, s. f.), permitiría comprobar si un activo declarado como interno responde desde afuera, y al revés. Otras fuentes de inteligencia, como las plataformas de intercambio de indicadores del tipo de MISP (Wagner et al., 2016), podrían sumarse por la misma vía. El trabajo no midió qué agregarían.

7.4.4 Repetir la medición sobre una campaña más larga

La recomendación es repetir la medición, con los mismos instrumentos, sobre una campaña más larga y con el flujo corregido. Cuatro semanas y 17 notificaciones no alcanzaron para juzgar el canal de alertas ni el aporte de la probabilidad de explotación como anticipo (sección 6.3), y el valor de 0,04 del apartado 7.3.1 necesita un período con probabilidades más altas. La misma campaña mediría las recomendaciones de este capítulo, que no se implementaron: la cobertura de la vía de la CNA, la precisión de la comparación de nombres y la recuperación por consulta de modificación. La reevaluación diferida y las revisiones de muestra del Capítulo 5 sirven como instrumentos sin cambios. Sobre un inventario con otros fabricantes, la medición pondría a prueba la tercera conclusión de la sección 6.3: que la precisión de la inferencia depende de cómo nombran sus productos los fabricantes.

Capítulo 8: Referencias

Ahmadi Mehri, V., Arlos, P., & Casalicchio, E. (2022). Automated context-aware vulnerability risk management for patch prioritization. *Electronics*, *11*(21), 3580. https://doi.org/10.3390/electronics11213580

Alahmadi, B. A., Axon, L., & Martinovic, I. (2022). 99% false positives: A qualitative study of SOC analysts' perspectives on security alarms. *Proceedings of the 31st USENIX Security Symposium (USENIX Security '22)*, 2783–2800. https://www.usenix.org/conference/usenixsecurity22/presentation/alahmadi

Allodi, L., & Massacci, F. (2014). Comparing vulnerability severity and exploits using case-control studies. *ACM Transactions on Information and System Security*, *17*(1), 1–20. https://doi.org/10.1145/2630069

Anwar, A., Abusnaina, A., Chen, S., Li, F., & Mohaisen, D. (2022). Cleaning the NVD: Comprehensive quality assessment, improvements, and analyses. *IEEE Transactions on Dependable and Secure Computing*, *19*(6), 4255–4269. https://doi.org/10.1109/TDSC.2021.3125270

AXELOS. (2019). *ITIL Foundation: ITIL 4 Edition*. The Stationery Office.

Baines, J. (2024, noviembre 14). *Outpacing NIST NVD with VulnCheck NVD++*. VulnCheck Blog. https://www.vulncheck.com/blog/outpacing-nvd-cpe

Center for Internet Security. (2024). *CIS Critical Security Controls, Version 8.1*. https://www.cisecurity.org/controls/v8-1

Cheikes, B. A., Waltermire, D., & Scarfone, K. (2011). *Common Platform Enumeration: Naming Specification Version 2.3* (NIST IR 7695). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.IR.7695

Christen, P. (2012). *Data Matching: Concepts and Techniques for Record Linkage, Entity Resolution, and Duplicate Detection*. Springer. https://doi.org/10.1007/978-3-642-31164-2

Clopper, C. J., & Pearson, E. S. (1934). The use of confidence or fiducial limits illustrated in the case of the binomial. *Biometrika*, *26*(4), 404–413. https://doi.org/10.1093/biomet/26.4.404

Cohen, J. (1960). A coefficient of agreement for nominal scales. *Educational and Psychological Measurement*, *20*(1), 37–46. https://doi.org/10.1177/001316446002000104

CVE Program. (s. f.). *cvelistV5: CVE cache of the official CVE List in CVE JSON 5 format*. Recuperado 20 de octubre de 2026, de https://github.com/CVEProject/cvelistV5

CVE Program. (2025). *CVE Record Format version 5.2.0*. https://github.com/CVEProject/cve-schema/releases/tag/v5.2.0

Cyber Safety Review Board. (2022). *Review of the December 2021 Log4j event*. Cybersecurity and Infrastructure Security Agency. https://www.cisa.gov/sites/default/files/publications/CSRB-Report-on-Log4-July-11-2022_508.pdf

Cybersecurity and Infrastructure Security Agency. (2019). *Binding Operational Directive 19-02: Vulnerability remediation requirements for internet-accessible systems*. https://www.cisa.gov/news-events/directives/bod-19-02-vulnerability-remediation-requirements--internet-accessible-systems-revoked

Cybersecurity and Infrastructure Security Agency. (2024). *Known Exploited Vulnerabilities Catalog*. U.S. Department of Homeland Security. https://www.cisa.gov/known-exploited-vulnerabilities--catalog

Cybersecurity and Infrastructure Security Agency. (2026a). *Vulnrichment: A repo to conduct vulnerability enrichment*. https://github.com/cisagov/vulnrichment

Cybersecurity and Infrastructure Security Agency. (2026b). *Binding Operational Directive 26-04: Prioritizing security updates based on risk*. https://www.cisa.gov/news-events/directives/bod-26-04--prioritizing-security-updates-based-risk

Cybersecurity and Infrastructure Security Agency. (2026c). *BOD 26-04: Implementation guidance for prioritizing security updates based on risk*. https://www.cisa.gov/news-events/directives/bod-26-04--implementation-guidance-prioritizing-security-updates-based-risk

Dissanayake, N., Jayatilaka, A., Zahedi, M., & Babar, M. A. (2022). An empirical study of automation in software security patch management. *Proceedings of the 37th IEEE/ACM International Conference on Automated Software Engineering (ASE '22)*, 1–13. https://doi.org/10.1145/3551349.3556969

Docker Inc. (s. f.). *Docker Documentation*. Recuperado 20 de octubre de 2026, de https://docs.docker.com/

Dong, Y., Guo, W., Chen, Y., Xing, X., Zhang, Y., & Wang, G. (2019). Towards the detection of inconsistencies in public security vulnerability reports. *Proceedings of the 28th USENIX Security Symposium*, 869–885. https://www.usenix.org/conference/usenixsecurity19/presentation/dong

Forum of Incident Response and Security Teams. (s. f.). *Using the Exploit Prediction Scoring System (EPSS)*. Recuperado 20 de septiembre de 2026, de https://www.first.org/epss/using-epss

Forum of Incident Response and Security Teams. (2026a). *FIRST.Org API v1 documentation*. https://api.first.org/

Forum of Incident Response and Security Teams. (2026b). *Get the Data*. https://www.first.org/epss/data

Hernández Sampieri, R., Fernández Collado, C., & Baptista Lucio, M. P. (2014). *Metodología de la investigación* (6.ª ed.). McGraw-Hill.

International Organization for Standardization, & International Electrotechnical Commission. (2022). *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. ISO. https://www.iso.org/standard/27001

Islam, C., Babar, M. A., & Nepal, S. (2019). A multi-vocal review of security orchestration. *ACM Computing Surveys*, *52*(2), 1–45. https://doi.org/10.1145/3305268

Jacobs, J., Romanosky, S., Edwards, B., Adjerid, I., & Roytman, M. (2021). Exploit Prediction Scoring System (EPSS). *Digital Threats: Research and Practice*, *2*(3), 1–17. https://doi.org/10.1145/3436242

Jiang, Y., Shang, F., Tan Wei You, F., Wang, H., Cong, C. R., Meng, Q., Oo, N., Lim, H. W., & Sikdar, B. (2025). *VulCPE: Context-Aware Cybersecurity Vulnerability Retrieval and Management*. arXiv preprint arXiv:2505.13895. https://doi.org/10.48550/arXiv.2505.13895

Joint Task Force Transformation Initiative. (2012). *Guide for conducting risk assessments* (NIST Special Publication 800-30 Rev. 1). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-30r1

Kaplan, E. L., & Meier, P. (1958). Nonparametric Estimation from Incomplete Observations. *Journal of the American Statistical Association*, *53*(282), 457–481. https://doi.org/10.1080/01621459.1958.10501452

Korn, E. L., & Graubard, B. I. (1998). Confidence intervals for proportions with small expected number of positive counts estimated from survey data. *Survey Methodology*, *24*(2), 193–201.

Meta Platforms, Inc. (s. f.). *React: The library for web and native user interfaces*. Recuperado 20 de octubre de 2026, de https://react.dev/

n8n GmbH. (2025). *n8n Docs*. https://docs.n8n.io/

National Institute of Standards and Technology. (s. f.-a). *National Vulnerability Database (NVD) API 2.0 documentation*. Recuperado 20 de octubre de 2026, de https://nvd.nist.gov/developers/vulnerabilities

National Institute of Standards and Technology. (s. f.-b). *Official Common Platform Enumeration (CPE) Dictionary*. Recuperado 19 de octubre de 2026, de https://nvd.nist.gov/products/cpe

National Institute of Standards and Technology. (2025). *NVD API: Getting Started*. https://nvd.nist.gov/developers/start-here

National Institute of Standards and Technology. (2026). *NIST updates NVD operations to address record CVE growth*. https://www.nist.gov/news-events/news/2026/04/nist-updates-nvd-operations-address-record-cve-growth

Nguyen, V. H., & Massacci, F. (2013). The (un)reliability of NVD vulnerable versions data: An empirical experiment on Google Chrome vulnerabilities. *Proceedings of the 8th ACM SIGSAC Symposium on Information, Computer and Communications Security (ASIACCS '13)*, 493–498. https://doi.org/10.1145/2484313.2484377

OWASP Dependency-Track. (s. f.). *Known vulnerability analysis*. Recuperado 17 de septiembre de 2026, de https://docs.dependencytrack.org/analysis-types/known-vulnerabilities/

Pashchenko, I., Plate, H., Ponta, S. E., Sabetta, A., & Massacci, F. (2018). Vulnerable open source dependencies: Counting those that matter. *Proceedings of the 12th ACM/IEEE International Symposium on Empirical Software Engineering and Measurement (ESEM '18)*, 1–10. https://doi.org/10.1145/3239235.3268920

PostgreSQL Global Development Group. (s. f.). *PostgreSQL 16 documentation*. Recuperado 20 de octubre de 2026, de https://www.postgresql.org/docs/16/

Ramírez, S. (s. f.). *FastAPI framework, high performance, easy to learn, fast to code, ready for production*. Recuperado 20 de septiembre de 2026, de https://fastapi.tiangolo.com/

Sanguino, L. A. B., & Uetz, R. (2017). *Software Vulnerability Analysis Using CPE and CVE*. arXiv preprint arXiv:1705.05347. https://doi.org/10.48550/arXiv.1705.05347

Segal, C. M. D., Segal, P. M. D., Banjar, C. E. de S., Paixão, F. de S., Borges, H., Neto, P. S., Santana de Almeida, E., Santos, J. C. S., Kocheturov, A., Srivastava, G. K., & Menasché, D. S. (2026). Characterizing and modeling the GitHub security advisories review pipeline. *Proceedings of the 23rd International Conference on Mining Software Repositories (MSR '26)*, 311–322. https://doi.org/10.1145/3793302.3793360

Shimizu, N., & Hashimoto, M. (2026). Vulnerability management chaining: An integrated framework for efficient cybersecurity risk prioritization. *IEEE Access*, *14*, 31407–31424. https://doi.org/10.1109/ACCESS.2026.3665768

Shodan. (s. f.). *Shodan search engine*. Recuperado 20 de octubre de 2026, de https://www.shodan.io/

Souppaya, M., & Scarfone, K. (2022). *Guide to enterprise patch management planning: Preventive maintenance for technology (NIST Special Publication 800-40 Rev. 4)*. National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-40r4

Spring, J. M., Householder, A. D., Hatleback, E., Manion, A., Oliver, M., Sarvepalli, V. S., Tyzenhaus, L., & Yarbrough, C. G. (2021). *Prioritizing vulnerability response: A stakeholder-specific vulnerability categorization (Version 2.0)*. Carnegie Mellon University, Software Engineering Institute. https://www.sei.cmu.edu/library/prioritizing-vulnerability-response-a-stakeholder-specific--vulnerability-categorization-version-20/

Stake, R. E. (1995). *The art of case study research*. Sage.

Tailwind Labs, Inc. (s. f.). *Tailwind CSS: A utility-first CSS framework*. Recuperado 20 de octubre de 2026, de https://tailwindcss.com/

Triantaphyllou, E. (2000). *Multi-criteria decision making methods: A comparative study* (Vol. 44). Springer. https://doi.org/10.1007/978-1-4757-3157-6

Uchakin, D. (2026, abril 19). *Your asset inventory doesn't wait for NVD*. Vulners Blog. https://vulners.com/blog/cve_affected_configurations_april_2026/

U.S. Department of Commerce, Office of Inspector General. (2026). *Evaluation of NIST's management of the National Vulnerability Database* (OIG-26-020-I). U.S. Department of Commerce. https://www.oig.doc.gov/wp-content/OIGPublications/OIG-26-020-I-SECURED.pdf

VoidZero Inc., & Vite contributors. (s. f.). *Vite: The build tool for the web*. Recuperado 20 de septiembre de 2026, de https://vite.dev/

Wagner, C., Dulaunoy, A., Wagener, G., & Iklody, A. (2016). MISP: The design and implementation of a collaborative threat intelligence sharing platform. *Proceedings of the 2016 ACM on Workshop on Information Sharing and Collaborative Security*, 49–56. https://doi.org/10.1145/2994539.2994542

Wåreus, E., & Hell, M. (2020). Automated CPE labeling of CVE summaries with machine learning. *Detection of Intrusions and Malware, and Vulnerability Assessment (DIMVA 2020), Lecture Notes in Computer Science*, *12223*, 3–22. https://doi.org/10.1007/978-3-030-52683-2_1

Zhang, S., Massacci, F., & Zhang, M. (2026). *The cathedral and the bazaar of software vulnerabilities: From the NVD to the CNAs*. arXiv preprint arXiv:2607.05670. https://doi.org/10.48550/arXiv.2607.05670

Capítulo 9: Anexos

Este capítulo reúne el material complementario que respalda la ejecución técnica del trabajo. El Anexo A documenta el diagnóstico previo sobre el inventario, cuyos resultados motivaron la corrección de los identificadores de plataforma y la reestructuración del flujo. El Anexo B describe el paquete de reproducibilidad: los archivos que permiten reconstruir el entorno, el procedimiento de despliegue y las credenciales que hay que crear, incluida la clave de la interfaz de la NVD. El Anexo C contiene el diccionario de datos del esquema relacional, columna por columna, con sus restricciones de dominio y sus índices. El Anexo D documenta el período de estabilización previo a la apertura de la recolección y delimita qué filas de la base provienen de él. El Anexo E presenta la revisión completa de la vía formal, que sirve de contraste para los errores de la vía de inferencia.

Anexo A. Diagnóstico previo del inventario (mayo a julio de 2026)

Antes de iniciar la campaña de recolección se ejecutó un diagnóstico sobre el inventario simulado, con el fin de comprobar si los identificadores CPE asignados a cada activo recuperaban efectivamente las vulnerabilidades que les correspondían. El diagnóstico se resolvió sobre una copia local del repositorio público de registros CVE, sin consultar la interfaz de la NVD, y abarcó los 23.144 registros publicados entre el 1 de mayo y el 31 de julio de 2026.

El diagnóstico detectó ocho identificadores defectuosos sobre los veinte productos del inventario, que afectaban a trece de los treinta activos. Cuatro estaban deprecados en el diccionario oficial del NIST, que declaraba su reemplazo, y cuatro no existían en él. Cinco de los ocho correspondían a productos de Microsoft, y la corrección de su nomenclatura llevó de cero a 1.766 las correlaciones que esos productos obtienen por el identificador que la propia CNA declara dentro del registro. Esa medición se resuelve por completo sobre el corpus local, sin intervención de la API, de manera que la corrección de nomenclatura es su única causa posible. Los ocho se corrigieron en la base y en el archivo de inicialización del esquema antes de comenzar la recolección.

El mismo diagnóstico permitió establecer con qué regularidad los fabricantes del inventario publican identificadores CPE en los registros que emiten. Seis de los veinte productos, pertenecientes a tres fabricantes, reciben ese dato de su propio fabricante de manera sistemática; los catorce restantes no lo reciben, o lo reciben de forma marginal. Esa desigualdad explica por qué la cobertura de correlación no puede leerse como una cifra única del sistema, y motiva que el Capítulo 5 la reporte desagregada por activo.

Una medición anterior del mismo diagnóstico quedó invalidada y no se utiliza en ningún punto de este trabajo: entre aquella ejecución y la vigente se modificaron simultáneamente la nomenclatura del inventario y el parámetro empleado para consultar la fuente, de modo que sus resultados no permiten atribuir la diferencia a ninguna de las dos causas por separado.

Una verificación posterior, del 5 de octubre de 2026, estableció cómo trataba la versión la consulta del diseño anterior, que pedía a la NVD las vulnerabilidades de cada identificador completo del inventario. Para los catorce identificadores que declaran versión y obtuvieron resultados, la interfaz

devolvió 4.859 registros, y los 4.859 coinciden con los que predicen los rangos de versión declarados en cada uno: la versión dejó fuera 24.138 de los 28.997 registros que mencionan esos productos. Los cinco identificadores de Windows no declaran versión en el inventario, de modo que la consulta no filtraba por ella, y el de Confluence no devolvió resultados porque el producto figura con otro nombre en el diccionario. No es uno de los ocho identificadores corregidos: el fabricante y el producto sí aparecen en los registros, y lo que falta en el diccionario es el nombre completo con la versión, que solo pedía esa consulta. En la campaña no tuvo efecto, porque las dos vulnerabilidades de Confluence seguían sin análisis de la NVD al cierre. La consulta tampoco distinguía el producto vulnerable de la plataforma: doce de los veinte identificadores recibían registros en los que figuraban solo como plataforma.

Anexo B. Paquete de reproducibilidad

El entorno de la Prueba de Concepto se reconstruye a partir de ocho archivos, agrupados en la carpeta `replication` del repositorio público https://github.com/lorenzoespetxe-wq/Thesis-Document--and-Replication-Package, en la versión del commit `6ee4e05`. Tres definen la infraestructura, uno declara las variables de entorno que esa infraestructura exige, tres contienen la topología de los flujos exportada desde el orquestador y uno conserva el esquema de la base tal como quedó en operación. La misma carpeta incluye lo necesario para volver a calcular las cifras del Capítulo 5: un volcado de la base con los datos de la campaña y los scripts de análisis con sus insumos. Ninguno incluye credenciales: los valores empleados durante la campaña no se publican, y el archivo de variables se entrega como plantilla con los nombres y sin los datos.

Tabla B1

Contenido del paquete de reproducibilidad

Archivo	Qué contiene
`docker-compose.yml`	Definición de los tres servicios del entorno —base de datos, orquestador e interfaz de administración —, la red aislada que los comunica, los volúmenes que persisten sus datos y la condición de arranque que subordina el orquestador a la disponibilidad de la base
`init-db.sh`	Crea la base de investigación `secops_research_db` en el primer arranque del contenedor y ejecuta sobre ella el archivo siguiente. Reside en un archivo propio porque el mecanismo de inicialización de PostgreSQL no admite la creación de bases dentro de un bloque de transacción implícita
`init-db.sql`	Definición completa del esquema —las cinco tablas, sus restricciones y sus índices— y población de la escala de criticidad y del inventario de treinta activos
`.env.example`	Nombres de las diez variables de entorno que exige el archivo de composición, con instrucciones y sin valores reales
`n8n_workflows/Refactored Workflow 1.3(After Patch Tuesday).json`	Artefacto de la campaña, exportado en la versión con que se cerró la recolección. Contiene veintiocho nodos: los diecisiete del flujo periódico y los once del circuito de reprocesamiento bajo demanda, que durante la recolección compartió el lienzo sin ser invocado
`n8n_workflows/Workflow de Reevaluación Diferida 1.1.json`	Flujo de disparo manual que recalcula el índice con información madura, descrito en la Fase 7 de la sección 3.12
`n8n_workflows/Webhook Workflow.json`	Circuito de reprocesamiento bajo demanda en la versión que invoca la capa de presentación. Se modificó el 25 de octubre de 2026, después del cierre, para que registre cada reproceso en la tabla de auditoría en lugar de reescribir el estado, la fecha de alerta y el identificador del mensaje del par. La versión que acompañó la recolección es la que figura dentro del artefacto de la campaña. Importar los dos archivos en la misma instancia duplica el circuito
`database/esquema_secops_research_db.sql`	Volcado del esquema de la base de investigación, sin datos, tomado de la base en operación el 19 de octubre de 2026. Coincide con `init-db.sql` en sus cinco tablas y sus cincuenta y cuatro columnas, y permite comprobar que el esquema publicado es el que corrió
`database/secops_research_db_campana.sql`	Volcado completo de la base de investigación, con los datos de la campaña, tomado el 20 de octubre de 2026: las 3.883 filas de telemetría, el inventario, la auditoría y la serie diaria de la probabilidad de explotación. No contiene direcciones de correo ni credenciales
`analisis/`	Scripts que producen las cifras del Capítulo 5, con las descargas de la NVD y de FIRST que leen y las salidas que generan. Corren sin cambios desde esa carpeta; su archivo `README.md` indica las condiciones para ejecutarlos

Nota. Contenido del paquete de reproducibilidad. Los tres archivos de infraestructura deben permanecer en la misma carpeta, porque el archivo de composición monta los dos scripts de inicialización por ruta relativa. Los comentarios que el esquema conserva en `init-db.sql` *y en el volcado corresponden a una versión anterior de este documento: remiten a otra numeración de secciones y presentan la tabla de telemetría como fuente para medir el tiempo medio de detección, que la sección 3.12 explica por qué no se reporta según su definición original. El archivo incorpora los cambios posteriores a la primera inicialización —la corrección de identificadores de agosto de 2026 y las estructuras del 1 de septiembre—, de modo que refleja el esquema final y no el inicial. La carpeta de análisis no incluye la copia del corpus público de registros CVE con que se leyó el dato de la CNA, por su tamaño: se obtiene del repositorio del programa CVE, en su versión del 27 de septiembre de 2026. Fuente: carpeta de reproducibilidad, en la versión citada.*

Procedimiento de despliegue

El entorno se levanta en cuatro pasos. Primero se copia `.env.example` como `.env` en la misma carpeta y se completan sus valores: el usuario y la contraseña de la base, los dos secretos que el orquestador emplea para cifrar credenciales y firmar sesiones, y las credenciales de acceso a la interfaz de administración. Los dos secretos del orquestador deben generarse como cadenas aleatorias largas, y la variable que gobierna la poda del historial de ejecuciones debe quedar en falso para conservar el registro completo de las corridas, que es la fuente de varias de las cifras que reporta este trabajo.

Segundo, se ejecuta la composición desde esa carpeta. En el primer arranque, el script de inicialización crea la base de investigación y aplica el esquema con el inventario ya poblado; en los arranques siguientes no vuelve a ejecutarse, porque el volumen de datos ya existe.

Tercero, se importan los flujos desde la interfaz del orquestador, disponible en el puerto 5678 del equipo anfitrión. Para reproducir la campaña alcanza con el artefacto de la campaña y el flujo de reevaluación diferida.

Cuarto, se crean las tres credenciales que los flujos referencian por nombre. La de PostgreSQL apunta al servicio `db` en el puerto 5432, sobre la base `secops_research_db`, con el usuario declarado en el archivo de variables; la resolución del nombre `db` funciona porque ambos contenedores comparten la red definida en el archivo de composición. La de correo es una credencial OAuth2 de Gmail, y el destinatario de las alertas, que en los archivos publicados figura como una dirección de ejemplo, debe reemplazarse en los dos nodos de envío. La tercera es la clave de la interfaz de la NVD, que se describe a continuación.

Clave de la interfaz de la NVD

La interfaz v2.0 de la NVD admite consultas sin autenticación, pero con un límite de cinco peticiones cada treinta segundos en ventana móvil. El registro de una clave eleva ese límite a cincuenta, y es la condición práctica para sostener una ingesta diaria que recorre la respuesta por páginas. La clave se solicita al NIST desde el formulario público del organismo, que la remite por correo electrónico a la dirección declarada, y no tiene costo (National Institute of Standards and Technology, 2025).

En el orquestador la clave se declara como una credencial de autenticación por encabezado, con el nombre `apiKey` y el valor recibido. Los flujos la referencian por el nombre de la credencial y no por su valor, de modo que la exportación puede publicarse sin exponerla. Esa credencial la consumen los nodos que consultan a la NVD en el flujo periódico, en el de reevaluación diferida y en el circuito bajo demanda.

Elevar el límite documentado no agota las restricciones que la fuente impone. Como registra la sección 3.9, el servicio de mitigación de automatismos que la NVD mantiene delante de su interfaz se activa por volumen sostenido aun operando por debajo del techo publicado, de modo que una implementación que reproduzca este trabajo necesita conservar el intervalo entre peticiones y el reintento automático que los flujos incorporan.

Anexo C. Diccionario de datos del esquema relacional

Este anexo detalla las cincuenta y cuatro columnas de las cinco tablas que componen la base de investigación, en el orden en que residen en el esquema. La sección 4.2 describe el papel de cada tabla dentro del sistema y agrupa las columnas de la tabla central en siete conjuntos; aquí se documenta cada una con su tipo, su admisión de nulos y lo que registra. La definición ejecutable está en `init-db.sql`, incluido en el paquete de reproducibilidad del Anexo B.

Once columnas del esquema se declaran como marcas temporales sin huso horario y almacenan tiempo universal coordinado, conforme al criterio único que fija la sección 3.8: ninguna guarda hora local. Dos más registran una fecha de calendario sin hora —la del ingreso al catálogo de explotación conocida y la de la serie diaria de probabilidad— y quedan fuera de ese criterio, porque no expresan un instante sino un día. La conversión a tiempo universal aparece una sola vez en el esquema, en el valor predeterminado de la marca de captura de la serie diaria; las demás marcas llegan ya expresadas en ese huso.

Tabla C1

Escala de criticidad (`criticidad_niveles`)

Columna	Tipo	Admite nulos	Qué registra
`id`	entero	no	Identificador del nivel, entero de 1 a 4 en orden ascendente de criticidad.
`nombre`	texto (20)	no	Etiqueta del nivel: baja, media, alta o crítica. Restringida a valores únicos.
`descripcion`	texto	sí	Texto que fija el criterio de asignación del nivel.
`peso_normalizacion`	numérico (5,4)	sí	Peso del componente de criticidad del índice. Columna generada y almacenada: el motor la calcula como el identificador dividido por cuatro, lo que produce 0,25, 0,50, 0,75 y 1,00.

Tabla C2

Inventario de activos (`activos`)

Columna	Tipo	Admite nulos	Qué registra
`id`	entero	no	Identificador interno del activo, asignado por secuencia.
`hostname`	texto (100)	no	Nombre de equipo del activo simulado.
`alias`	texto (200)	sí	Etiqueta descriptiva de la función que cumple el activo en el entorno.
`cpe`	texto (255)	no	Identificador normalizado de plataforma, almacenado con los once atributos del estándar, que con el prefijo `cpe:2.3` suman trece campos. Lleva índice propio.
`criticidad_id`	entero	no	Clave foránea hacia la escala de criticidad. Impide registrar un nivel inexistente.
`exposicion_internet`	booleano	no	Estado de exposición del activo. Atributo estático del entorno simulado, no producto de un escaneo.
`created_at`	marca temporal	sí	Momento de creación de la fila. La escribe la inicialización del esquema.

Tabla C3

Telemetría de vulnerabilidades (`telemetria_vulnerabilidades`)

Columna	Tipo	Admite nulos	Qué registra
`id`	entero	no	Identificador interno de la fila, asignado por secuencia.
`cve_id`	texto (20)	no	Identificador de la vulnerabilidad en el catálogo CVE.
`activo_id`	entero	no	Clave foránea hacia el inventario. Junto con el identificador de la vulnerabilidad forma la clave única que hace del par la unidad de registro.
`cvss_score`	numérico (4,2)	sí	Puntaje de severidad publicado por la fuente en el momento de la detección.
`epss_score`	numérico (5,4)	sí	Probabilidad estimada de explotación en el momento de la detección. Cuatro decimales, de modo que un valor real inferior a 0,00005 queda registrado como cero.
`kev_status`	booleano	sí	Pertenencia al catálogo de explotación conocida de CISA en el momento de la detección.
`irc_score`	numérico (5,4)	sí	Índice de Riesgo Compuesto calculado en la detección, según la función de la sección 3.6.
`prioridad`	texto (20)	sí	Categoría asignada a partir del índice.
`fecha_publicacion_nvd`	marca temporal	no	Fecha de publicación de la vulnerabilidad declarada por la fuente.
`fecha_ingesta_pipeline`	marca temporal	sí	Momento en que el flujo ingirió el registro. La escribe el orquestador.
`fecha_alerta_generada`	marca temporal	sí	Momento en que se cerró el procesamiento del par, haya derivado o no en notificación.

Columna	Tipo	Admite nulos	Qué registra
`message_id`	texto (255)	sí	Identificador del mensaje de correo emitido, cuando el par superó el umbral de notificación.
`cve_description`	texto	sí	Descripción oficial publicada por la fuente.
`nvd_url`	texto (512)	sí	Enlace al registro completo de la vulnerabilidad.
`epss_url`	texto (512)	sí	Enlace a la consulta de probabilidad de explotación.
`fecha_hitl_update`	marca temporal	sí	Marca de la última transición de estado fijada por el analista.
`fecha_actualizacion_datos`	marca temporal	sí	Marca que deja la reevaluación diferida al actualizar la fila. Es la única columna original que ese flujo modifica.
`estado`	texto (30)	no	Estado del hallazgo. Arranca en «detectada» y recorre las transiciones descritas en la sección 2.5.
`fuente_correlacion`	texto (20)	sí	Vía por la que se estableció la correlación en la detección. Conserva el significado de fuente de detección inicial y no se sobrescribe.
`nivel_confianza`	texto (10)	sí	Garantía que corresponde a esa vía: formal cuando el identificador lo publica el NIST, inferida cuando resulta de la comparación de nombres.
`fecha_modificacion_nvd`	marca temporal	sí	Fecha de última modificación que la fuente declaraba al ingerir el registro.
`ssvc_exploitation`	texto (10)	sí	Punto de decisión sobre explotación que publica CISA. Se persiste y no entra en el cálculo del índice.
`fuente_correlacion_final`	texto (20)	sí	Vía formal que confirmó después una correlación establecida por inferencia. Excluye la vía de inferencia, de modo que no puede registrar como confirmación la misma vía que se confirma.
`fecha_enriquecimiento_nvd`	marca temporal	sí	Fecha de última modificación que la fuente declaraba en el momento de esa confirmación.
`fecha_promocion_detectada`	marca temporal	sí	Momento en que el flujo advirtió la confirmación.
`irc_score_final`	numérico (5,4)	sí	Índice recalculado con información madura por la reevaluación diferida.
`epss_score_final`	numérico (5,4)	sí	Probabilidad estimada de explotación al cierre.
`cvss_score_final`	numérico (4,2)	sí	Puntaje de severidad al cierre.
`kev_status_final`	booleano	sí	Pertenencia al catálogo de explotación conocida al cierre.
`kev_fecha_agregado`	fecha	sí	Fecha en que CISA incorporó la vulnerabilidad a su catálogo, cuando corresponde.
`ssvc_exploitation_final`	texto (10)	sí	Punto de decisión sobre explotación al cierre.

Tabla C4

Auditoría de acciones (`auditoria_acciones`)

Columna	Tipo	Admite nulos	Qué registra
`id`	entero	no	Identificador interno de la fila, asignado por secuencia.
`accion`	texto (50)	no	Tipo de acción registrada. El flujo diario escribe la ingesta de la ventana; la capa de presentación escribe la transición de estado que fija el analista y el reenvío de una alerta, y el circuito bajo demanda, el reproceso que ese reenvío dispara.
`tipo_entidad`	texto (50)	no	Tipo de entidad afectada: la ejecución en las filas que escribe el flujo diario, el par vulnerabilidad--activo en las demás.
`entidad_id`	entero	no	Identificador de esa entidad: el número de ejecución que asigna el orquestador, lo que permite empalmar cada fila con su corrida, o el identificador de la fila de telemetría sobre la que actuó el analista.
`timestamp`	marca temporal	no	Momento del registro, con valor predeterminado tomado del reloj del motor.
`metadata_json`	documento JSON	sí	Documento con los datos del caso, cuyas claves se detallan más abajo.

Tabla C5

Serie diaria de probabilidad de explotación (`epss_serie_diaria`)

Columna	Tipo	Admite nulos	Qué registra
`id`	entero	no	Identificador interno de la fila, asignado por secuencia.
`cve_id`	texto (20)	no	Identificador de la vulnerabilidad.
`fecha`	fecha	no	Fecha a la que corresponde el valor. Junto con el identificador forma una clave única que impide duplicar una fecha ya capturada.
`epss_score`	numérico (6,5)	sí	Probabilidad estimada de explotación de esa fecha, con cinco decimales: conserva la precisión completa de la fuente.
`epss_percentil`	numérico (6,5)	sí	Percentil que la fuente asigna a ese valor dentro del conjunto publicado.
`fecha_captura`	marca temporal	no	Momento en que la fila se escribió, convertido explícitamente a tiempo universal coordinado.

Nota. Diccionario de las cinco tablas del esquema `secops_research_db`. La columna «Tipo» traduce la declaración de PostgreSQL: el paréntesis indica la longitud máxima en las columnas de texto y la precisión y escala en las numéricas. Fuente: catálogo del sistema de la base en operación, contrastado contra `init-db.sql`.

Estructura del documento de auditoría

La columna que cierra la tabla de auditoría almacena un documento JSON con los conteos de cada corrida. Sus claves son las siguientes: el número de vulnerabilidades recibidas efectivamente y el de vulnerabilidades ingeridas; la cantidad de páginas que llegaron y el testigo booleano de truncamiento, que indica si la respuesta quedó incompleta por haber superado el techo de la

interfaz; el número de vulnerabilidades distintas que correlacionaron y el número de pares que produjeron; cuatro contadores, uno por cada vía de correlación declarada, y la lista ordenada de los identificadores correlacionados. La lista guarda solo las vulnerabilidades que la corrida correlacionó y no todas las que ingirió; las ingeridas se reconstruyen según indica la sección 3.8.

De esos cuatro contadores, el artefacto solo alimenta dos: el de la vía formal, que registra las correlaciones resueltas con el identificador que publica el NIST, y el de la vía de inferencia. Los dos restantes —el identificador que declara la CNA dentro del registro y el que puede aportar CISA— permanecen en cero a lo largo de toda la campaña, porque, como expone la sección 3.10, esos datos no llegan a través de la interfaz de la NVD. Su presencia en el documento responde al dominio de cuatro valores que admite la columna de procedencia, no a una medición.

Los conteos por vía y el conteo total se calculan de manera independiente, según detalla la sección 4.2, de modo que su suma superaría al total en una corrida donde una misma vulnerabilidad alcanzara activos por las dos vías. Ninguna fila de la tabla registra ese caso.

La capa de presentación escribe en esa misma tabla dos acciones propias, con una estructura distinta. La transición de estado registra el estado anterior y el nuevo, de modo que el recorrido de la decisión humana queda reconstruible según describe la sección 2.5. El reenvío de una alerta registra la categoría de prioridad del hallazgo, un identificador propio del reenvío y su fecha. Cuando la capa está conectada al orquestador, el reenvío dispara el circuito bajo demanda, que deja una segunda fila con el índice recalculado, la categoría y el resultado del triaje y, si emitió el correo, el identificador del mensaje. Ninguna de estas acciones aparece entre las filas de la campaña, conforme al alcance que la sección 1.7 declara para esa capa.

Restricciones de dominio

Las restricciones de verificación acotan cada columna al rango o al conjunto de valores que le corresponde.

Tabla C6

Restricciones de verificación del esquema

Columna	Valores admitidos
`cvss_score`, `cvss_score_final`	Entre 0 y 10
`epss_score`, `epss_score_final`, `irc_score`, `irc_score_final`	Entre 0 y 1
`epss_serie_diaria.epss_score`, `epss_serie_diaria.epss_percentil`	Entre 0 y 1
`prioridad`	`CRITICA`, `ALTA`, `INFORMATIVA`
`estado`	`DETECTADA`, `NOTIFICADA`, `INFORMATIVA`, `EN_REVISION`, `REMEDIADA`, `DESCARTADA`
`fuente_correlacion`	`NVD`, `CNA`, `ADP`, `HEURISTICA`
`fuente_correlacion_final`	`NVD`, `CNA`, `ADP`
`nivel_confianza`	`FORMAL`, `INFERIDA`
`ssvc_exploitation`, `ssvc_exploitation_final`	`none`, `poc`, `active`

Nota. Restricciones de verificación del esquema. La columna que registra la confirmación formal posterior excluye el valor de inferencia, de modo que no puede registrar como confirmación la misma vía que se confirma. De los tres valores que sí admite, solo el del NIST resulta alcanzable a través de la interfaz que el artefacto consulta, por la razón que expone la sección 3.10; los otros dos permanecen en el dominio por simetría con la columna de procedencia original. El valor `INFORMATIVA` *figura en dos dominios distintos —prioridad y estado— y designa cosas distintas en cada uno, según declara la sección 1.7. Fuente: catálogo del sistema de la base en operación.*

A ellas se suman tres restricciones de integridad referencial y de unicidad. La tabla de inventario referencia la escala de criticidad, y la de telemetría referencia el inventario, de modo que no puede registrarse un par sobre un activo inexistente. La unicidad sobre el activo y la vulnerabilidad es la que hace del par la unidad de registro, y la unicidad sobre la vulnerabilidad y la fecha impide duplicar una fecha ya capturada en la serie diaria.

Índices

El esquema define once índices además de las claves primarias y de las restricciones de unicidad, que llevan el suyo propio. El inventario lleva uno sobre el identificador de plataforma. La tabla de telemetría lleva cuatro sobre las columnas por las que se la consulta habitualmente —la vulnerabilidad, el activo, el estado y la prioridad—, uno sobre la fecha de publicación y uno parcial sobre la columna de confirmación formal posterior, restringido a las filas donde esa columna tiene valor, que son las que registran una promoción de vía. La tabla de auditoría lleva cuatro, sobre el tipo de acción, el tipo de entidad, su identificador y la marca temporal.

Anexo D. Período de estabilización y apertura de la recolección

La sección 3.12 declara un período de estabilización previo a la recolección y excluye sus corridas del análisis. Este anexo documenta esas corridas, los ajustes que las afectaron y las filas que dejaron en la base, de modo que la exclusión pueda verificarse y no quede como una afirmación del texto.

El flujo reestructurado se creó el 23 de agosto de 2026 y se ejecutó desde entonces de forma manual, mientras se ajustaban los puntos que la puesta a prueba iba revelando. Su primera publicación quedó registrada el 26 de agosto a las 13:59 locales, un minuto antes de la primera corrida del disparador programado, que se dispara a las 14:00. Entre el 23 y el 29 de agosto se registraron cuarenta ejecuciones del flujo, treinta y siete de ellas manuales. El cronograma de la sección 3.13 reparte esos días en dos etapas —la estabilización, del 23 al 28 de agosto, y el congelamiento, el 29 —, que este anexo documenta juntas porque ninguna de sus corridas entra en el análisis.

Tabla D1

Actividad diaria del flujo durante el período de estabilización

Día	Ejecuciones	Filas de auditoría	Pares persistidos
23 de agosto	7	0	3
24 de agosto	0	0	0
25 de agosto	3	1	0
26 de agosto	4	2	10
27 de agosto	4	1	22
28 de agosto	4	4	0
29 de agosto	18	1	0

Nota. Actividad del flujo reestructurado entre su publicación y la apertura de la recolección. Las ejecuciones provienen del historial del orquestador, que conserva el registro completo porque la poda automática está desactivada; las filas de auditoría y los pares, de las tablas correspondientes de la base de investigación. Las tres columnas cuentan cosas distintas: una ejecución puede no dejar fila de auditoría si se interrumpió antes de esa rama, y puede no producir pares si la ventana consultada no arrojó correlaciones. Las fechas se expresan en hora local, convertidas desde el tiempo universal coordinado en que la base persiste sus marcas.

Tres de esos ajustes dejaron rastro en los propios datos y conviene declararlos, porque explican por qué las filas del período no son comparables una a una con las posteriores.

El primero afecta a la rama de auditoría. Las corridas del 23 de agosto produjeron pares sin dejar constancia de la corrida: la primera fila de auditoría es del 25 de agosto. El segundo afecta a la estructura de esa fila, que se amplió en dos tramos. Las dos primeras carecen de las tres claves que registran cuántas vulnerabilidades se recibieron, cuántas páginas llegaron y si la respuesta quedó truncada. El conteo de recibidos y el testigo de truncamiento aparecen desde la tercera fila, el 26 de agosto; el conteo de páginas, desde la primera corrida de la recolección, el 30 de agosto. Las veintiocho corridas de la recolección llevan las tres. El tercero afecta a la correlación: las primeras trece filas de telemetría se resolvieron íntegramente por la vía de inferencia, y la vía formal aparece por primera vez el 27 de agosto.

El 29 de agosto concentra dieciocho ejecuciones y ningún par nuevo. Corresponden a la verificación del artefacto contra la base tras la publicación de su versión definitiva, que el registro del orquestador fecha ese mismo día a las 20:04 locales y que es la última anterior a la apertura de la recolección. El procedimiento es el que describe la Fase 6 de la sección 3.12, y la recolección se abrió con la corrida siguiente, el 30 de agosto.

Filas del período que permanecen en la base

Las corridas de estabilización escribieron treinta y cinco pares, que no se eliminaron de la tabla de telemetría. Se conservan por la misma razón por la que el artefacto quedó congelado: borrarlos habría exigido intervenir sobre los datos ya recolectados, y su presencia es preferible a su supresión siempre que quede delimitada.

De las 3.883 filas que contiene la tabla, treinta y cinco provienen del período de estabilización y 3.848 de la recolección. La frontera es la marca de ingesta, que en las filas del período es anterior al 30 de agosto de 2026 en hora local. Toda cifra del Capítulo 5 que se calcule sobre la campaña debe aplicar ese filtro, y declarar cuál de los dos universos está contando.

Las nueve filas de auditoría anteriores al 30 de agosto siguen el mismo criterio: la tabla contiene treinta y siete, de las cuales veintiocho corresponden a corridas de la recolección.

Anexo E. Revisión de la vía formal

La sección 3.12 incluyó en la validación también los pares de la vía formal. El artefacto toma el identificador que publica el NIST, pero lo compara con su propia regla, de modo que revisarlos mide lo que el artefacto hizo con ese dato. Este anexo sirve de contraste para la vía de inferencia de la sección 5.2: muestra si sus errores son propios de la inferencia o del artefacto. A diferencia de la inferencia, la vía formal se juzgó completa, de modo que sus cifras no tienen margen de muestreo.

Tabla E1

Resultado de la revisión de la vía formal

Resultado	Vulnerabilidades	Pares
Registradas por la vía formal	101	459
Correctas en el producto	50	357 (77,8 %)
Error de plataforma	51	102 (22,2 %)

Nota. Pares registrados por la vía formal, incluidos 20 del período de estabilización, según el criterio de la sección 5.1. Se juzgaron todos: 60 vulnerabilidades contra el aviso del fabricante, y 41 que coinciden con el activo solo como plataforma, cuyo error se establece sin consultar el aviso, porque el inventario de esos activos registra solo el sistema operativo. De las 60 juzgadas contra el aviso, 10 resultaron también errores de plataforma, de Chrome sobre macOS, y aportan los 20 pares del período de estabilización; por eso el error de plataforma suma 51 vulnerabilidades y 102 pares. Fuente: tabla de telemetría, revisión del 4 de octubre de 2026 y consulta de cierre a la NVD.

La vía formal también se equivoca, pero de otra manera. Sus 102 errores salen de una sola regla y recaen sobre las dos estaciones con macOS. En vulnerabilidades de programas como Chrome o Acrobat, la NVD declara macOS como plataforma: el sistema sobre el que corre el programa afectado. El artefacto correlacionó esas vulnerabilidades con las dos estaciones, cuyo inventario registra solo el sistema operativo, porque no distingue los dos papeles (sección 5.1).

Sobre esas mismas estaciones, la vía de inferencia no cometió ese error. Registró 450 pares sobre macOS, y los siete casos revisados fueron correctos. Además, ninguno de sus 3.409 pares de la campaña coincide con el activo solo como plataforma. El motivo está en la fuente que lee cada vía. La inferencia lee la lista de productos afectados que publica el fabricante, que nombra el programa y no el sistema. La vía formal lee la configuración de la NVD, que agrega el sistema como plataforma. Es una propiedad de la fuente y no un mérito de la regla: un fabricante que listara el sistema operativo entre los productos afectados la haría fallar igual.

Las dos vías comparten, en cambio, la ceguera de versión. La vía formal compara fabricante y producto, igual que la inferencia, y deja de lado los rangos que la propia configuración declara. Un caso lo muestra. En la falla de GitLab CVE-2026-85706, la inferencia correlacionó una versión que el fabricante excluye, y al día siguiente la vía formal dio el par por confirmado. Sobre los 357 pares correctos, la versión no se puede comprobar, porque son todos de Windows. Además, en Windows la NVD reproduce lo que declara Microsoft, de modo que la revisión confirma que el artefacto fue consistente con su fuente, pero no aporta evidencia independiente sobre la versión.

La revisión juzga el producto y no la exposición. Las dudas de esta vía se resolvieron con el mismo criterio que las de la inferencia (apartado 5.2.1). En 79 de los 357 pares correctos, la falla está en un rol o componente opcional de Windows que el inventario no registra: el servidor DHCP, los servicios para NFS, Message Queuing o el centro de distribución de claves de Kerberos. En esos pares el producto es el afectado, pero el activo puede no ser explotable. El caso más claro es el del centro de distribución de claves, que solo corre en los controladores de dominio: siete de sus nueve pares recaen sobre estaciones y servidores que no lo son. El apartado 7.2.1 trata ese dato entre los que le faltaron al inventario.